

绿盟远程安全评估系统 RSAS 常见问题一本通



扫码提交您的意见反馈



<https://www.nsfocus.com.cn>

■ 版权声明

本文中出现的任何文字叙述、文档格式、插图、照片、方法、过程等内容，除另有特别注明，版权均属北京神州绿盟科技有限公司（简称绿盟科技）所有，受到有关产权及版权法保护。任何个人、机构未经绿盟科技的书面授权许可，不得以任何方式复制或引用本文的任何片断。

■ 内容声明

您购买的产品、服务或特性等受合同和条款的约束，本文档中描述的部分功能可能不在您的购买或使用范围之内。

本文档仅作为使用指导，实际产品可能会由于版本升级或其他原因，与文档描述有略微差异。

■ 免责声明

在使用产品之前，请详细阅读免责声明，一旦开始使用，即认可和接受本声明的全部内容。在使用过程中，绿盟科技不对以下情况承担任何责任：

- 因系统运维或管理人员未及时处理影响系统稳定性和可用性的告警，而造成的数据损失、系统可用性降低等情况。
- 因业务量超过所规划硬件能力而造成的数据损失、系统可用性降低等情况。
- 因自然灾害（包含但不限于水灾、火灾、地震等）或外部原因（包含但不限于断网、断电等）而造成的数据损失、系统可用性降低或不可用等情况。

■ 格式约定

- **粗体字**：菜单、命令和关键字
- *斜体字*：文档名、变量



- **说明**：对描述内容的补充和引用信息



- **提示**：使用设备时的技巧和建议



- **注意**：需要特别注意的事项和重要信息



- **警告**：有可能造成人身伤害的警告信息

目录

1.前言	10
1 常见功能/配置问题 FAQ	11
(一) 手册文档获取地址	11
1. 一本通手册在哪里获取	11
2. 设备手册在哪里获取?	11
(二) 账号密码相关	12
1. 如何登录设备 web 界面?	12
2. web 界面默认账号密码	12
3. 如何重置账号密码?	12
4. RSAS 登录界面提示被锁定怎么办	14
5. RSAS 获取系统配置信息下载的压缩包密码是什么?	14
(三) 串口登录及相关操作	15
1. 如何登录设备串口?	15
2. 如何重置 web 账号允许登录范围?	17
3. 如何查看网口 MAC 地址?	17
(四) 版本查询及升级	18
1. 升级注意事项	18
2. 升级路线简介	19
3. 离线升级长时间卡 20%如何解决?	20
4. 怎么区分设备使用软硬件类型升级包?	21
5. 升级报错: 更新解密失败怎么处理?	21
6. RSAS -X/-P 型号是否支持升级到 V6.0R04F04?	21
7. 设备版本如何降级?	21
8. 涉密版如何确认详细版本信息?	21
9. 涉密版和标准版升级包通用吗?	23
10. 升级到 V6.0R04F04 版本, 扫描任务结果会清空吗	23
11. RSAS 虚拟化 ARM 版本的系统升级包选择哪个呢	24
12. 如何确认系统版本是否存在定制, 是否可以升级	24
13. 国产化 HHA 型号的是哪个位置获取升级包	24
14. 升 V6.0R04F04 版本提示 升级包安装异常, 系统将会重启恢复至最后更新状态,	

请联系支持中心	24
(五) 系统状态及证书参数	24
1. 如何导入证书?	24
2. 使用中设备如何切换证书?	25
3. RSAS 证书到期时间是晚上 24 点还是 0 点	25
4. 设备证书过保后的影响	25
5. 测试证书过期, 正在扫描的任务会不会停?	26
6. 导入证书是否影响扫描任务数据?	26
7. 证书导入失败提示无效证书	26
8. 漏扫导入证书出错, 提示不合法	26
9. 漏扫提示证书状态过期, 但是实际为未过期	26
10. 导入证书时显示 hash 值不符	26
11. 漏扫一登录就跳出个导入许可证页面	27
12. 如何查看查看 IP 授权使用情况	27
13. 授权 IP 数是怎么计算的?	27
14. RSAS V6 扫描主机提示“不在授权 IP 范围内”或者扫描 web 站点提示: IP 授权已使用完	27
15. 授权 IP 范围满了怎么办?	27
16. 怎么查看授权 IP 数使用了多少?	27
17. RSAS web 界面登录提示“IP 地址未授权”?	28
18. 授权任务个数满了如何清理?	28
19. 证书中的“授权扫描口数”指的什么?	28
20. 虚拟化设备证书中“虚拟 CPU 数”含义是什么?	29
21. 磁盘告警超过阈值要怎么清理?	29
(六) 报表展示	30
1. 不想让某个漏洞展示在报表中如何操作?	30
2. 只想输出包含中高危漏洞的离线报表如何操作?	32
3. 误报修正后的漏洞能否恢复?	33
4. 如何自定义报表 logo?	33
5. RSAS 如何查看扫到的漏洞返回信息?	35
6. 输出的离线报表看不到具体端口信息/漏洞详情	35

7. 想要导出部分报表的数据怎么操作	36
8. RSAS 是否支持导出英文格式报表?	37
9. RSAS 输出报表提示无权限操作	37
10. 如何配置任务结束后自动发送报表到邮箱?	38
11. 如何配置任务结束后自动发送报表到 FTP?	40
(七) 数据外发/联动功能	41
1. RSAS 是否支持 syslog?	41
2. RSAS 支持 SNMP agent 吗?	41
3. RSAS 支持与非绿盟漏洞管理平台联动吗?	42
4. RSAS 支持与非绿盟堡垒机联动获取密码吗?	42
5. V6.0R04F04 版本漏扫支持分布式部署么	42
(八) 安装部署及认证	42
1. 虚拟化镜像有 ova 格式的吗?	42
2. 信创 RSAS 虚拟化镜像支持认证模式有哪些	42
3. 虚拟化认证需要放通什么网络策略?	42
4. 云端认证频率和离线状态说明	43
5. 云端认证报错“激活失败: HashSign 字段不存在”怎么处理?	43
6. 云端认证报错“设备激活失败(原因:证书冲突)”原因?	43
7. 虚拟化设备安装过程黑屏后自动关机	43
8. RSAS 重装需要多长时间?	43
9. RSAS 管理口和扫描口是否可以配置同一个网段?	44
10. RSAS 虚拟化怎样扩展空间容量(磁盘)大小?	44
11. KVM 虚拟化漏扫支持 nat 网卡模式吗	44
12. 请问 RSAS 虚拟化支持麒麟系统安装吗	44
13. RSAS 虚拟化镜像支持在海光 CPU 上部署么	44
14. RSAS 是否支持 U 盘部署	44
15. 产品咨询是否支持容器化部署	44
(九) Web 界面访问及路由相关	44
1. 支持的浏览器版本?	44
2. RSAS 能否自定义 web 登录端口?	44
3. RSAS 支持 IPV6 配置吗?	45

4. RSAS 管理口可以做扫描口吗？	45
5. RSAS 最大支持配置路由条数是多少？	45
6. 如何在跨网段访问或扫描时配置缺省路由？	45
7. RSAS 是否支持配置 ACL 从网络层限制 web 访问？	46
8. RSAS 是否存在链路聚合的功能	46
9. RSAS 是否支持配置允许扫描 IP 范围？	47
10. RSAS 对外开放端口有哪些？	47
(十) 漏洞库问题	47
1. 如何查看漏洞是否支持扫描？	47
2. 漏洞库中漏洞检测类型代表什么含义？	49
3. 漏洞模板/配置核查模板能导出离线文件查看吗？	49
4. 想要某个漏洞不展示怎么操作	50
(十一) 资产管理模块	50
1. 资产管理无法从任务结果中自动生成设备节点到资产树？	50
(十二) 任务数据相关	50
1. 任务列表中任务风险值灰色实际点击进去任务有漏洞数据和风险信息	51
2. 任务误删除后能否恢复？	51
3. 系统还原能在不同设备间还原吗？	51
4. RSAS F03 版本任务可以导入到 F04 版本设备吗？	51
5. 恢复出厂设置和重新安装系统是一个操作吗	51
(十三) 数据接口相关	51
1. 数据接口如何设置配置文件参数值去下发任务？	51
2. 数据接口获取任务结果中字段值含义有说明文档吗？	52
3. 数据接口能删除任务吗？	53
(十四) 系统管理-服务	53
1. 如何关闭抓包功能？	53
2. 漏扫如何修改系统时间	53
2 扫描使用 FAQ	54
(一) 扫描所需网络策略及影响	54
1. 扫描目标续开放什么网络策略？	54
2. RSAS 隔着防火墙扫描有什么影响吗？	54

3. 经过 NAT 网络扫描有什么影响？	55
4. RSAS 系统扫描是全连接还是半连接扫描？	55
5. 系统扫描是否支持代理配置？	56
6. 扫描路径中间存在代理设备或扫描目标就是代理设备，导致扫描流量被转发至非扫描目标设备中	56
(二) 系统（主机）扫描任务	56
1. 登陆扫描对目标的影响	56
2. RSAS 系统扫描能否只扫描开放端口不扫漏洞？	56
3. 系统扫描可能会对目标上传文件测试吗？	56
4. 大量资产全端口扫描下，导致中间网络设备宕掉	56
5. 扫描打印机出现打印机自动打印乱码纸张	57
6. 口令猜测导致目标机账号锁死	57
7. NTP/openssh 远程扫描扫不到版本漏洞	57
8. 大批量任务/资产扫描时界面卡慢	58
9. 漏扫能够登录扫描国产化的麒麟、统信系统吗	58
10. 扫描器现在支持 大模型相关框架的扫描吗（比如 AutoGPT、Ollama、LangChain、Open-WebUI、RagFlow 等）	59
(三) Web 扫描任务	59
1. Web 扫描注意事项	59
2. Web 应用扫描后目标站点被增删改数据了	59
3. Web 扫描支持登录扫描的站点类型有哪些？	59
4. 支持 web 弱口令猜测的站点类型	60
5. web 弱口令任务怎么下发	60
6. 为什么 V6.0R04F04 的 web 扫描默认配置扫不出基于 dnslog 平台检测的漏洞例如 log4j 远程代码执行？	60
7. Web 扫描已爬取的链接数为什么大于等于已扫描的链接数？	60
8. 漏扫怎么让 web 只做爬行，不做漏洞扫描	60
9. RSAS web 扫描支持扫动态验证码吗	60
(四) 配置核查任务	61
1. 导入离线核查结果文件提示“导入脚本执行错误”	61
2. 导入离线核查结果文件提示“离线检查工具未更新”	61
3. 离线结果导入失败，提示“此检查结果依赖的模板已经删除，请使用新的离线工	

具”	61
(五) 任务列表	61
1. 暂停操作后为何出现停止按钮瞬时消失的情况?	61
3 常见问题排查流程	62
(一) 判断是否需要登录扫描	62
1. 流程图	62
2. 流程答疑	62
(二) 微软漏洞漏报	66
1. 流程图	66
2. 流程答疑	66
(三) 微软漏洞误报	66
1. 流程图	66
2. 流程答疑	67
3. 排查示例	67
(四) Web 服务器软件及组件类漏洞误报	69
1. 流程图	69
2. 流程答疑	69
3. 排查示例	69
(五) openssh 漏洞漏误报	71
1. 流程图	71
2. 流程答疑	72
3. 排查示例	75
(六) Linux 本地漏洞漏误报排查	75
1. 流程图	75
(七) 各任务类型区别, 怎么判断该下发哪种任务	76
1. 流程图	76
2. 流程答疑	77
(八) 通过系统评估任务的扫描结果确认漏洞来源及判断依据	77
1. 流程图	77
2. 流程答疑	78
(九) 磁盘清理	79

1. 流程图	79
2. 流程答疑	80
(十) 虚拟化漏扫 ping 不通	81
1. 流程图	81
2. 1 流程答疑	82
3. 排查示例	84
(十一) 扫描器造成目标服务器宕机排查流程	91
1. 流程图	91
2. 流程答疑	91
(十二) Web 扫描后目标站点被增删数据排查流程	91
1. 流程图	92
2. 流程答疑	92
(十三) 二次开发接口（数据接口）排查流程	92
1. 流程图	92
2. 流程答疑	93
(十四) 界面无法访问排查流程	93
1. 流程图	93
2. 14.2 流程答疑	94
(十五) Weblogic 系统漏洞误报排查流程	94
1. 流程图	94
2. 流程答疑	95
(十六) BVS 实际值不准确	97
1. 流程图	97
2. 流程答疑	97
3. 排查示例	97
(十七) 离线脚本导入报错	101
1. 流程图	101
2. 流程答疑	102
3. 排查示例	102
(十八) RDP 登录失败排查流程	103
1. 流程图	103

2. 流程答疑	104
(十九) SMB 登录失败排除流程	115
1. 流程图	115
2. 流程答疑	115
(二十) SSH 登陆失败排查流程	125
1. 流程图	125
2. 流程答疑	126
(二十一) 扫描主机/站点不存活/可达, 但实际存活/可达	126
1. 流程图	126
2. 流程答疑	126
(二十二) 认证、联动失败/离线	127
1. 流程图	127
2. 流程答疑	128
(二十三) 升级卡住、失败排查流程	129
1. 流程图	129
(二十四) 操作系统识别错误排查流程	130
1. 流程图	130
2. 流程答疑	130
(二十五) 周期任务不执行排查流程	131
1. 流程图	131
2. 排查示例	132
(二十六) 系统扫描两次扫描结果存在差异	132
1. 流程图	132
(二十七) web 扫描两次扫描结果存在差异	133
1. 27.1 流程图	133

1.前言

本文详细介绍了绿盟远程安全评估系统（NSFOCUS Remote Security Assessment System）常见问题手册，针对在日常使用产品过程中提供帮助，本手册仅作为使用指导，实际产品可能会由于版本升级或其他原因，与手册描述有略微差异，如手册内容不能满足您的问题转接绿盟售后服务

售后服务

盟管家自助服务 推荐

- 网站: <https://user.nsfocus.com>
- 微信公众号: 搜索并关注“绿盟科技技术服务”，单击“盟管家”
- 二维码:



- 服务热线

业务类型	支持热线	E-mail	服务时间
安全产品与平台售后服务	400-818-6868 转接 0	support@nsfocus.com	周一至周日 7×24 小时全天服务
云安全服务	400-818-6868 转接 2	rs@nsfocus.com	
购买咨询	400-818-6868 转接 1	csc@nsfocus.com	

1 常见功能/配置问题 FAQ

(一) 手册文档获取地址

1. 一本通手册在哪里获取

BBS 社区-自助专区-运维管理-安全管理-绿盟远程安全评估系统 RSAS

<https://bbs.nsfocus.com/>

2. 设备手册在哪里获取？

用户手册、数据接口手册在设备关于页面下载：



snmp 说明文档、syslog 说明文档在功能页旁下载：



或者登录绿盟科技社区，在 RSAS 产品页中获取下载：

<https://bbs.nsfocus.com/site/files/list?productid=377>



(二) 账号密码相关

1. 如何登录设备 web 界面？

web 登录：默认访问方式 [HTTPS://IP](https://ip)

出厂默认 IP 信息：

V6.0R02F00 及以上版本：

管理口：<https://192.168.1.1>

扫描口 1：<https://192.168.2.1>

2. web 界面默认账号密码

标品 V6.0R02F00 及以上版本：

系统管理员：admin/admin（V6.0R04F03 版本为 Admin123!@#，除此版本外，其他都为 admin）

审计管理员：auditor/auditor

涉密版本：

安全管理员：sysmanager/sysmanager

系统管理员：sysadmin/sysadmin

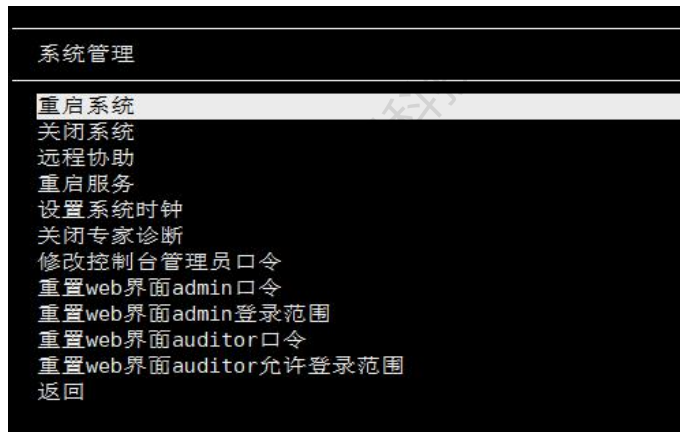
审计管理员：sysauditor/sysauditor

3. 如何重置账号密码？

忘记 web 界面账号登录密码，系统默认账号可通过登录串口进行重置：

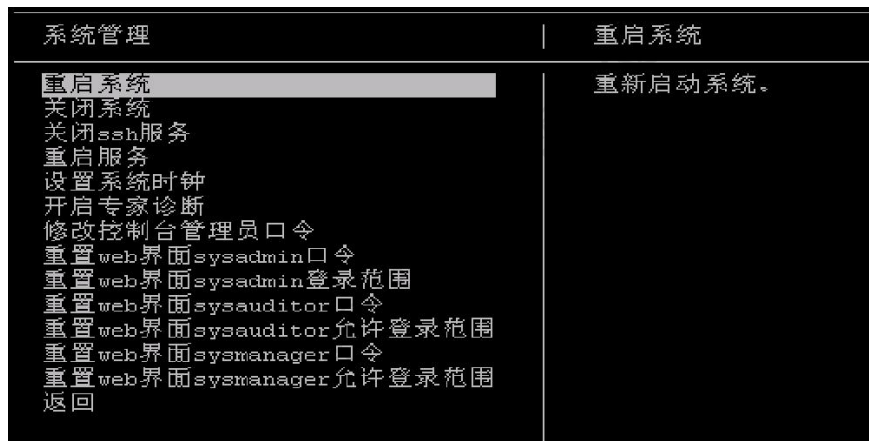
标准版：

登录串口后，进入 系统管理 > 重置 web 界面 admin 口令/重置 web 界面 auditor 口令



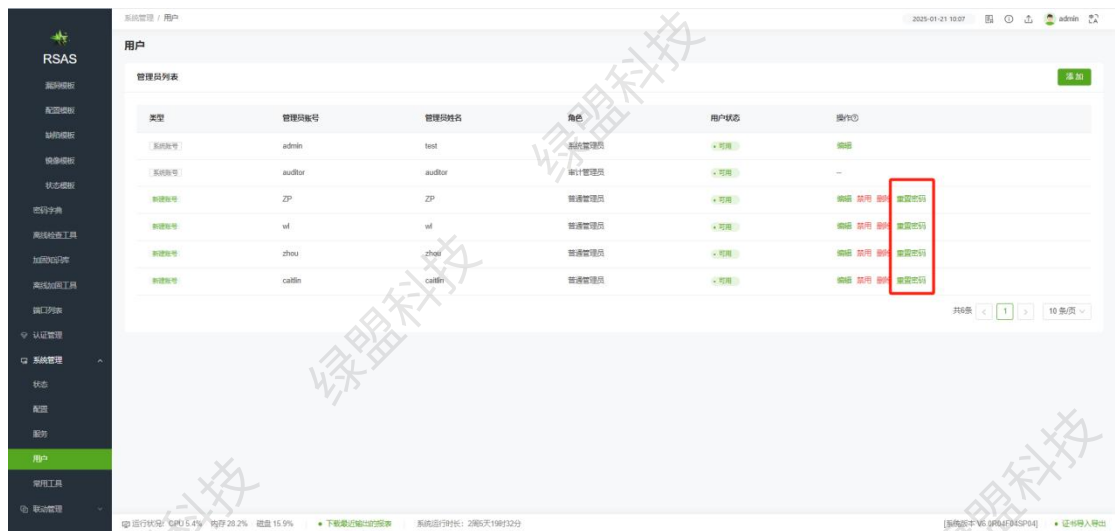
涉密版：

登录串口后，进入 系统管理 > 重置 web 界面 sysadmin 口令/重置 web 界面 sysauditor 口令/重置 web 界面 sysmanager 口令



自定义用户可通过登录系统管理员（标准版：admin、涉密版：sysadmin），在系统管理-用户页面点击对应用户重置密码。

V6.0R04F04 及以上版本：



V6.0R04F04 以下版本:



4. RSAS 登录界面提示被锁定怎么办

一般锁定是因账号密码错误多次登录造成，确认被锁定策略，如果是 ip 被锁定，可以更换一个 ip 地址登录

如果是账号被锁定，一般默认锁定时间是 20min，锁定期间不要重复登录，待锁定时间过后在重新登陆

5. RSAS 获取系统配置信息下载的压缩包密码是什么？

获取系统配置信息的具体操作如下：

- 1、选择菜单 系统管理 > 配置 > 系统配置，进入系统配置页面，“获取系统配置信息”区域
- 2、单击【一键获取】按钮，下载压缩包至本地保存。
- 3、使用密码“RSAS 设备的 HASH”，解压压缩包，查看系统信息即可。

注意：hash 不一致无法解密



(三) 串口登录及相关操作

1. 如何登录设备串口？

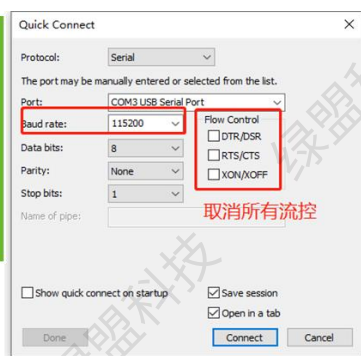
登录参数：默认账号密码：conadmin/conadmin，波特率：115200

硬件设备使用串口线连接到 S 口，在连接电脑上右键计算机-管理，点击设备管理器查看串口端口号，使用终端工具连接上述查询到的 COM 口。

① 串口连线方法



②使用终端工具连接上述查询到的COM口。
终端工具举例：
secureCRT、
PUTTY等。
以secureCRT为例连接配置如下：



虚拟化设备，直接打开虚拟机控制台页面，使用账号密码登录即可。

注意事项：

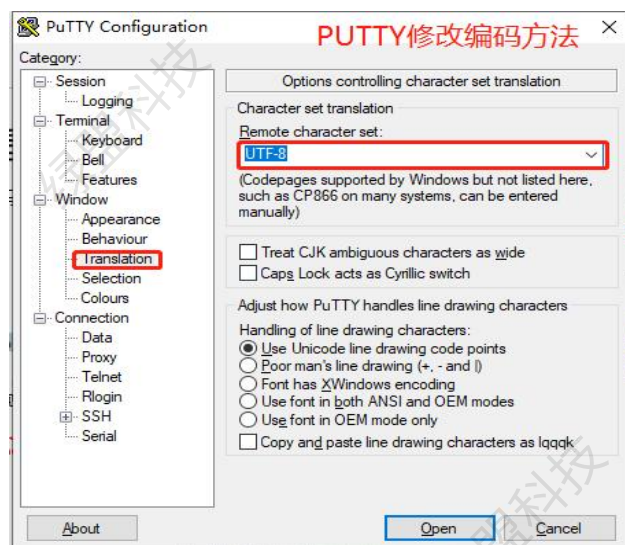
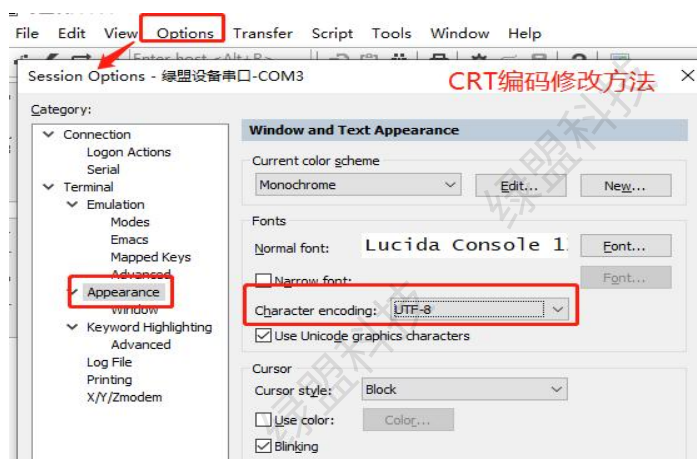
①如果串口登录后出现乱码，请更换编码测试。

推荐编码：

secureCRT： UTF-8、 default、 GB2312

PUTTY： UTF-8、 use font encoding

②如果当前终端工具串口显示行错乱，请更换终端工具连接



2. 如何重置 web 账号允许登录范围？

如果 web 账号设置了允许登录范围，忘记该登录范围，导致登录 ip 不在范围内无法成功登录 web 界面，可通过串口操作重置。

标准版：

登串口，进入 系统管理 > 重置 web 界面 admin 登录范围/重置 web 界面 auditor 登录范围

涉密版：

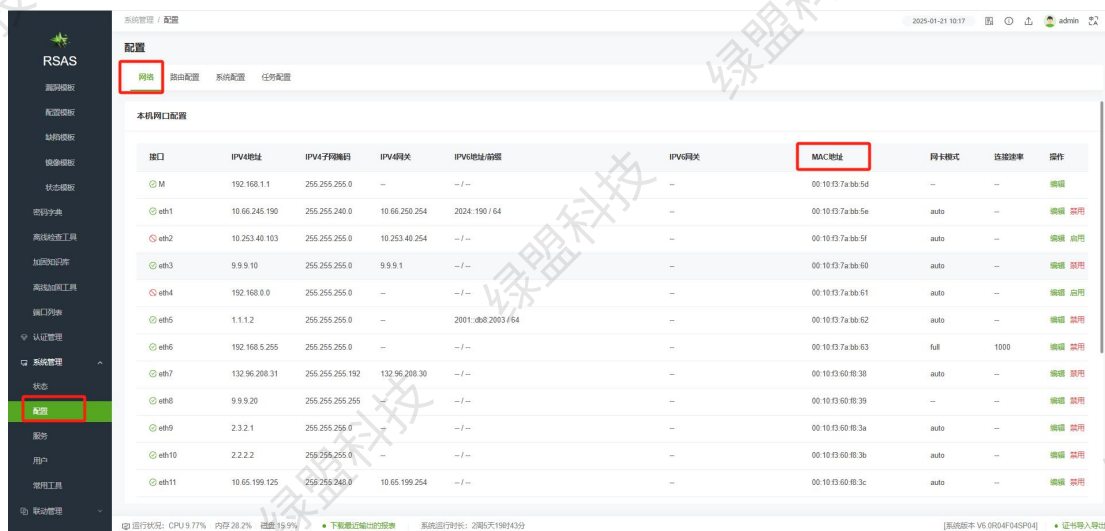
登录串口后，进入 系统管理 > 重置 web 界面 sysadmin 登录范围/重置 web 界

面 sysauditor 登录范围/重置 web 界面 sysmanager 登录范围

3. 如何查看网口 MAC 地址？

V6.0R04F04 及以上版本：

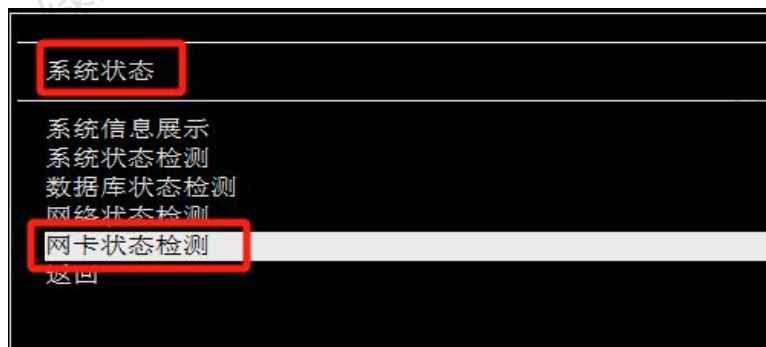
登录 web 界面，点击 系统管理 > 配置 > 网络，即可查看各网口的 mac 地址：



接口	IPv4地址	IPv4子网掩码	IPv4网关	IPv6地址/前缀	IPv6网关	MAC地址	网卡模式	连接速率	操作
M	192.168.1.1	255.255.255.0	--	--	--	00:10:13:7a:b6:5d	--	--	编辑
eth1	10.66.245.190	255.255.240.0	10.66.250.254	2024:190/64	--	00:10:13:7a:b6:5e	auto	--	编辑 禁用
eth2	10.253.40.103	255.255.255.0	10.253.40.254	--	--	00:10:13:7a:b6:5f	auto	--	编辑 禁用
eth3	9.9.9.10	255.255.255.0	9.9.9.1	--	--	00:10:13:7a:b6:60	auto	--	编辑 禁用
eth4	192.168.0.0	255.255.255.0	--	--	--	00:10:13:7a:b6:61	auto	--	编辑 禁用
eth5	1.1.1.2	255.255.255.0	--	2001:db8:2003/64	--	00:10:13:7a:b6:62	auto	--	编辑 禁用
eth6	192.168.5.255	255.255.255.0	--	--	--	00:10:13:7a:b6:63	full	1000	编辑 禁用
eth7	132.96.208.31	255.255.255.192	132.96.208.30	--	--	00:10:13:60:b6:30	auto	--	编辑 禁用
eth8	9.9.9.20	255.255.255.255	--	--	--	00:10:13:60:b6:39	--	--	编辑 禁用
eth9	2.3.2.1	255.255.255.0	--	--	--	00:10:13:60:b6:3a	auto	--	编辑 禁用
eth10	2.2.2.2	255.255.255.0	--	--	--	00:10:13:60:b6:3b	auto	--	编辑 禁用
eth11	10.65.199.125	255.255.240.0	10.65.199.254	--	--	00:10:13:60:b6:3c	auto	--	编辑 禁用

V6.0R04F04 以下版本：

登录串口，进入 系统状态 > 网卡状态检测，在回显出来的对应网卡信息中查看 ether 信息即 MAC 地址信息，eth0 为管理口，eth1 为扫描口 1，eth2 为扫描口 2，以此类推。



```
docker0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
inet 1.1.0.1 netmask 255.255.255.0 broadcast 1.1.0.255
ether 02:42:01:a6:15:81 txqueuelen 0 (Ethernet)
RX packets 0 bytes 0 (0.0 B)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 0 bytes 0 (0.0 B)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

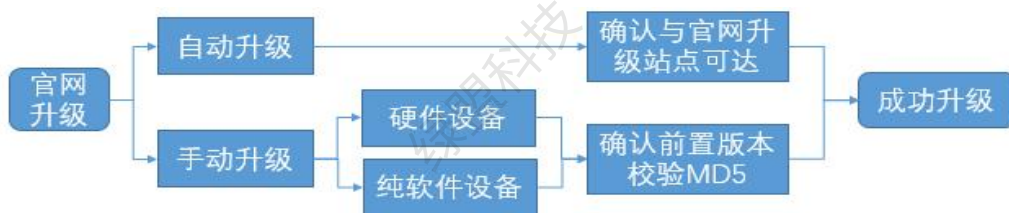
eth0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
inet 192.168.1.1 netmask 255.255.255.0 broadcast 192.168.1.255
ether 08:35:71:22:8c:06 txqueuelen 1000 (Ethernet)
RX packets 0 bytes 0 (0.0 B)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 0 bytes 0 (0.0 B)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

eth1: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
inet 111.2.114.203 netmask 255.255.255.0 broadcast 111.2.114.255
inet6 fe80::a35:71ff:fe22:8c07 prefixlen 64 scopeid 0x20<link>
ether 08:35:71:22:8c:07 txqueuelen 1000 (Ethernet)
RX packets 26649783 bytes 3498268878 (3.2 GiB)
RX errors 0 dropped 8124 overruns 0 frame 0
TX packets 28194823 bytes 2469614770 (2.3 GiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

（四）版本查询及升级

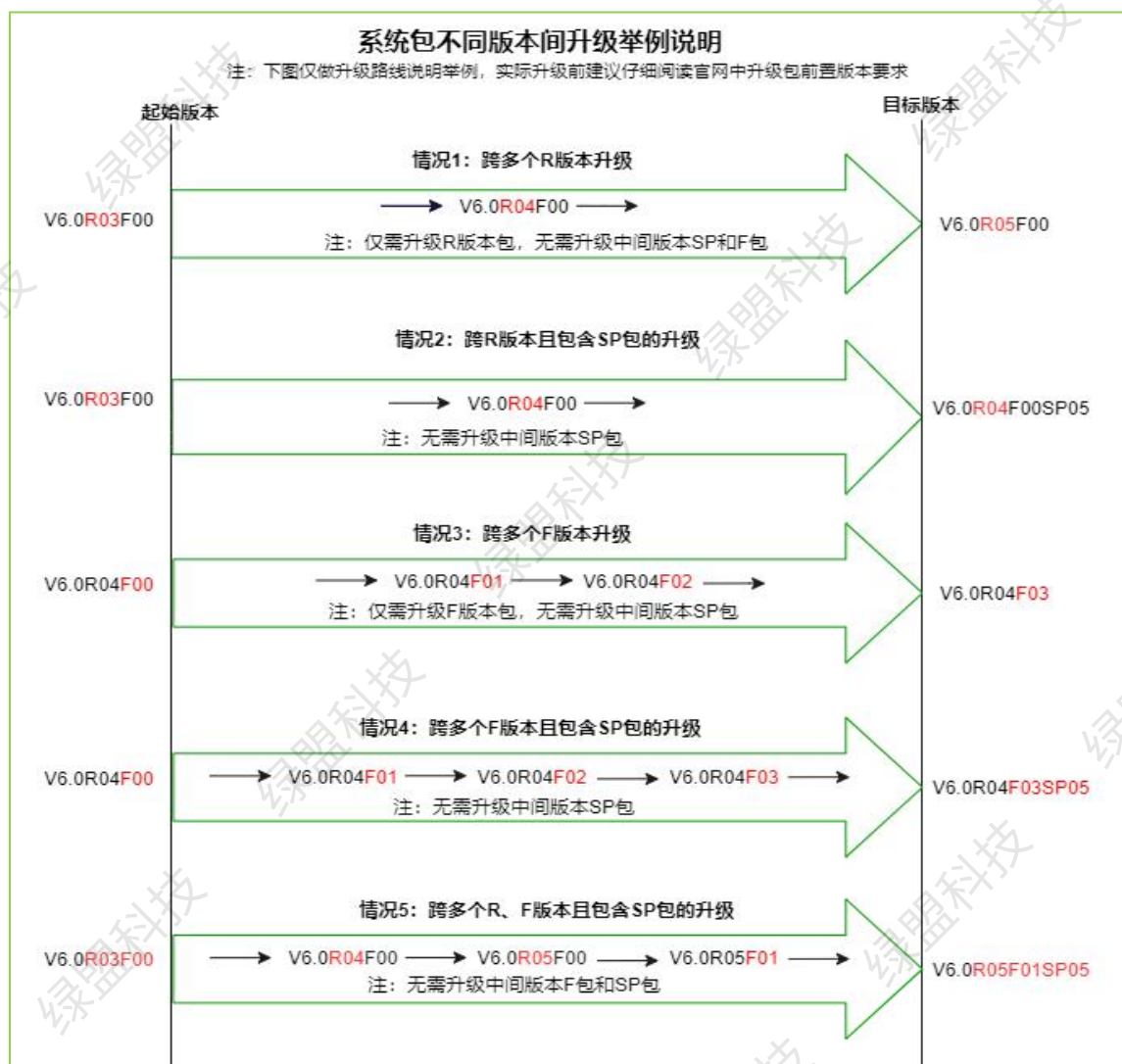
1. 升级注意事项

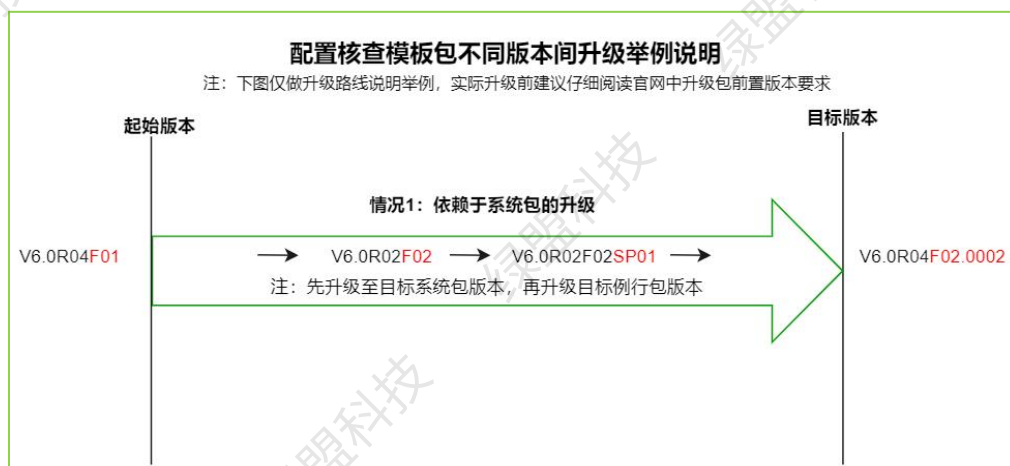
- 定时升级/立即升级需要配置 DNS、缺省网关（系统管理-配置-网络中设置），且保证 RSAS 到升级站点网络可达，官网升级站点地址：
[HTTP://UPDATE.NSFOCUS.COM](http://update.nsfocus.com) 或 [HTTPS://UPDATE.NSFOCUS.COM](https://update.nsfocus.com)
80 或 443 端口；可使用常用工具中 curl 命令验证升级站点是否网口可达。
- 当系统中存在正在运行的任务、正在创建的还原点、正在执行还原操作、正在执行漏洞验证操作时，无法进行升级操作，待以上操作执行完成后，方可执行升级操作。
- 定时升级时，如已到指定时间，系统中仍存在正在运行的任务、还原点和漏洞验证操作时，系统无法进行升级，当以上操作执行完成后，系统会再次调度升级进程执行升级。
- 过期的正式证书只支持升级过期时间之前发布的升级包。
- 手动升级前，需要检查升级包 MD5 值是否与官方发布 MD5 值一致，仔细阅读升级官网升级说明前置版本要求。
- 如果遇到升级疑似卡住的现象，千万不要刷新当前升级页面，可新开一个浏览器标签页进行进度查看。



2. 升级路线简介

手动升级有严格的前置版本要求，下面举例说明升级包升级路线。





3. 离线升级长时间卡 20%如何解决？

离线升级，提交升级包后，进度一直卡在 20%无变化（例如等待了半小时以上），且重开浏览器页签查看版本未升级上去，可尝试以下操作来解决：

- 尝试更换浏览器重新升级
- 尝试更换网络环境（最好直连）重新上传升级包升级——有的网络环境限速限流或者现在上传，例如 VPN 环境
- 尝试重启设备，重新升级

长时间卡在其他进度时，建议先重开个页签看版本是否已升级上去，如果没有则保留问题环境联系售后排障。

4. 怎么区分设备使用软硬件类型升级包？

RSAS 虚拟化设备采用加密狗方式认证，升级应选硬件设备分类，云端认证、集中授权、ESP-L 认证设备选择软件分类升级包

RSAS 硬件盒子设备选硬件分类升级包



5. 升级报错：更新解密失败怎么处理？

- 检查升级包类型（云端认证、集中授权、ESP-L 认证设备，升级官网上传证书下载软件升级包升级）
- 检查升级包的完整性，校验升级包 md5 值以及升级包名称（不能随意更改升级包名称）
- 标品 X86 架构的升级包和国产化 XC 的升级包是分开的，不要下载错误

6. RSAS -X/-P 型号是否支持升级到 V6.0R04F04？

不支持，这两款型号设备属于低端型号，性能不足以支撑，因此不能升级 V6.0R04F04。如需使用 V6.0R04F04 版本，可考虑将设备以旧换新。

7. 设备版本如何降级？

产品本身没有直接降级方法，可通过串口重装系统，恢复到出厂低版本，然后再升级到想要的某个版本上。注意：重装后仅保留证书和网络配置，所有任务数据、报表数据等数据信息将全部清空。

8. 涉密版如何确认详细版本信息？

涉密版因为保密要求，系统状态中设备版本信息均已大版本展示，没有详细版本展示。此时如需获取详细版本，可通过以下方式：

方法一：通过获取系统配置信息获取详细版本，操作方法如下：

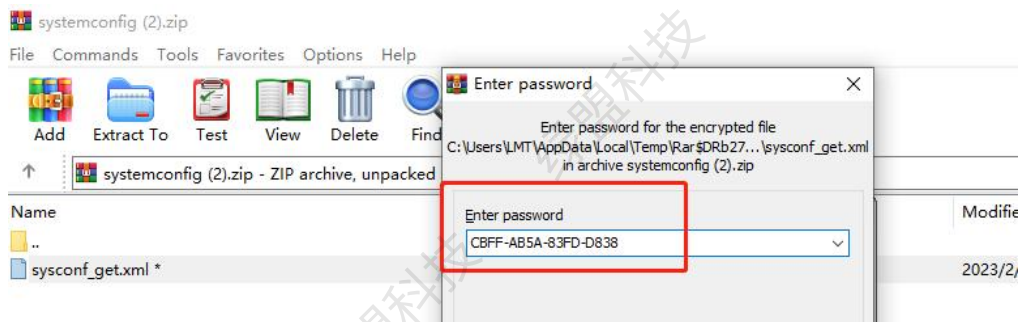
The screenshot shows the RSAS web interface. On the left is a sidebar with navigation options: 新建任务, 任务列表, 报表输出, 仪表盘, 告警平台, 资产管理, 认证管理, 模板管理, 系统管理, 状态, 配置 (highlighted), 服务, 用户, 常用工具. The main content area has tabs for 网络, 路由配置, 系统配置, and 任务配置. Under 系统配置, there are sections for 服务器证书 (with '选择文件' and '未选择任何文件' buttons), 服务器证书私钥 (with '选择文件' and '未选择任何文件' buttons), and 获取系统配置信息 (with a '一键获取' button highlighted by a red box). Below this is the 'NF联动' section with fields for 联动状态, 联动IP, and 密码, and a '确定' button.

获取成功后会下载一个 zip 包，该 zip 包解压密码为该设备的 HASH 值，如下：

The screenshot shows the '绿盟网络安全漏洞扫描系统 V6.0' interface. The left sidebar has 系统管理, 状态 (highlighted), 配置, 服务, 用户, and 常用工具. The main content area shows system status details. A table lists various components and their versions:

产品型号	NX3-VM
系统版本	V6.0
系统插件版本	V6.0
Web插件版本	V6.0
代码审计规则版本	V6.0
配置核查模板版本	V6.0
资产指纹版本	V6.0
出厂版本	6.0
插件总数	2526个
漏洞总数(系统/应用)	243905(242647/1258)个
对应CVE编号数	58867个
代码审计缺陷数	221个
代码审计规则数	1112个
授权任务个数	8000个
已用任务个数	0个
设备HASH	CBFF-AB5A-83FD-D838

The '设备HASH' (Device Hash) value is highlighted with a red box.



解压开后 xml 中展示的具体版本信息如下：

```
<?xml version="1.0" encoding="utf-8"?>
<!--系统配置信息-->
<sysconf>
<!--系统状态信息-->
<statusinfo>
  <!--产品型号-->
  <system_type>VM</system_type>
  <!--设备HASH-->
  <hash>CBFF-AB5A-83FD-D838</hash>
  <!--出厂版本-->
  <firmware>V6.0R04F02</firmware>
  <!--系统版本-->
  <sys_version>V6.0R04F02</sys_version>
  <!--系统插件版本-->
  <vulsys_version>V6.0R02F01.2810</vulsys_version>
  <!--web插件版本-->
  <vulweb_version>V6.0R02F00.2709</vulweb_version>
</statusinfo>
<!--系统证书信息-->
<authinfo>
```

方法二：通过历史更新查看

登录 web 界面，点击右上角【升级】或者是在【系统管理】-【服务】中，通过【历史升级】-【已安装系统升级包】查看最新一次安装的版本即为设备当前版本信息。

历史更新记录				
升级包名称	文件大小	发布时间	安装时间	描述
rsas-sys-V6.0R02F01.dat	60.5M	2016-01-25	2016-04-02	新增云端授权、集中授权等功能
rsas-sys-V6.0R02F01SP01.dat	2.6M	2016-03-15	2016-04-02	V6.0R02F01 SP01 系统升级包
rsas-sys-V6.0R02F01SP02.dat	1.9M	2016-04-14	2016-04-02	V6.0R02F01 SP02 系统升级包
rsas-sys-V6.0R02F01SP03.dat	2.4M	2016-05-09	2016-05-13	系统升级包
rsas-sys-V6.0R02F01SP04.dat	2.7M	2016-05-26	2016-05-30	系统升级包
已安装系统插件升级包				

9. 涉密版和标准版升级包通用吗？

通用。涉密版和标准版受证书控制来实现三权分立，升级包未做区分。

10. 升级到 V6.0R04F04 版本，扫描任务结果会清空吗

升级不影响任务

11. RSAS 虚拟化 ARM 版本的系统升级包选择哪个呢

一般虚拟化 RSAS ARM 镜像支持云端认证，可选择对应软件包分类下的 HFC 分类下的系统包，插件包不区分型号，可直接升级

12. 如何确认系统版本是否存在定制，是否可以升级

可通过系统版本号字母进行判断，如果有定制，则版本号中带 M，如 V6.0M04F03SP06，此版本为定制版本，不可升级系统版本，插件包可正常升级，如果版本号不含 M，如 V6.0R04F04SP06，则是常规系统版本命名，可升级系统包

13. 国产化 HHA 型号的是哪个位置获取升级包

下载标品包（请勿下载飞腾系列下的包）

14. 升 V6.0R04F04 版本提示 升级包安装异常,系统将会重启恢复至最后更新状态,请联系支持中心

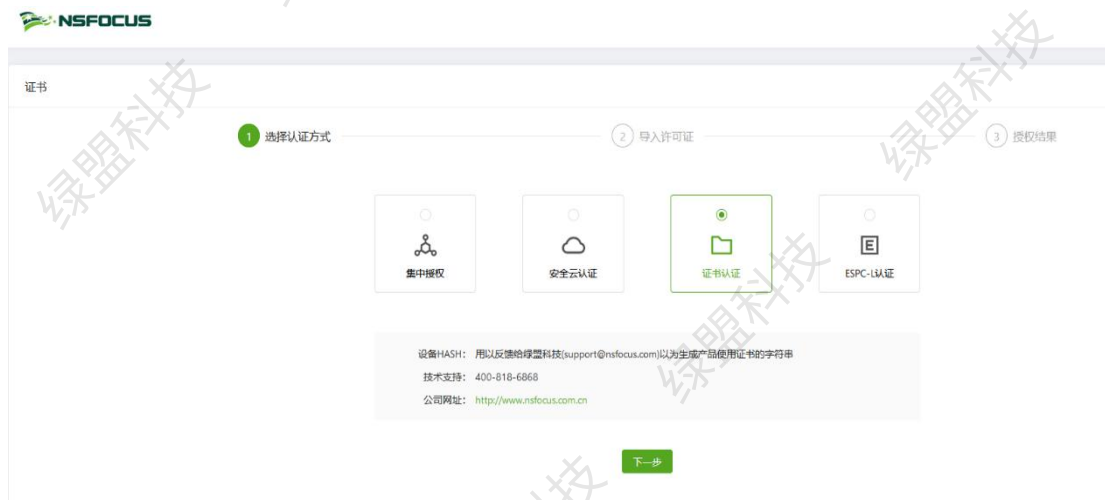
请确认设备型号，NX3-P,NX3-X,NX3-HDBX,不支持升级到 V6.0R04F04 版本，可正常升级插件版本

（五）系统状态及证书参数

1. 如何导入证书？

硬件设备，首次登录 web 界面时，上传设备 HASH 对应证书即可；

虚拟化设备，首次登录 web 界面时，选择对应认证方式上传证书即可，如下图所示。



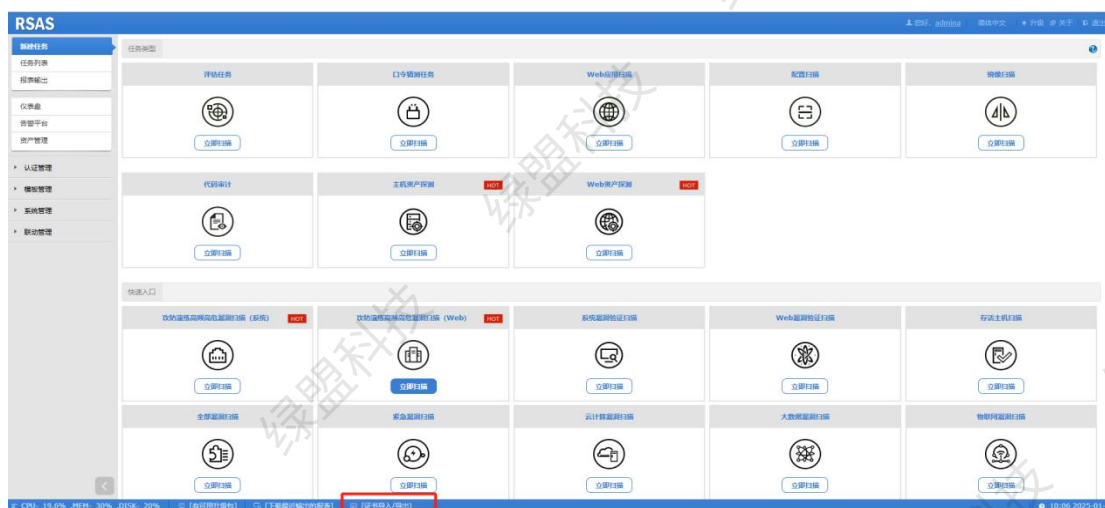
2. 使用中设备如何切换证书？

点击设备界面下方状态栏【证书导入/导出】按钮操作：

V6.0R04F04 及以上版本：



V6.0R04F04 以下版本：



3. RSAS 证书到期时间是晚上 24 点还是 0 点

举例，如显示证书截止时间为 4.18 号，则过期时间是 18 号 23:59，也就是 19 号 0 点

4. 设备证书过保后的影响

- 1、测试证书过保后会提示导入证书，功能不可用
- 2、正式证书过保后，在过保时间以后发布的升级包不可升级，过保日期之前的发布升级包还可以继续升级，设备其他自身功能使用正常
- 3、正式证书过保后，不再享受售后技术支持团队免费支持

5. 测试证书过期，正在扫描的任务会不会停？

正在执行的任务，如果执行过程中证书过期了，不会影响该任务执行，但是测试证书过期后界面需重新导入证书后才能登录界面看到任务信息。

6. 导入证书是否影响扫描任务数据？

不影响

7. 证书导入失败提示无效证书

- 1、首先确认证书起始时间在当前时间有效日期内，如当前日期为 25 年 4.20 号，证书开始时间要早于或等于 4.20 号，结束时间要晚于 4.20 号，否则无法导入
- 2、确保设备系统时间正确，当前系统时间不在证书时间范围内，也会无法导入

8. 漏扫导入证书出错，提示不合法

- 1、检查设备系统时间，是否在证书时间范围内（如果界面无法登录，登录串口可以查看时间），若系统时间不准确可修改系统时间
- 2、若系统时间没问题，请检查证书起止时间是否包含当前时间，如不包含，请调整证书起止时间或等符合证书开始时间再导入
- 3、检查证书格式，如果是集中授权、云端认证或者 ESPL 认证，证书开头为 CA 格式开头文件，如果是硬件设备或者加密狗认证则证书文件无 CA 开头

9. 漏扫提示证书状态过期，但是实际为未过期

- 1、检查设备系统时间，是否在证书时间范围内（如果界面无法登录，登录串口可以查看时间），若系统时间不准确可修改系统时间
- 2、若系统时间没问题，请检查证书起止时间是否包含当前时间，如不包含，请调整证书起止时间或等符合证书开始时间再导入

10. 导入证书时显示 hash 值不符

- 1、解析证书文件查看证书 hash（也可以通过申请证书的邮件信息确认证书里的 hash）
- 2、确认证书 hash 和当前设备 hash 不符，如果设备是硬件，确认硬件设备是否返修过或者更换过配件，如换过内存、磁盘等，更换配件引起的 hash 变更，可联系硬件维修工程师协助申请新的证书
- 3、如果设备是加密狗认证，请确认加密狗是否变化，如有更换 hash 也会变化，请换会对应加密狗

4、如果设备是去狗认证，请确认是否设备虚拟化部署环境是否变化，如虚拟机做了迁移，也会引起 hash 变化，请联系销售重新做证书，并作废原证书

11. 漏扫一登录就跳出个导入许可证页面

设备导入的是测试证书，测试证书过期后会自动回到导入证书页面

12. 如何查看查看 IP 授权使用情况

查看系统管理-状态-证书状态，查看授权 IP 范围是否个数已使用完

13. 授权 IP 数是怎么计算的？

记录存活的 IP 数记录到授权 IP 范围列表中。

如果扫描的是站点，那么记录站点解析后的 IP，计算方式如下：

域名授权计算方式			
类型	扫描目标形式	解析后实例	计算方式
1	192.168.1.1	192.168.1.1	记录 1 个授权
2	http://192.168.1.1	192.168.1.1	记录 1 个授权
3	https://192.168.1.1	192.168.1.1	记录 1 个授权
4	http://www.test.com	192.168.1.1	记录 1 个授权
5	http://www.test.com:8080	192.168.1.1	记录 1 个授权

14. RSAS V6 扫描主机提示“不在授权 IP 范围内”或者扫描 web 站点提示：IP 授权已使用完

查看系统管理-状态-证书状态，查看授权 IP 范围是否个数已使用完

15. 授权 IP 范围满了怎么办？

正式证书在保时间内，每年可免费申请一次清空包服务。免费清空次数使用完后如果仍需清空包，则需要联系销售购买。

申请方式：联系绿盟售后，提供设备 HASH 信息、版本信息、认证方式 进行申请

16. 怎么查看授权 IP 数使用了多少？

登录设备系统管理-状态—证书状态，授权 IP 模块会显示已用个数，点击对应使用个数，会显示具体授权 IP

17. RSAS web 界面登录提示“IP 地址未授权”？

请检查用于登录的电脑 IP 是否在该账号设置的允许登录范围内，如果不在请更换为范围内 IP 登录，如果忘记允许登录范围 IP 是什么，可在串口进行重置。

18. 授权任务个数满了如何清理？

授权任务个数跟设备型号相关，占满后可通过删除任务列表中的历史任务进行清理释放

19. 证书中的“授权扫描口数”指的什么？

代表设备实际能使用的扫描口个数，启用扫描口超过证书限制后将无法再启用新的扫描口。数值对应关系如下：

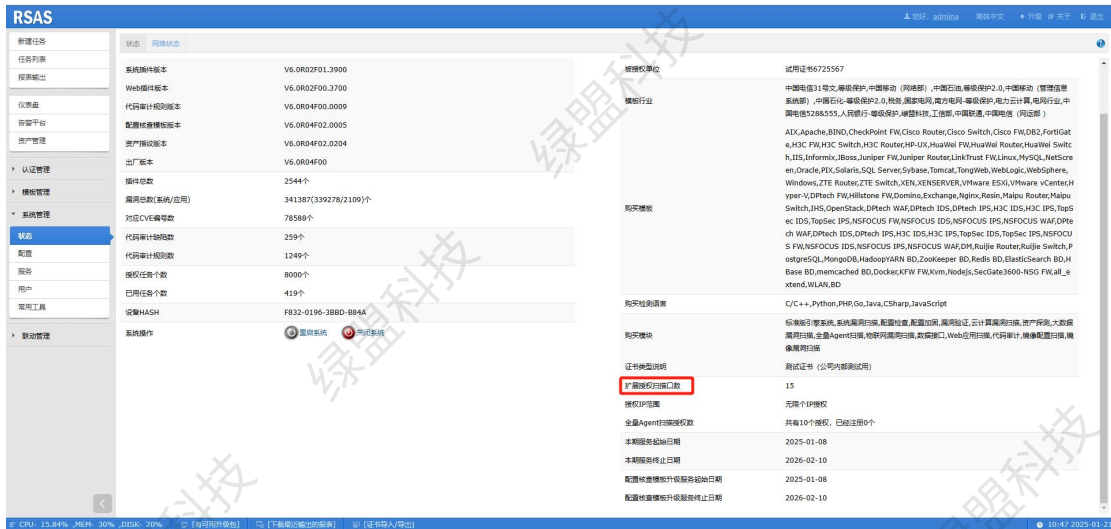
V6.0R04F04 及以上版本：

RSAS 实际可用的扫描口=证书“授权可用扫描口数”



V6.0R04F04 以下版本：

RSAS 实际可用的扫描口=证书“扩展授权扫描口数”+1



20. 虚拟化设备证书中“虚拟 CPU 数”含义是什么？

虚拟化设备并不是实际配置了多少 CPU 数就能使用多少，实际可配置使用的 CPU 数受证书中虚拟 CPU 数授权控制，对应关系如下：

V6.0R04F04 及以上版本：

RSAS 实际可用的 CPU 核数=证书“授权可用虚拟 CPU 数”，最大值 8

V6.0R04F04 以下版本：

RSAS 实际可用的 CPU 核数=证书“扩展授权虚拟 CPU 数”+2，最大值 8

RSAS 如何配置 hosts？

问题场景：客户扫描某些站点，不能通过公共 dns 解析，希望添加 hosts 记录。

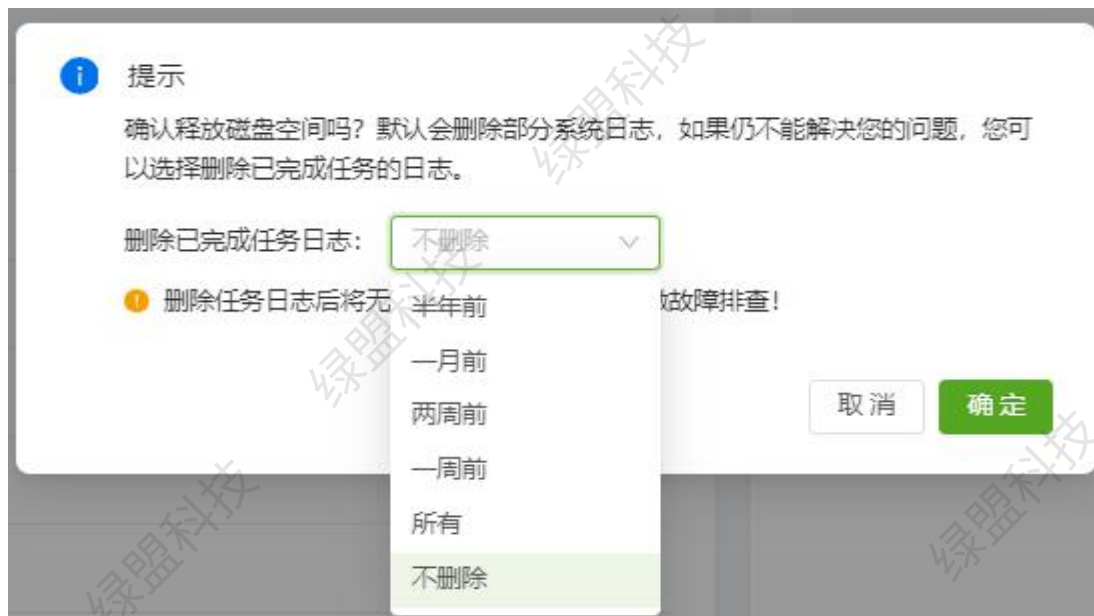
如何配置：V6.0R04F01SP04 开始支持 hosts 配置功能，按照问号中说明添加 ip 域名记录即可。

21. 磁盘告警超过阈值要怎么清理？

V6.0R04F04 及以上版本

点系统管理-状态-运行状态，磁盘旁边的释放空间试试，按提示选择情况数据

资源状态				系统资源优化
状态	资源项	资源使用率	操作	
正常	CPU	51.1 %	—	
正常	内存	34.4 %	—	
使用率过高	硬盘	54.6 %	释放空间	



V6.0R04F04 以下版本:

可先尝试删除任务列表中历史任务以及报表输出—报表列表中历史报表数据,如清理后磁盘还告警,可联系售后 400 进行处理

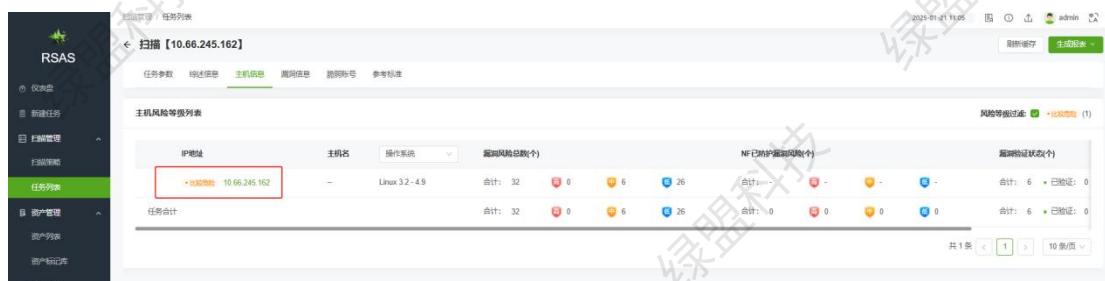
(六) 报表展示

1. 不想让某个漏洞展示在报表中如何操作?

问题场景: 扫描结束后有些漏洞认为误报或者暂时无法修复,但不想在报表上看到该漏洞,可以点击误报修正操作来屏蔽该漏洞。

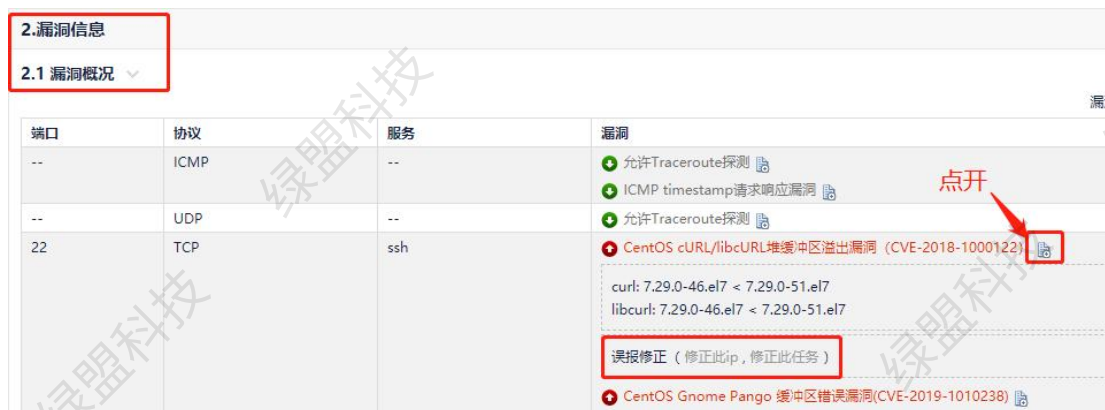
点击任务中对应 IP 的在线主机报表,在漏洞概况-漏洞信息下,点开漏洞获取详情按钮,在最下方有“误报修正”的选项,设置好后点击确定即可。修正后的任务输出的离线报表也看不到已修正的漏洞。

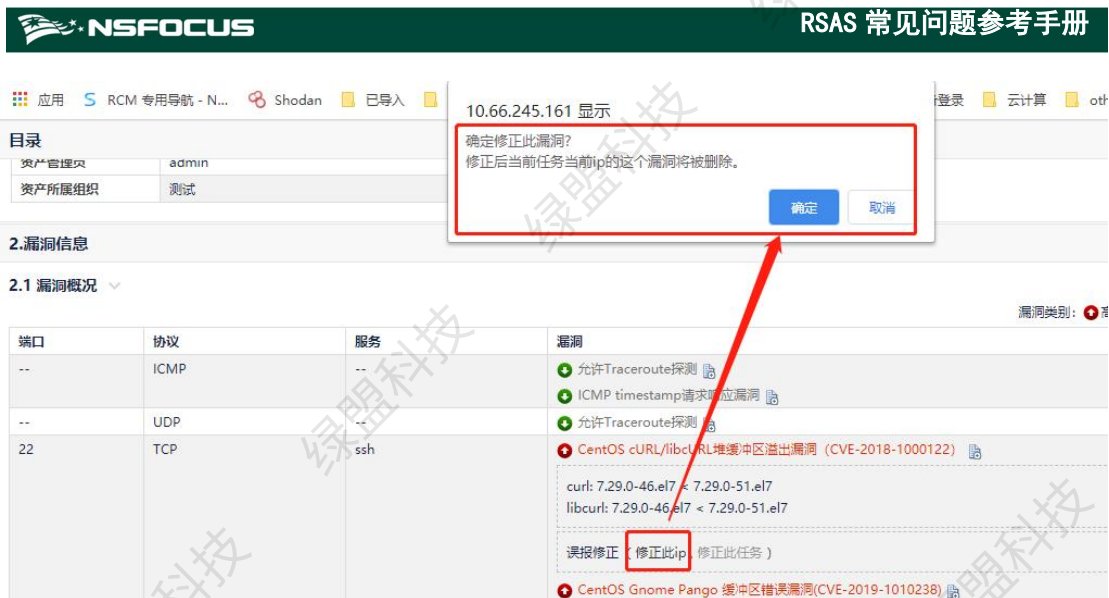
V6.0R04F04 及以上版本:





V6.0R04F04 以下版本:





2. 只想输出包含中高危漏洞的离线报表如何操作?

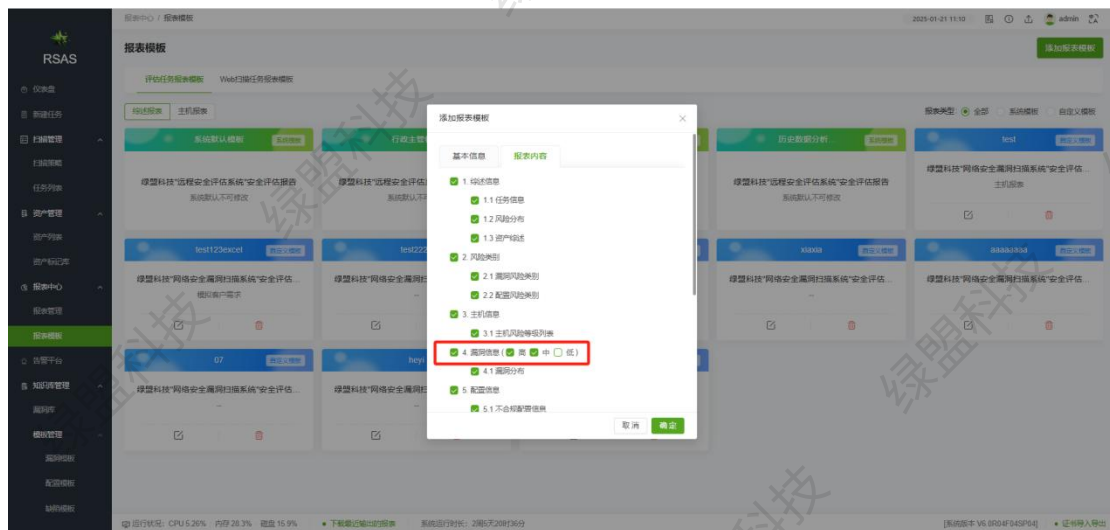
可通过自定义 综述报表和主机报表 报表模板, 报表模板中自定义仅勾选高中危漏洞, 保存模板, 输出时选择该报表模板输出即可。

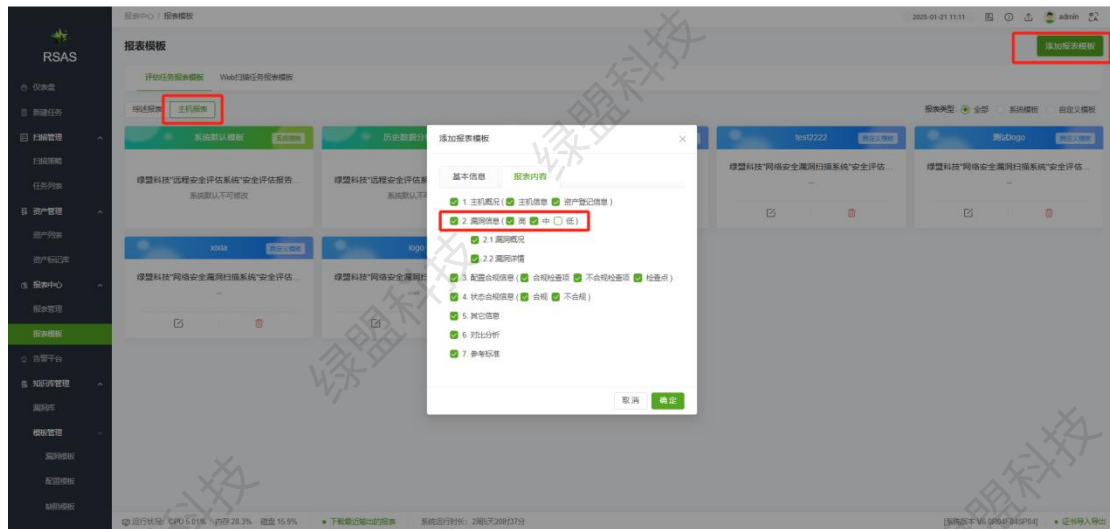
自定义报表模板操作路径:

V6.0R04F04 及以上版本: 报表中心-报表模板

V6.0R04F04 以下版本: 模板管理-报表模板

操作方法以 V6.0R04F04 及以上版本为例, 如下图:





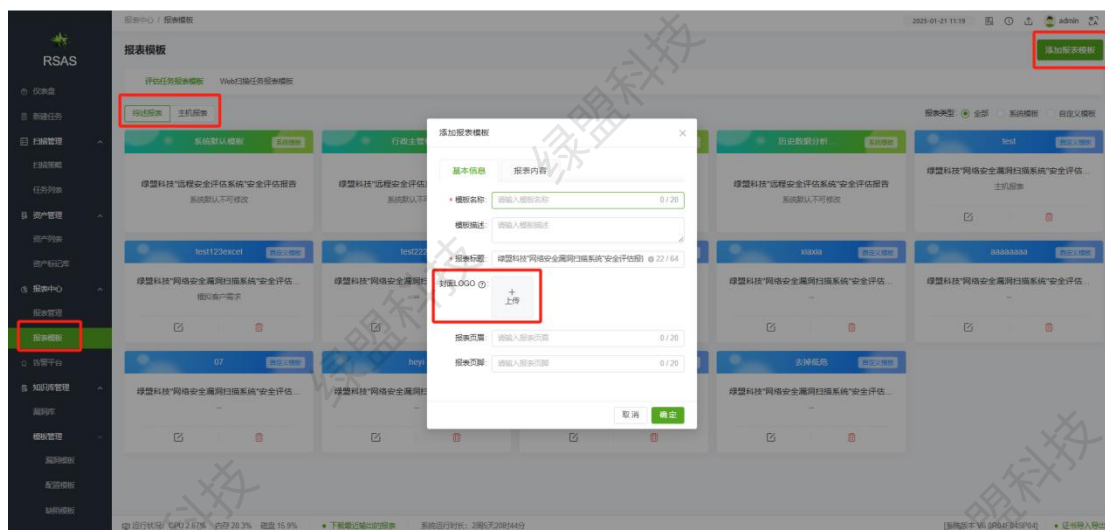
3. 误报修正后的漏洞能否恢复？

不能恢复

4. 如何自定义报表 logo？

word、pdf 格式报表通过自定义报表模板实现，html 格式报表通过 系统管理 > 配置 > 系统配置 > 系统界面定制实现





生成报表

输出范围: ☒ 普通扫描任务 ☐ Web应用扫描任务 ☐ 镜像扫描任务 ☐ 代码审计任务
☐ 主机资产探测任务 ☐ Web资产探测任务

显示最近: 50条

- ☒ 1794 扫描 [10.66.245.162]
- ☐ 1793 扫描 [10.66.245.162]
- ☐ 1791 扫描 [testfire.net]
- ☐ 1772 [sysScan]10.65.200.189;10.66.245.162;10.66.245.180;192.168.1.1-16
- ☐ 1752 离线 [Linux_20240116]
- ☐ 1750 离线 [172.28.38.11]
- ☐ 1748 扫描 [10.66.245.162]

筛选主机: ☐

报表类型: ☒ HTML ☐ EXCEL ☐ WORD ☐ PDF ☐ XML

报表内容: ☒ 综述报表 ☒ 主机报表

综述报表模板: 去掉低危 [报表模板管理](#)

* 报表标题: 绿盟科技“网络安全漏洞扫描系统”安全评估报告

主机报表模板: 去掉低危 [报表模板管理](#)

* 报表标题: 绿盟科技“网络安全漏洞扫描系统”安全评估报告-主机报表

单任务输出: ☐ 报表名称

5. RSAS 如何查看扫到的漏洞返回信息？

可以通过在线主机报表或者导出的离线 html 报表-主机报表中, 点击对应任务后的小图标展开, 即可看到漏洞返回信息

2.1 漏洞概况

远程扫描

端口	协议	服务	☐ 漏洞
--	ICMP	--	☐ 低 ICMP timestamp请求响应漏洞 

Originate timestamp:00000000
Receive timestamp:01bf91cd
Transmit timestamp:01bf91cd

6. 输出的离线报表看不到具体端口信息/漏洞详情

请检查导出报表是否有勾选主机报表（系统扫描）/站点报表（web 扫描），端口信息/漏洞详情均在扫描目标单一报表文件中，综述报表只展示统计情况。

生成报表

输出范围: ☒ 普通扫描任务 ☐ Web应用扫描任务 ☐ 镜像扫描任务 ☐ 代码审计任务
☐ 主机资产探测任务 ☐ Web资产探测任务

显示最近: 50条

☒ 1795 全渠道退款平台OCR在山的资产申请
☐ 1794 扫描 [10.66.245.162]
☐ 1793 扫描 [10.66.245.162]
☐ 1791 扫描 [testfire.net]
☐ 1772 [sysScan]10.65.200.189;10.66.245.162;10.66.245.180;192.168.1.1-16
☐ 1752 离线 [Linux_20240116]
☐ 1750 离线 [1773.70.70.111]

筛选主机: ☐

报表类型: ☒ HTML ☐ EXCEL ☐ WORD ☐ PDF ☐ XML

报表内容: ☒ 综述报 ☒ 主机报表

综述报表模板: 系统默认模板 [报表模板管理](#)

报表标题: 绿盟科技网络安全漏洞扫描系统安全评估报告

主机报表模板: 系统默认模板 [报表模板管理](#)

报表标题: 绿盟科技网络安全漏洞扫描系统安全评估报告-主机报表

单任务输出: ☐ 报表名称

生成报表

输出范围: ☐ 普通扫描任务 ☒ Web应用扫描任务 ☐ 镜像扫描任务 ☐ 代码审计任务
☐ 主机资产探测任务 ☐ Web资产探测任务

显示最近: 50条

☒ 1797 testweb
☐ 1796 扫描任务[http://10.65.14.232:8080]
☐ 1790 扫描任务[http://192.168.119.81:8765]
☐ 1789 扫描任务[http://10.65.199.188:8765]
☐ 1756 扫描任务[https://www.cht.plus/#/index]
☐ 1755 扫描任务[https://www.cht.plus/#/index]

筛选站点: ☐

报表类型: ☒ HTML ☐ EXCEL ☐ WORD ☐ PDF ☐ XML

报表内容: ☒ web综述报 ☒ 站点报表

综述报表模板: 系统默认模板 [报表模板管理](#)

报表标题: 绿盟科技网络安全漏洞扫描系统安全评估报告

单任务输出: ☐ 报表名称

子任务模式: ☐

7. 想要导出部分报表的数据怎么操作

可在生成报表页面筛选主机，根据主机风险等级和操作系统进行筛选，导出其中符合要求的部分数据



8. RSAS 是否支持导出英文格式报表？

V6.0R04F04 版本开始支持英文切换，将设备切换到英文模式下后，再去输出报表就是英文格式报表了。

切换方法：登录 web 界面后，点击设备界面右上角语言切换：



9. RSAS 输出报表提示无权限操作

目前已遇到两种情况：

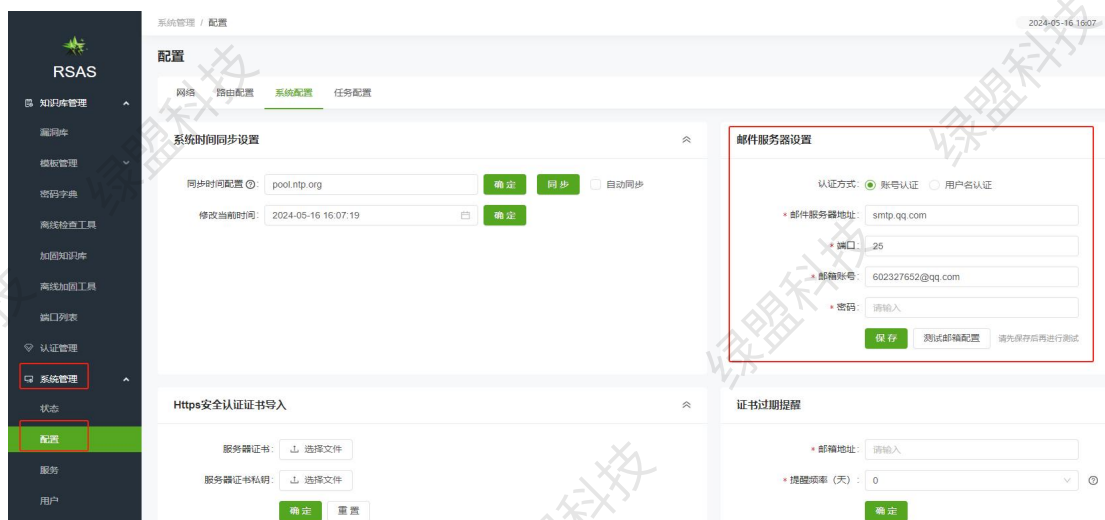
- 1.任务名称中有空格，删除任务名称中的空格后，重新输出报表并下载成功。
- 2.任务名称看起来是正常的，但是实际存在一个不可见的非法字符u200b，修改任务名称后，重新输出报表并下载成功。

10. 如何配置任务结束后自动发送报表到邮箱？

RSAS 支持在任务结束后自动生成报表并发送至指定邮箱（如果仅勾选自动生成报表，不选择发送至邮箱或者 FTP，即表示任务结束后自动生成报表，无需手动输出，完成后可在报表输出中去下载该报表），支持的任务类型：评估任务、web 应用扫描、配置扫描、主机资产探测、web 资产探测。

- 配置邮件服务器（发件服务器）

在系统管理-配置-系统配置中正确填写邮件服务器设置：



- 配置任务结束后自动生成报表并发送到邮箱

测试邮箱可以正常收到邮件后，在新建任务中-任务报表中，勾选启用自动生成报表、启用发送报表，按需求在发送报表中选择报表格式以及邮件邮箱地址，下发扫描任务，任务结束后可在目标邮箱中收到扫描结果文件。



【注意事项】

邮件服务器的密码并非登录邮箱的密码，而是邮箱授权码。

举例 163 邮箱授权码配置位置：进入 163 邮箱，选择设置，找到 POP3/ SMTP/IMAP，确认开启了 IMAP/SMTP 服务，开启后点击生成授权码。



在 RSAS 配置保存后可以点击测试邮箱配置，测试邮箱能否正常收到邮件：



成功后在下任务时启用自动发送报表到邮箱即可，发件服务器邮箱和收件邮箱可以是同一个。

11. 如何配置任务结束后自动发送报表到 FTP？

RSAS 支持在任务结束后自动生成报表并发送至指定 FTP，支持的任务类型：评估任务、web 应用扫描、配置扫描、主机资产探测、web 资产探测。

配置方法：

① 配置 FTP 服务器

在系统管理-配置-任务配置中正确填写 FTP 服务器配置



② 配置任务结束后自动生成报表并发送到 FTP 服务器

测试 FTP 可以正常收到邮件后，在新建任务中-任务报表中，勾选启用自动生成报表、启用 FTP 上传，按需求在发送报表中选择报表格式以及邮件邮箱地址，下发扫描任务，任务结束后即可在目标 FTP 目录中看到扫描结果文件。



【注意事项】

- FTP 服务器配置中的路径，如果是上传到 FTP 根目录，则填写“/”，如果是上传到 FTP 根目录下的某个 xxx 目录则填写“/xxx”，且保证该目录是存在的。
- 配置的用户能正常登录到 FTP 服务器并且在 FTP 路径下需要上传下载权限
- RSAS FTP 客户端当前仅支持被动模式，如果 FTP 服务器端只支持主动模式，那么连接就会失败

问题原因：RSAS ftp 客户端模式与服务器端不一致导致

解决方案：将 ftp 服务器端改成被动模式

- FTP 服务器确实配置了被动模式，但抓包中依旧显示服务器端进入被动模式失败
- 问题原因：ftp 服务器防火墙策略未对 RSAS 放开相关端口（主要是被动模式的端口范围）策略

解决方案：ftp 服务器上正确配置防火墙策略，放开服务器到 RSAS 的端口连接限制

（七）数据外发/联动功能

1. RSAS 是否支持 syslog?

标准设备（标准版本、涉密版本）：支持，V6.0R04F01SP03 上开始支持，配置路径：系统管理 > 配置 > 系统配置 > syslog 同步设置，编码格式为 UTF-8。

信创设备：不支持

2. RSAS 支持 SNMP agent 吗？

不支持。只支持 TRAP，不支持 GET/SET 操作（即不支持管理端通过 oid 主动向被管理设备查询信息），因此也没有 mib 库文件。

snmp trap 配置路径： 点击设备管理>配置>系统配置>SNMP Trap 配置，选择相应 SNMP 版本，正确填写各项信息与管理端一致。在该配置页面处可下载 snmp oid 说明文档。

3. RSAS 支持与非绿盟漏洞管理平台联动吗？

这个得看目标平台联动的方式是什么？如果是基于 api 接口联动调用，那么 RSAS 可支持。其他联动方式不支持，如需支持需要进行定制。

4. RSAS 支持与非绿盟堡垒机联动获取密码吗？

不支持。

5. V6.0R04F04 版本漏扫支持分布式部署么

不支持分布式部署，可以通过联动平台产品做管理

（八）安装部署及认证

1. 虚拟化镜像有 ova 格式的吗？

没有。目前提供的镜像格式为 ISO、qcow2，如需 ova 格式，请自行部署完成后导出相应格式文件。

2. 信创 RSAS 虚拟化镜像支持认证模式有哪些

支持云端认证及集中授权认证，其他不支持

3. 虚拟化认证需要放通什么网络策略？

V6.0R04F02及之后镜像部署

集中授权

RSAS端口	流量方向	ESPC (集中授权平台)
TCP: 1-65535 随机端口	→	TCP: 5050、5007、5008、443
TCP: 5050	←	TCP: 1-65535 随机端口

云端认证

RSAS源端口	流量方向	目的地址	目的端口
TCP: 1-65535 随机端口	→	auth.api.nsfocus.com espp.api.nsfocus.com	TCP+TLS+SSH: 5050

ESP-L认证

RSAS端口	流量方向	ESP-L平台
TCP: 443	←	TCP: 1-65535 随机端口

V6.0R04F02之前镜像部署

集中授权

RSAS端口	流量方向	ESPC (集中授权平台)
TCP: 1-65535 随机端口	→	TCP: 5002、5003
TCP: 5002、5003	←	TCP: 1-65535 随机端口

云端认证

RSAS源端口	流量方向	目的地址	目的端口
TCP: 1-65535 随机端口	→	auth.api.nsfocus.com espp.api.nsfocus.com	TCP: 5002、5003

4. 云端认证频率和离线状态说明

RSAS 云端认证认证时长：当设备第一次认证过后，将会每天再发起一次认证，此时：当设备认证超时超过

3 天，则设备进入【离线状态 1】。设备功能仍可正常使用，但无法升级。当设备认证超时超过 7 天，或者

认证失败，则设备进入【离线状态 2】。设备进入离线状态 2 后，设备无法登录，需要重新认证。

认证成功的云端是一天一次

认证失败后会变为 1 小时一次

进入离线阶段一：超时时间 t ， $3 \text{ 天} \leq t < 7 \text{ 天}$

进入离线阶段二：时时间 t ，若 $t \geq 7 \text{ 天}$

离线一不能生成离线报表、不能导出任务、不能升级、不能创建和导入导出还原点、不能创建和恢复快照，禁用二次开发接口，其他功能可用。

离线二界面无法登录

5. 云端认证报错“激活失败：HashSign 字段不存在”怎么处理？

云端的证书默认情况下是 CA 开头的，如果遇到不是 CA 开头的，建议咨询客户是否改过证书名称，若没改过，提示“激活失败，HashSign 字段不存在”，则应该为证书制作错误，建议重新制作云端证书。

6. 云端认证报错“设备激活失败（原因：证书冲突）”原因？

证书重复给多个虚拟化 RSAS 使用导致，重复使用会导致离线问题。（请确认是否有将一个证书给两台 RSAS 使用）

7. 虚拟化设备安装过程黑屏后自动关机

请检查配置的硬盘大小是否符合要求，V6.0R04F04 版本镜像开始要求最低硬盘 300G。如果不满足硬盘要求，请按部署手册要求重新部署。

8. RSAS 重装需要多长时间？

根据设备性能，数据量多少决定，实际测试 10 分钟至 1.5 小时不等。

9. RSAS 管理口和扫描口是否可以配置同一个网段？

不可以，会影响 web 登录及扫描结果

10. RSAS 虚拟化怎样扩展空间容量（磁盘）大小？

- 1、RSAS 虚拟化型号安装完成的话不支持扩容磁盘，只能重装进行扩容
- 2、RSAS 硬件型号磁盘扩容要根据具体情况确认，具体可联系销售沟通

11. KVM 虚拟化漏扫支持 nat 网卡模式吗

配置上支持，但不建议，因为 nat 模式可能会影响扫描结果准确性。

12. 请问 RSAS 虚拟化支持麒麟系统安装吗

XC 版本镜像支持在 ARM 系列的 CPU（飞腾 2000、鲲鹏、麒麟）上安装

13. RSAS 虚拟化镜像支持在海光 CPU 上部署么

V6.0R05F000 版本标品镜像支持在海光环境上部署

14. RSAS 是否支持 U 盘部署

不支持

15. 产品咨询是否支持容器化部署

目前标品暂不支持容器化部署，如有特殊环境需要，可请销售联系产品经理获取定制镜像

（九）Web 界面访问及路由相关

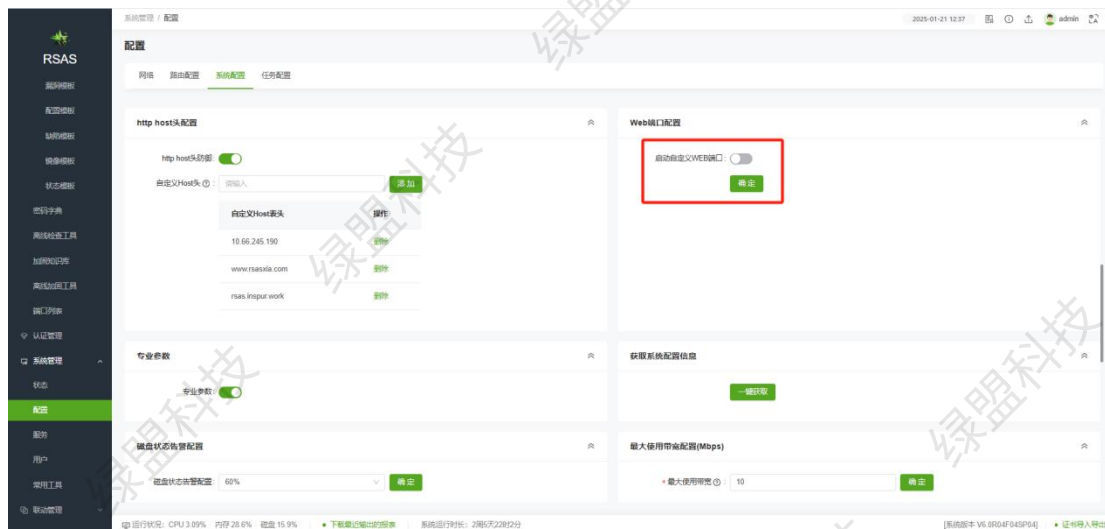
1. 支持的浏览器版本？

V6.0R04F04 及以上版本：Chrome、Edge、Firefox 的最新版浏览器（chrome 内核 94 以上，火狐内核 100 以上），不兼容 IE

V6.0R04F04 以下版本：Firefox、Chrome、Edge、IE（8、11）

2. RSAS 能否自定义 web 登录端口？

支持自定义，配置方法：点击系统管理-配置-系统配置，启动自定义 WEB 端口进行设置即可。



3. RSAS 支持 IPV6 配置吗？

支持，在系统管理-配置-网络中可对网口进行 IPV6 配置，可同时配置 IPV4+IPV6 来使用

4. RSAS 管理口可以做扫描口吗？

可以。管理口和目标网络可达即可扫描，管理口和扫描口并未做完全的功能拆分，和扫描口一样的使用，反之扫描口也可用作 web 登录管理。

5. RSAS 最大支持配置路由条数是多少？

最大支持配置 50 条路由。由于 RSAS 并不是专业的网络交换路由设备，因此提供配置的路由条数不多，若有更精细化的路由配置需求，建议在 RSAS 下一级网络交换路由设备上配置实现

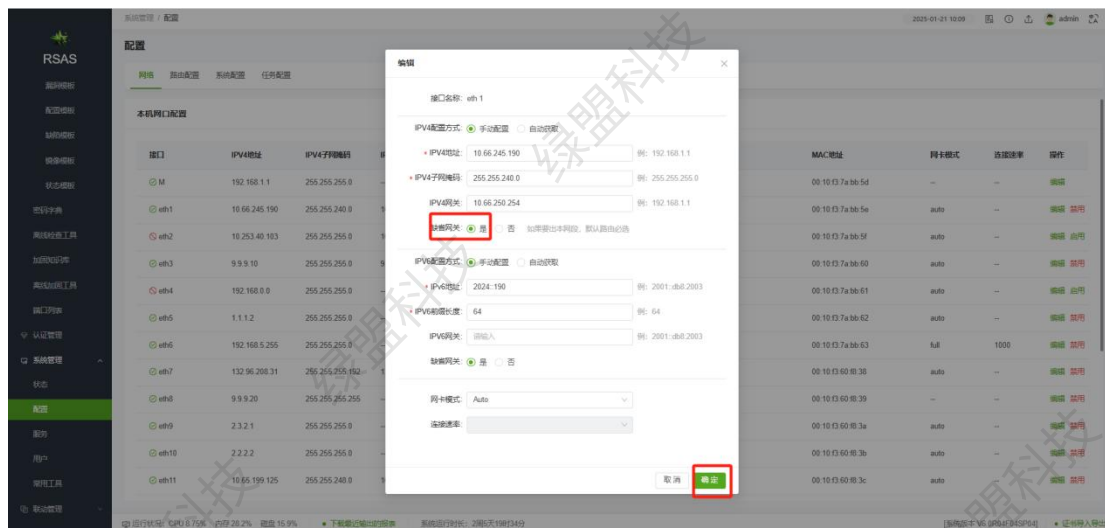
6. 如何在跨网段访问或扫描时配置缺省路由？

全零默认路由不需要手动编写，可通过设置网口的缺省网关来自动生成。扫描口默认路由可通过 web 界面或串口进行配置，管理口网络及路由配置只能在串口下操作。

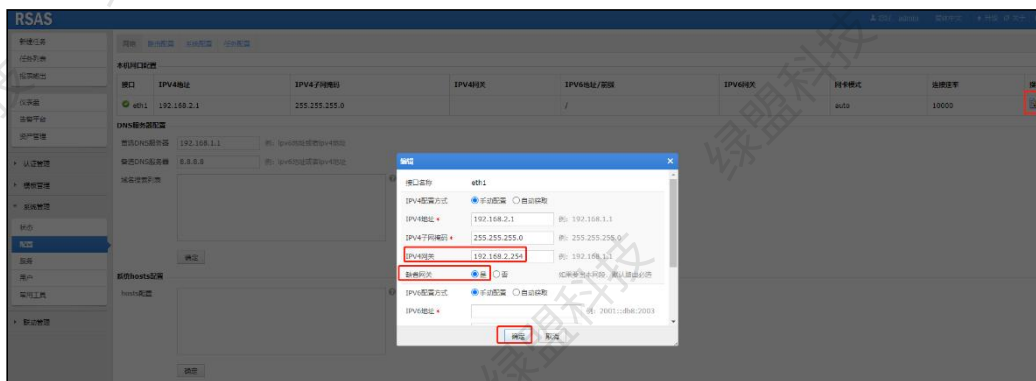
Web 界面配置方法：

进入 系统管理 > 配置，在网络页签中选择需要生成默认路由的网口，单击【编辑】，在弹出的网络配置框中，输入网口 IP 地址及网关，缺省网关选择“是”，配置完成后单击【确定】。

V6.0R04F04 及以上版本：

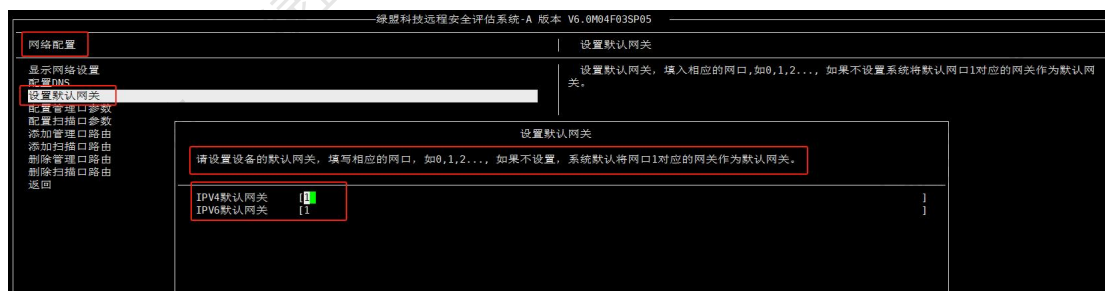


V6.0R04F04 以下版本:



串口配置方法:

单击网络配置设置默认网关, 在 IPv4 网关一栏设置需要配置默认路由的接口数字, 例如: 0 代表管理口, 1 代表扫描口 1, 2 代表扫描口 2, 以此类推。



7. RSAS 是否支持配置 ACL 从网络层限制 web 访问?

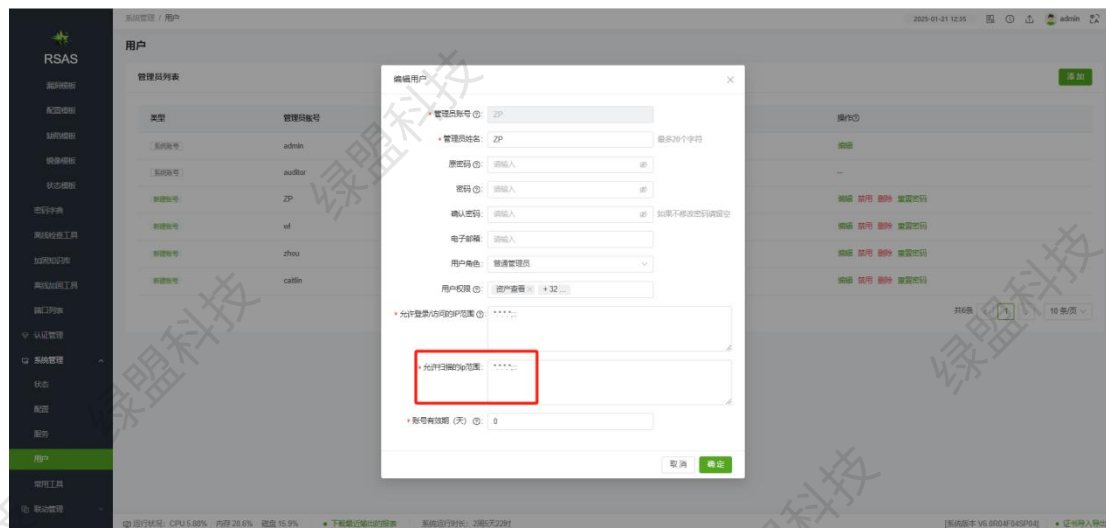
不支持

8. RSAS 是否存在链路聚合的功能

不支持

9. RSAS 是否支持配置允许扫描 IP 范围？

支持，配置方法：点击 系统管理 > 用户，点击编辑需要配置的账号，设置允许扫描范围，以回车、分号、逗号隔开。



10. RSAS 对外开放端口有哪些？

端口	说明	是否外部可访问	是否默认开启
443	用于漏扫管理页面	是	是
50022、6000-65535	用于 ssh 登录到设备后台进行问题排障	是	否，需开启系统管理-服务-系统服务-远程协助才会启用
56000-65530	部分插件采用会连端口方式检测漏洞，在检测过程中会开放，检测结束后自动关闭	是	否

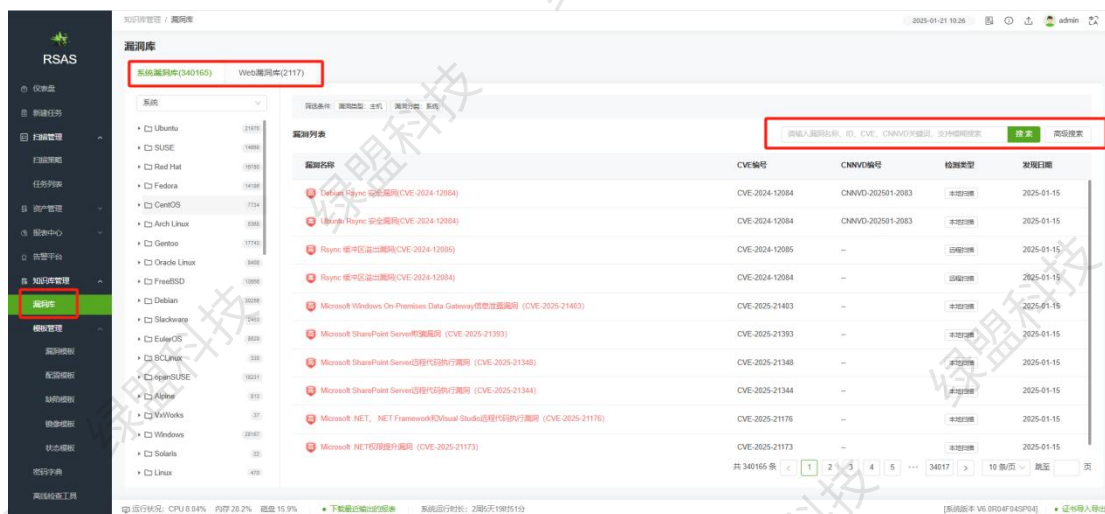
(十) 漏洞库问题

1. 如何查看漏洞是否支持扫描？

登录 web 界面后，在漏洞库中进行查询，如果能查到则支持扫描，查不到则不支持，注意查询时需保持 系统插件/web 插件 版本最新。

V6.0R04F04 及以上版本：

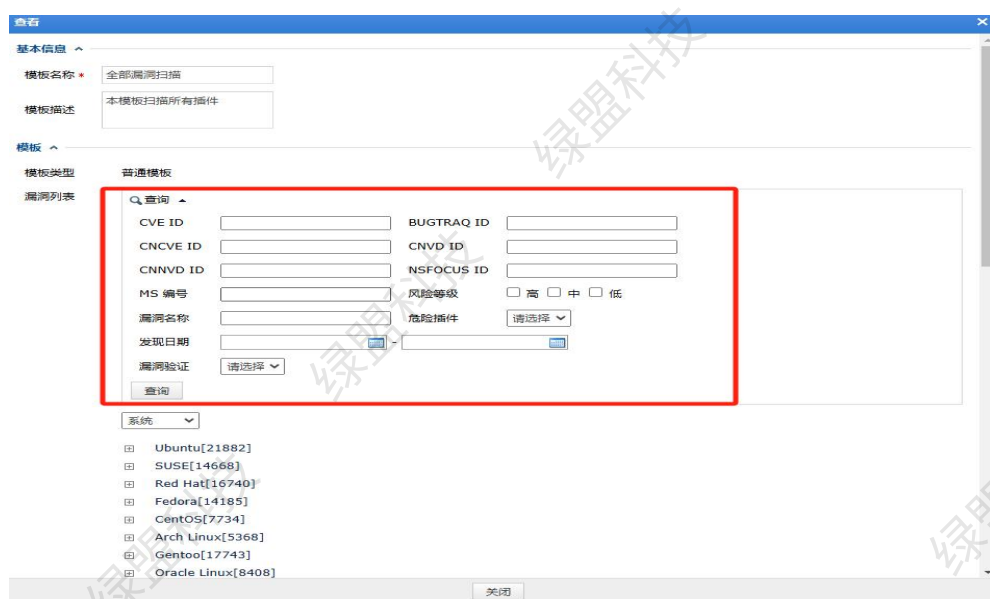
登录 web 界面，点击 知识库管理 > 漏洞库，按需点击 系统漏洞库/web 漏洞库，输入关键字进行查询。（注意：漏洞名称不具有唯一性，可能因为名称不一致导致查询失败，推荐使用 cve/cnvd 等编号进行查询）



V6.0R04F04 以下版本:

登录 web 界面，点击模板管理 > 漏洞模板，按需点击系统扫描模板/web 扫描模板，选择全部漏洞模板，点击查看，在弹窗中根据漏洞名称/CVE 等信息进行查询。（注意：漏洞名称不具有唯一性，可能因为名称不一致导致查询失败，推荐使用 cve/cnvd 等编号进行查询）





2. 漏洞库中漏洞检测类型代表什么含义？

V6.0R04F04 版本开始，对漏洞库展示内容进行了优化，增加了检测类型字段展示，有三个值，分别为：远程扫描、本地扫描、登录扫描。

远程扫描：

无须登录到扫描目标可探测到的漏洞。向被扫描主机的一些应用监听的端口发包，基于探测到的端口 banner 信息，匹配 RSAS 漏洞库中该版本组件存在的漏洞直接报出。

常见有绝大部分的 Web 组件漏洞（Apache、Tomcat、Nginx、Weblogic、Websphere、PHP 等）、OpenSSH 漏洞、Oracle 漏洞、FTP 漏洞、NTP 漏洞、MySQL 漏洞等等。

本地扫描：

需做登录操作才可探测到的漏洞。在 RSAS 上通过设定的用户登陆扫描目标后，根据获取到的补丁信息/操作系统版本信息/注册表信息等来判断是否存在漏洞。

原理扫描：

无须登录到扫描目标可探测到的漏洞。基于安全研究人员会分析已经被发现的攻击漏洞特征，RSAS 构造带有已知攻击特征的数据包，去扫描目标主机，检查通过攻击特征包请求的数据是否有回包，如果目标主机返回漏洞存在的预期结果，则报出该漏洞。

3. 漏洞模板/配置核查模板能导出离线文件查看吗？

模板数据属于产品核心知识，因此不能导出可查看的离线文件。漏洞库/配置核查模板导出的都是加密过的 dat 文件，用于设备之间漏洞模板/配置模板的备份导入。

4. 想要某个漏洞不展示怎么操作

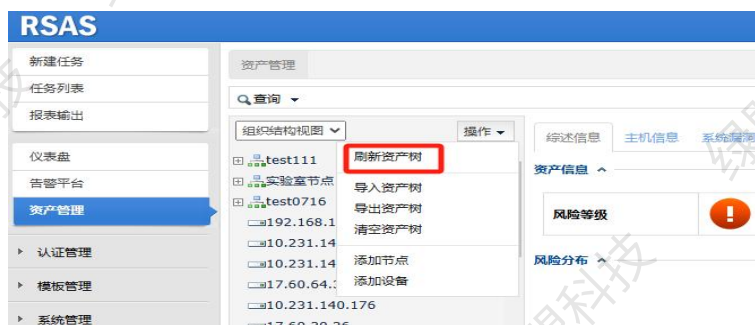
可自定义漏洞模板，在漏洞模板中不选中对应漏洞

（十一）资产管理模块

1. 资产管理无法从任务结果中自动生成设备节点到资产树？

首先，资产管理中必须配置节点范围，且下发的任务目标 ip 在节点范围中，任务扫描完成也有存活 ip 漏洞信息等。此时若还是没有生成节点到资产树，单击【资产管理-】【刷新资产树】，刷新后如还未自动生成设备节点，请检查该设备 IP 是否已经存在于其他节点树中。

V6.0R04F04 以下版本：



V6.0R04F04 及以上版本：



（十二）任务数据相关

1. 任务列表中任务风险值灰色实际点击进去任务有漏洞数据和风险信息

可点击任务列表—刷新任务列表尝试刷新任务信息。

2. 任务误删除后能否恢复？

无法恢复

3. 系统还原能在不同设备间还原吗？

不能。只能在同一个设备的同版本（包括系统版本及插件版本）上进行系统还原，不同设备间不支持互相导入还原点，如果误操作引起的设备故障极有可能只能重装。

系统还原点创建包含配置文件与数据库等文件（包含任务、资产树、自定义密码字典等内容，不会备份已生成的报表）

4. RSAS F03 版本任务可以导入到 F04 版本设备吗？

可以导入，但是 F04 版本任务不能导入 F03 版本

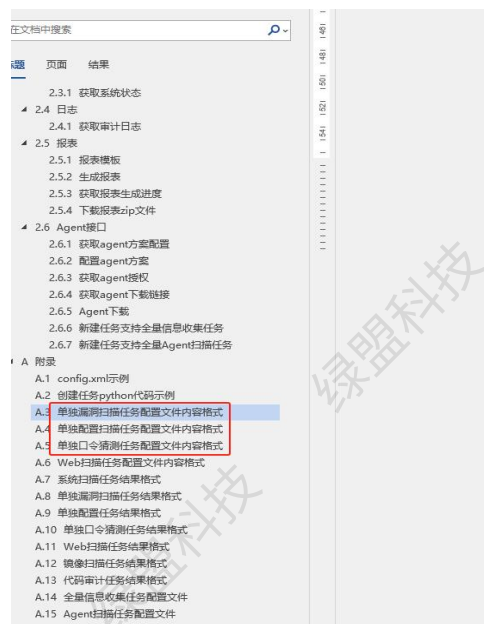
5. 恢复出厂设置和重新安装系统是一个操作吗

是的，叫法不同，串口下选项都是重装系统，把系统恢复到出厂状态，数据清空，仅保留网络配置和证书

（十三）数据接口相关

1. 数据接口如何设置配置文件参数值去下发任务？

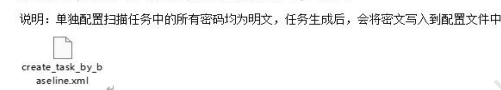
配置文件中任务参数释义可在数据接口文档-附录中保存对应示例文件查看具体字段释义，按照释义要求去配置对应值：



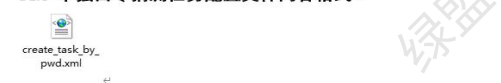
A.3 单独漏洞扫描任务配置文件内容格式



A.4 单独配置扫描任务配置文件内容格式



A.5 单独口令猜测任务配置文件内容格式



```
<?xml version='1.0' encoding='UTF-8'?>
<!DOCTYPE plist PUBLIC "-//Apple//DTD PLIST 1.0//EN" "http://www.apple.com/DTDs/PropertyList-1.0.dtd">
<config>
  <server>
    <key name="task_type" value="ip"/>
    <key name="targets" value="10.65.195.204"/>

    <key name="os_match" value="yes"/>
    <key name="messystypes" value="5;6;7;8;9;10;11;12;13;14;15;16;17;18;20;21;22;23;24;25;26;27;28"/>

    <key name="isguesspwd" value="no"/>
    <key name="port_strategy" value="standard"/>
    <!--指定端口扫描、allports(全端口扫描)-->
    <!--key name="port_strategy_userports" value="1-100,443,445"-->
    <!--*指定端口列表: 若port_strategy为用户有此标签否则无, value为一个或多个端口用逗号分隔-->
    <key name="port_speed" value="3"/>
    <key name="port_tcp" value="T"/>
    <key name="port_udp" value="no"/>
    <key name="live" value="yes"/>
    <key name="live_icmp" value="yes"/>
    <key name="live_udp" value="no"/>
    <!--key name="live_udp_ports" value="25,53"/>
    <!--多个端口用逗号分隔-->
    <key name="live_tcp_allports" value="no"/>
    <!--当yes时下面两项(live_tcp, live_tcp_ports)不生效-->
    <key name="live_tcp" value="yes"/>
    <key name="live_tcp_ports" value="21,22,23,25,80,443,445,139,3389,6000"/>
    <!--* TCP端口列表: 若live_tcp标签的value为yes则有此标签, value为一个或多个端口用逗号分隔-->
    <key name="live_arps" value="no"/>
  
```

2. 数据接口获取任务结果中字段值含义有说明文档吗?

有说明文档,可在数据接口文档-附录中保存对应示例文件查看具体字段释义:

```

<?xml version="1.0" encoding="utf-8" ?>
<aurora>
  <ret_code>0</ret_code>
  <ret_msg>success</ret_msg>
  <data>
    <page>1</page>
    <page_size>1</page_size>
    <page_total>1</page_total>
    <target_total>1</target_total>
    <report>
      <vendor>绿盟科技</vendor>
      <product>远程安全评估系统</product>
      <version>V6.0R03F01SP01</version>
      <sysvul_version>V6.0R02F01.1800</sysvul_version>
      <task><!--任务基本信息-->
        <id>19</id> <!--任务id-->
        <name><!--任务名称-->
          <![CDATA[扫描【10.65.195.206】-口令+配置+漏扫]]>
        </name>
        <task_type>3</task_type><!--任务类型-->
        <vuln_template>100</vuln_template><!--漏洞模板id-->
        <time_start_scan>2020-06-23 15:50:51</time_start_scan><!--任务开始时间-->
        <time_end_scan>2020-06-23 15:53:55</time_end_scan><!--任务结束时间-->
      </task>
      <scanned_ip_count>1</scanned_ip_count><!--扫描IP数-->
      <failed_hosts><!--扫描失败主机列表-->
    </failed_hosts>
    <targets><!--扫描信息：对所有扫描结果这个显示，每个target为一个扫描ip-->
      <target>
        <ip>10.65.195.206</ip><!--任务扫描ip-->
      </target>
    </targets>
  </data>
</aurora>

```

3. 数据接口能删除任务吗？

不能

(十四) 系统管理-服务

1. 如何关闭抓包功能？

V6.0R04F01SP03 版本新增专业参数开关，开关控制抓包、远程协助功能是否展示在界面。

操作路径如下：

标准设备：

标准版本：

使用 admin 登录，点击 系统管理 > 配置 > 系统配置，关闭“专业参数”

涉密版本：

使用 sysadmin 登录，点击 系统管理 > 配置 > 系统配置，关闭“专业参数”

信创设备：不支持关闭

2. 漏扫如何修改系统时间

修改系统时间可通过时间服务器通过或者手动修改方式实现，手动修改和证书类型相关

时间同步方式：

系统管理-配置-系统配置 系统时间同步配置中通过同步时间配置修改时间

手动修改方式：

正式证书：可直接在系统管理-配置-系统配置 系统时间同步配置中修改当前时间实现（不可修改证书起止时间以外的时间），串口也可修改



测试证书：设备界面和串口均不支持修改，需要联系绿盟技术支持后台修改

2 扫描使用 FAQ

（一）扫描所需网络策略及影响

1. 扫描目标需开放什么网络策略？

问题：RSAS 和扫描目标之间有防火墙，而且不想绕过或关闭防火墙，应该开启哪些端口？

答案：0~65535 端口双向开启，建议 RSAS 和扫描目标之间最好不要有防火墙等防护设备（即使放通了策略，由于机制问题有些防护设备依旧会发送伪包代替目标设备响应造成结果不准确等问题）。

原因：

- ①源端口：根据 TCP/IP 协议，源端口是随机的
- ②目的端口：RSAS 的工作过程是：先完成主机存活发现、然后进行端口发现、系统和服务识别，再调用其它的插件进行漏洞检测。对已经存活的主机，必须探测出主机上开启了什么端口才能继续扫描，所以建议目标主机开放所有端口。

2. RSAS 隔着防火墙扫描有什么影响吗？

一般不建议隔着防火墙扫描，原因：

- ①扫描期间可能产生大量会话，若防火墙上会话不能及时释放，可能会导致会话数占满等问

题

① 在防火墙环境中，由于网络策略等限制，可能会导致获取结果不准确

如果环境中存在跨防火墙扫描，建议操作如下：

- 向防火墙管理员确认防火墙会话性能、利用率。--设置更积极的会话老化率
- 在防火墙上开放网络策略：扫描器随机源端口（1-65535）→目标网段 ACCEPT
- 在 RSAS 端，设置较低的最大并发扫描主机数（系统管理-配置-任务配置-系统并发数配置）
- 在 RSAS 端，设置较低的端口扫描速度（新建任务-高级选项参数-端口扫描速度）
- 从较小的子网开始扫描

3. 经过 NAT 网络扫描有什么影响？

虚拟 RSAS 网卡能否配置 NAT 模式进行扫描？--不建议，推荐使用桥接

硬件 RSAS 能否通过 NAT 网络扫描？--不建议

- 由于 NAT 网络会由网关设备代理内部设备建立网络连接，因此在端口服务操作系统识别阶段，nmap 处于 NAT 网络内部或者处于经过 NAT 连接网络的虚拟机内部时，nmap 扫描基本上到 NAT 设备就终止了，最终影响端口服务及操作系统识别结果，最终可能影响扫描结果。
- 就算 nmap 能够扫描外部网络，由于 NAT 对 TCP 连接代理时会影响报文原本的 seq 以及 ttl 等，从而对相应的指纹产生影响，最终的结果就是指纹信息不准确或者混乱。从而最终导致 nmap 的 os 识别的不准确。
- 所以，一般不建议在 NAT 网络内部使用 RSAS 对 NAT 外部网络进行探测。

4. RSAS 系统扫描是全连接还是半连接扫描？

默认是全连接扫描，可通过下发任务时高级选项参数调整

← 新建评估任务

基本信息 高级选项 报表输出设置

端口扫描策略：标准端口扫描 [编辑端口服务列表](#)

扫描速度：普通

TCP端口扫描方式：CONNECT SYN

UDP扫描：[disabled]

CONNECT: 推荐选项，通过直接建立完整的TCP连接来判断端口开放情况，此方法快而准

SYN: 向目标端口发送SYN包，依据对方是否回复ACK报文来判断端口开放情况。

5. 系统扫描是否支持代理配置？

不支持

6. 扫描路径中间存在代理设备或扫描目标就是代理设备，导致扫描流量被转发至非扫描目标设备中

问题原因：RSAS 对中间是否存在代理设备是无法感知的，如果路径中间存在代理设备或目标就是代理设备，由于代理设备本身的功能，是会将扫描流量转发出去的。

解决方案：①开启代理时不建议扫描代理设备，或请知悉可能会转发扫描流量的风险 ②扫描路径中存在代理设备，或者目标为代理设备时，先彻底关闭代理功能后再尝试扫描

（二）系统（主机）扫描任务

1. 登陆扫描对目标的影响

系统登录扫描：会在目标执行查询命令，无其他风险操作；

在线配置扫描：会在目标机上创建临时文件和临时服务，获取命令结果完成扫描后会自动清理掉临时文件和临时服务，不会对目标机产生危险操作；

2. RSAS 系统扫描能否只扫描开放端口不扫漏洞？

可以。

配置方法：

下发任务时，漏洞模板选择为端口扫描，则只探测目标开放端口信息，不进行漏洞扫描；

漏洞模板： 端口扫描

下发任务时，漏洞模板选择为远程服务版本信息收集，则探测目标开放端口服务版本信息，不进行漏洞扫描。

漏洞模板： 远程服务版本信息收集

3. 系统扫描可能会对目标上传文件测试吗？

某些原理扫描方式的远程代码执行漏洞可能会进行上传文件测试。

4. 大量资产全端口扫描下，导致中间网络设备宕掉

问题原因：一般来说是中间设备承受不住这么大的发包量，或者未及时释放会话导致

解决方案：RSAS 上降低并发数等配置，中间网络设备设置更积极的会话老化率

5. 扫描打印机出现打印机自动打印乱码纸张

问题原因：打印机本身不需要验证，只要数据发到端口上，打印机就会处理，或者打印机存在未授权访问等漏洞导致。这种情况都是打印机本身存在问题才会触发打印

解决方案：进入 系统管理 > 配置 > 系统配置，端口屏蔽配置中添加打印相关端口，屏蔽掉不做扫描

6. 口令猜测导致目标机账号锁死

问题原因：RSAS 在扫描过程中根据密码字典中的内容按顺序尝试登录目标设备进行暴力破解，若目标机配置有多次登录失败即锁定账号等策略，多次猜测可能会导致目标账号锁死。

解决方案：①取消目标机登录失败锁定策略 ②若无法取消锁定策略，请知晓口令猜测风险，谨慎使用口令猜测任务。

7. NTP/openssh 远程扫描扫不到版本漏洞

RSAS V6.0R04F00SP06 版本评估任务的高级选项中新增 OpenSSH 远程版本扫描开关配置；V6.0R04F01SP05 版本评估任务的高级选项中新增 NTP 远程版本扫描开关配置。

上述开关用于灵活控制 OpenSSH 以及 NTP 远程版本漏洞的扫描，此开关仅控制远程版本漏洞的扫描，本地漏洞的扫描不受该配置项控制。



8. 大批量任务/资产扫描时界面卡慢

可能是任务并发过高无法适配当前扫描操作导致，详情如下。

最大并发数上限值仅适用于默认参数配置的情况，如下发任务均采用默认参数（例如标准端口、默认漏洞模板等），且不带口令猜测，此时可以使用并发数上限配置。

若任务参数非默认，如全端口扫描，或者在评估任务的基础上加入了口令猜测或其他类型的扫描任务，则建议开启系统资源优化按钮，或降低并发数配置，适当降低并发数会提高系统整体响应速度（比如扫描速度、web 界面响应速度）。

调整方法：

- ✓ V6.0R04F04 以上版本优先开启系统资源优化：点击系统管理-状态-运行状态，开启系统资源优化按钮



- ✓ 如果开启资源优化后，效果不明显，还可手动降低一些系统并发

- 点击系统管理-配置-任务配置-系统并发数配置
- 设置“最大并发扫描主机数”和“最大任务并发插件数”为当前最大值（下拉框中的最大数值即为当前型号可设置的最大并发数值）的 $\frac{2}{3}$ 或 $\frac{1}{2}$ 及以下



9. 漏扫能够登录扫描国产化的麒麟、统信系统吗

支持

10. 扫描器现在支持 大模型相关框架的扫描吗（比如 AutoGPT、Ollama、LangChain、Open-WebUI、RagFlow 等）

目前不支持

（三）Web 扫描任务

1. Web 扫描注意事项

关于扫描需要登陆的站点建议如下：

- ① 最好能给扫描目标提供一个专属于扫描器登录扫描使用的目标站点账号，其他人均不使用该账号操作。
- ② 下发目标填写为站点登录后的主 URL 或漏洞所在 URL
- ③ 基于第二步基础，扫描范围选择为按域名扫描，整站扫描，确保扫描时爬虫是从站点根目录开始爬取扫描，爬取更全
- ④ 排除可能会导致登出的接口，一般 url 关键字为 logout 等（如果需要扫描登出接口本身，建议再下发一个只包含登出链接的任务，但是下发时间要晚于排除此接口的任务结束时间）。排除 URL 配置方法如下：新建任务，填写扫描目标后，启用认证配置，编辑配置，将登出功能 URL 填写到排除链接中。
- ⑤ 如果无法创建新账号供扫描器使用，使用同一账号进行测试的情况下，需要确认 Cookie 失效的机制，避免外部操作对扫描结果的干扰；此种场景更建议下发定时任务，在无人使用此账号的非工作时间进行扫描。
- ⑥ 如果目标站点性能较差，可以降低并发，以减少爬虫和插件请求过多导致目标站点宕机。

2. Web 应用扫描后目标站点被增删改数据了

问题原因：通过链接爬取、注入类插件探测等，正好触发了页面的删除、修改、添加功能。

注意事项：测试数据一旦插入目标站点，或者删除了目标站点的数据，将无法自动恢复。

解决方案：①建议在站点测试环境或备份环境进行扫描（特别是做了高权限账号登录扫描的场景）②针对表单页面，关闭 RSAS 上的表单扫描（默认已关闭），极大降低扫描时增删改几率，但不能完全避免，因为爬虫阶段如果爬取到增删改功能页、或漏洞探测阶段正好获取相关功能页进行注入也可能会触发。

3. Web 扫描支持登录扫描的站点类型有哪些？

- 登录会跳转至统一认证身份平台的站点。
- 插入硬件设备认证的站点，如插入 key 认证的站点。
- 认证信息没有存储在请求或响应头中的站点。
- RSAS 系统版本 V6.0R04F03 以前不支持登录扫描前后端分离站点。

4. 支持 web 弱口令猜测的站点类型

- web 口令猜测支持的类型：表单填充的、basic 认证的、已知应用的（Apache APISIX 存在弱口令、通达 OA 存在弱口令、检测到 webmin 存在弱口令等等插件里面可搜索到的弱口令检测）。
- 不支持口令猜测的类型：带验证码的站点。

5. web 弱口令任务怎么下发

没有单独的 web 弱口令任务，可以在配置参数中自定义添加 30 组弱口令

6. 为什么 V6.0R04F04 的 web 扫描默认配置扫不出基于 dnslog 平台检测的漏洞例如 log4j 远程代码执行？

由于老版本新建 web 扫描任务界面上没有 dnslog 开关，所以默认是开启的，而 F04 版本由于客户需求在高级参数中增加了这个开关，默认为关闭状态，所以使用默认配置扫描不会检测需要使用 dnslog 平台检测的漏洞了。如果需要扫描这类漏洞可以在新建 web 扫描的高级选项中开启这个开关。

如果是在老版本下发的周期任务，那么升级 F04 后产生的周期任务 dnslog 开关是为开启的。

7. Web 扫描已爬取的链接数为什么大于等于已扫描的链接数？

因为一个站点里面有图片链接，样式等不会被扫描，以及高级选项参数中的单目录文件数、目录深度、链接总数、排除后缀，扫描连接总数等参数会限制扫描的链接数量。

8. 漏扫怎么让 web 只做爬行，不做漏洞扫描

目前不支持

9. RSAS web 扫描支持扫动态验证码吗

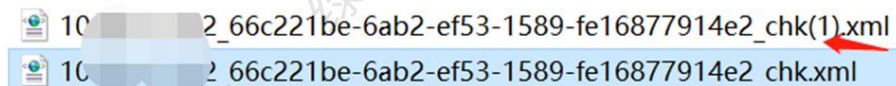
需具体场景具体分析，需要验证码信息在请求头中携带固定那么支持，如果不确定是否支持可咨询售后排查。

（四）配置核查任务

1. 导入离线核查结果文件提示“导入脚本执行错误”

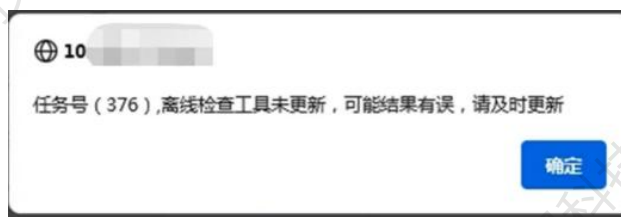
离线结果文件格式是固定的，不能自行更改结果文件格式。

例如 Windows 类的结果文件，若为 xxx_chk(1).xml，则会报错导入脚本执行错误，在导入时，需修改为正确的 xxx_chk.xml



2. 导入离线核查结果文件提示“离线检查工具未更新”

提示离线检查工具未更新则表明，离线检查工具的版本是低于目前 RSAS 设备版本的，建议下载最新版本的离线核查工具进行核查。



3. 离线结果导入失败, 提示“此检查结果依赖的模板已经删除, 请使用新的离线工具”

说明检查脚本并不是从该设备上下载的，请重新在对应设备上下载脚本执行，执行结果导入下载脚本的那台设备中。

（五）任务列表

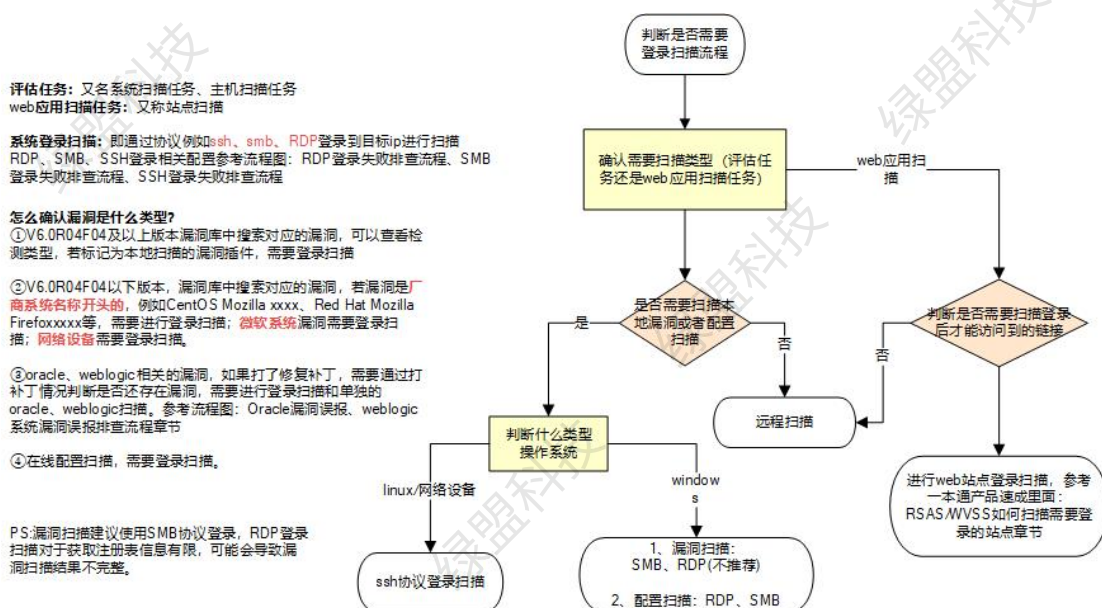
1. 暂停操作后为何出现停止按钮瞬时消失的情况？

V6.0R04F04 版本之前，当用户执行暂停操作后，操作栏中存在的按钮是：续扫、停止和删除按钮，在暂停操作后立马执行停止操作，界面会提示停止操作失败，不允许用户执行停止操作，以及暂停后任务进度还会持续前进的情况。因此在 R04F04 版本对该问题进行了优化，当执行暂停操作后，会在任务进度条处给出状态提示：暂停中，此时操作栏中不会出现停止和续扫按钮，当暂停操作真实完成后，停止和续扫操作按钮恢复，正常情况下，暂停中消耗时间为秒级，若系统数据量太大，暂停中可能会持续近 1 分钟时间。

3 常见问题排查流程

(一) 判断是否需要登录扫描

1. 流程图

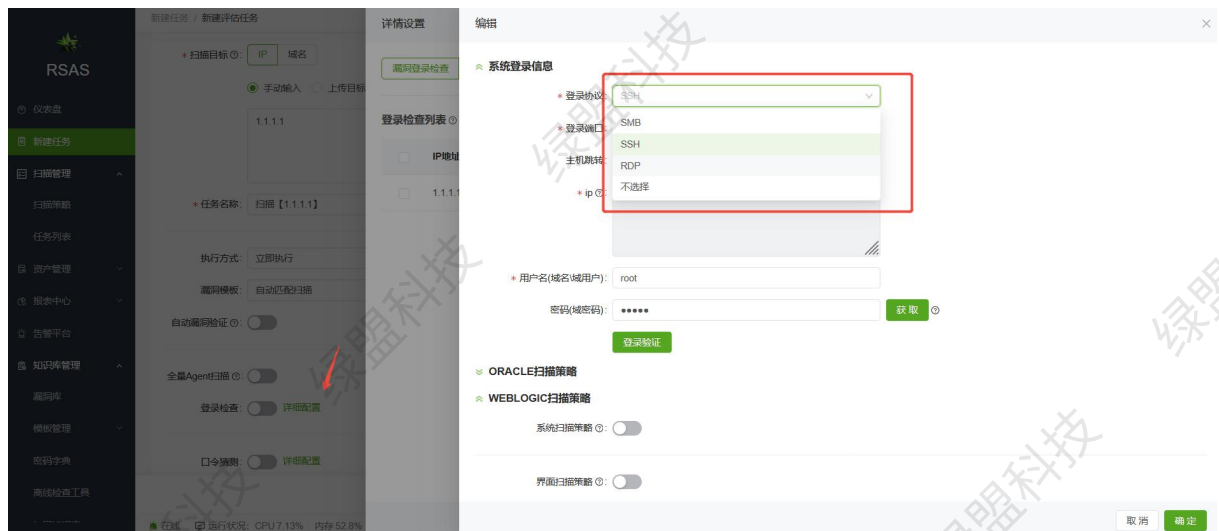


2. 流程答疑

1、评估任务即系统扫描任务，进行主机扫描，扫描 ip 或者域名。web 应用扫描是扫描 url 即 web 站点



2、系统登录扫描，是通过协议登录扫描，常见 SSH、RDP、SMB（协议登录扫描相关问题可参考流程图配置：RDP 登录失败排错流程、SMB 登录失败排错流程、SSH 登录失败排错流程）



3、怎么判断漏洞类型？

①V6.0R04F04 及以上版本漏洞库中搜索对应的漏洞，可以查看检测类型，若标记为本地扫描的漏洞插件，需要登录扫描

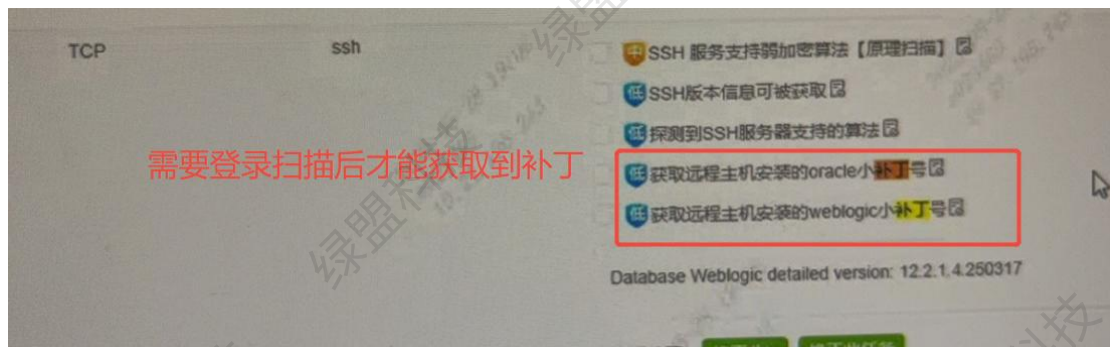


②V6.0R04F04 以下版本，漏洞库中搜索对应的漏洞，若漏洞是**厂商系统名称开头的**，例如 CentOS Mozilla xxxx、Red Hat Mozilla Firefoxxxxx 等，需要进行登录扫描；**微软系统**漏洞需要登录扫描；**网络设备**需要登录扫描。



版权所有 © 绿盟科技

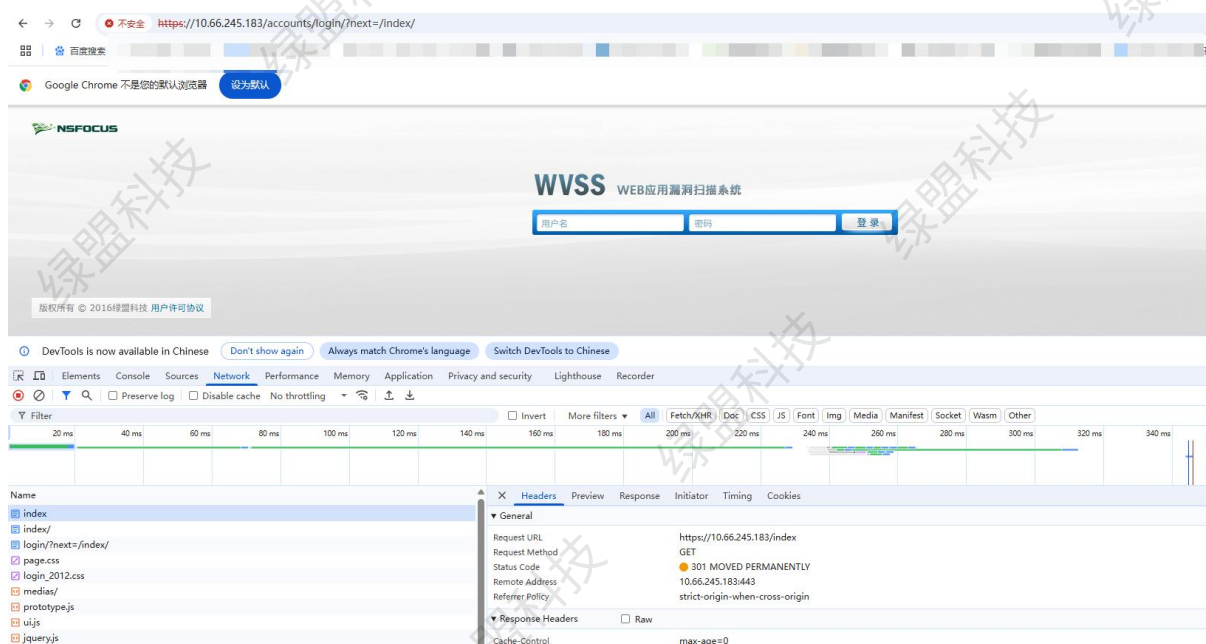
在漏洞，需要进行登录扫描和单独的 oracle、weblogic 扫描。参考流程图：Oracle 漏洞误报、weblogic 系统漏洞误报排查流程章节



④在线配置扫描，需要登录扫描。

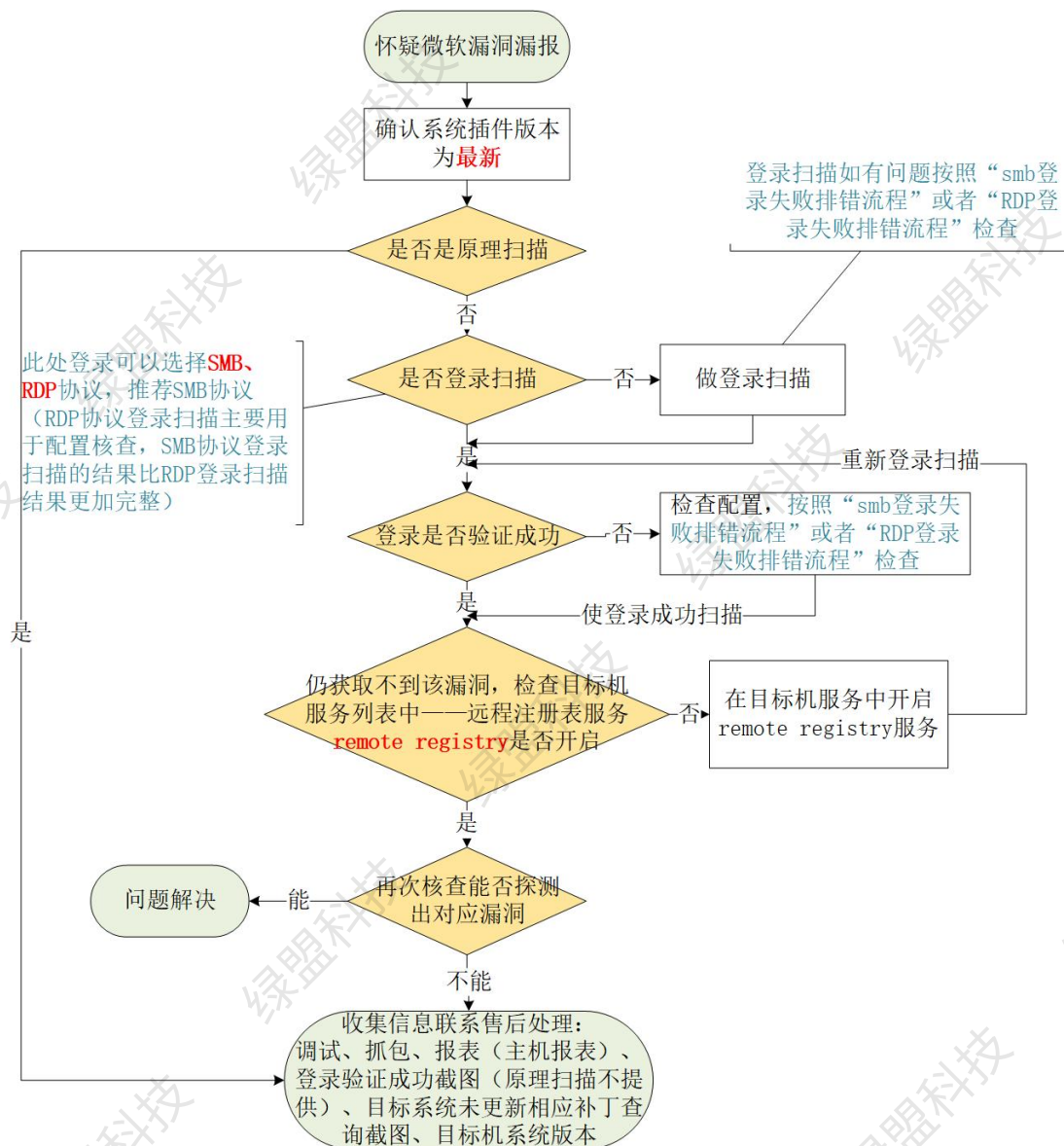


4、web 应用扫描，当需要扫描登录后的才能正常访问的 url 时，需要配置登录扫描。
例如：https://10.66.245.183/index 这个 url，没有登录情况下访问，会 302 跳转到登录页面。如果要扫描这个 url 就需要登录扫描。



(二) 微软漏洞漏报

1. 流程图

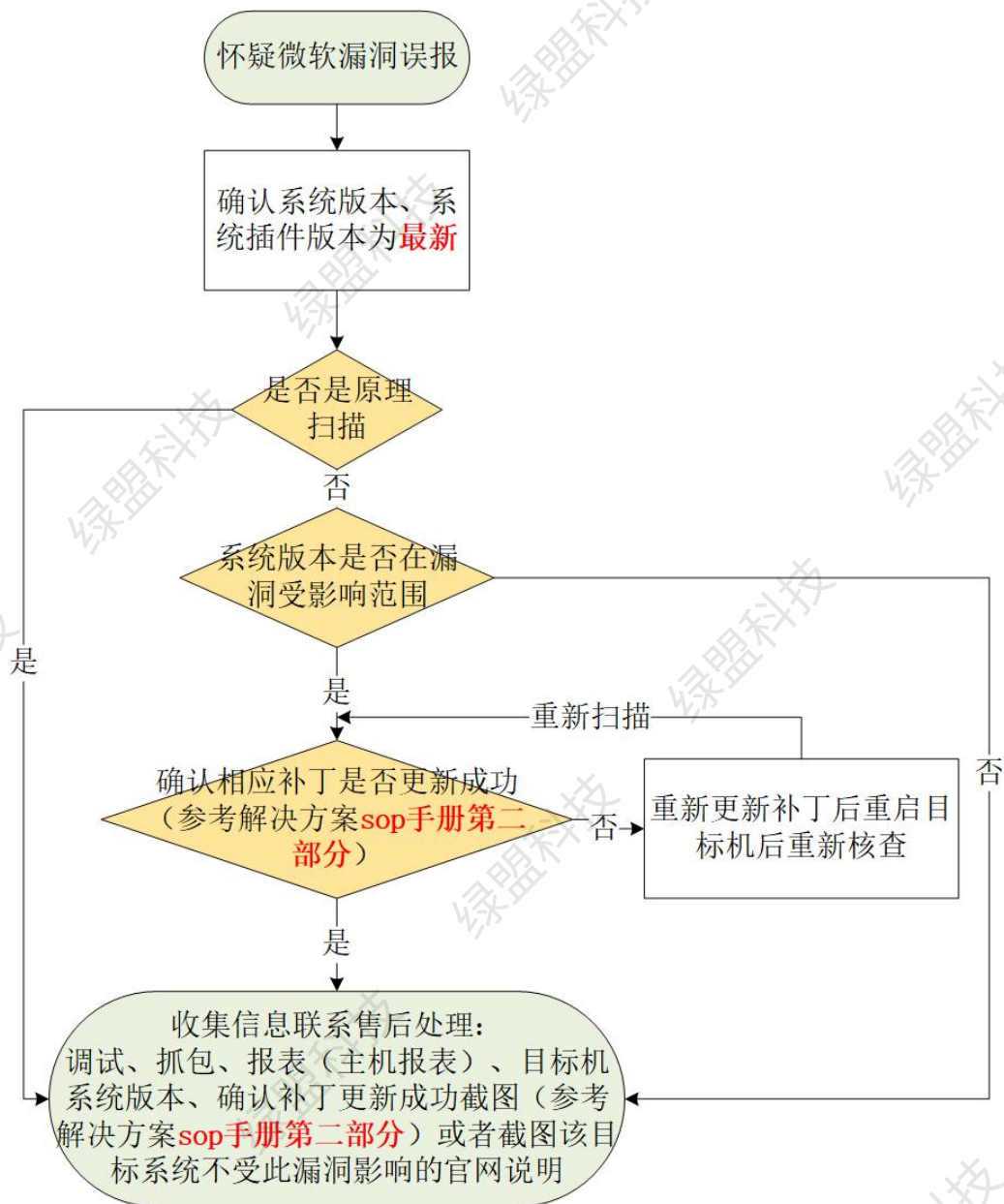


2. 流程答疑

登录方式参考 SMB 或 RDP 登录流程

(三) 微软漏洞误报

1. 流程图



2. 流程答疑

- 1、系统插件必须保持当前官网最新，以排除过往版本 bug 影响
- 2、确认目标系统是否在微软官网声明的受影响范围内
- 3、确定补丁更新成功，确认方法请参考产品使用速成
- 4、确定客户更新的补丁是否存在补丁链关系，实际更新补丁已经修复了却还爆出漏洞，确认方法参考产品使用速成，如果存在补丁链替换关系，同时也得执行第三步确认，以免即使更新了补丁，实际未生效情况。

3. 排查示例

【经典案例】

win7 已经更新了 MS17-010 的补丁，也重启了电脑，依旧被远程扫描出 MS17-010 漏洞

端口	协议	服务	漏洞
445	TCP	netbios-ssn	Microsoft Windows SMB 远程代码执行漏洞(CVE-2017-0144)(MS17-010)【原理扫描】 0xc0000205L Microsoft Windows SMB 远程代码执行漏洞(CVE-2017-0148)(MS17-010)【原理扫描】 Microsoft Windows SMB 远程代码执行漏洞(CVE-2017-0146)(MS17-010)【原理扫描】 Microsoft Windows SMB 远程代码执行漏洞(CVE-2017-0145)(MS17-010)【原理扫描】 Microsoft Windows SMB 远程代码执行漏洞(CVE-2017-0143)(MS17-010)【原理扫描】 Microsoft Windows SMB 信息泄露漏洞(CVE-2017-0147)(MS17-010)【原理扫描】

排查过程：

- 1、确定设备系统插件版本为当前官网最新
- 2、确认操作系统版本为 win7 sp1 64 位旗舰版，更新的补丁，更新后重启过电脑，并且在系统中能搜索到对应的 KB 补丁

Microsoft Windows (360)	MICROSOFT VISUAL C++ 2010 X64 REGISTRATION...	2012/11/19
用于 Microsoft Windows 的安全更新(KB4012212)	Microsoft Windows	Microsoft Corporation 2017/5/14
Windows Internet Explorer 9	Microsoft Windows	Microsoft Corporation 2016/11/21

但实际上补丁更新的主要文件 c:\windows\system32\drivers\srv.sys 的版本是旧的修改时间也是早的，早于 MS17-010 补丁对文件的更新时间

属性	值
说明	
文件说明	Server driver
类型	系统文件
文件版本	6.1.7601.17608
产品名称	Microsoft® Windows® Operating System
产品版本	6.1.7601.17608
版权	© Microsoft Corporation. All rights reserved.
大小	458 KB
修改日期	2015/11/19 15:25
语言	英语(美国)
原始文件名	SRV.SYS

微软官方给出的此补丁对于 win7 64 位系统主要更新的 srv.sys 文件版本和时间如下

Srv.sys	6.1.7601.23689	462,848	11-Feb-2017	15:58	x64	None	Not applicable
Srv2.sys	6.1.7601.23689	405,504	11-Feb-2017	15:58	x64	None	Not applicable

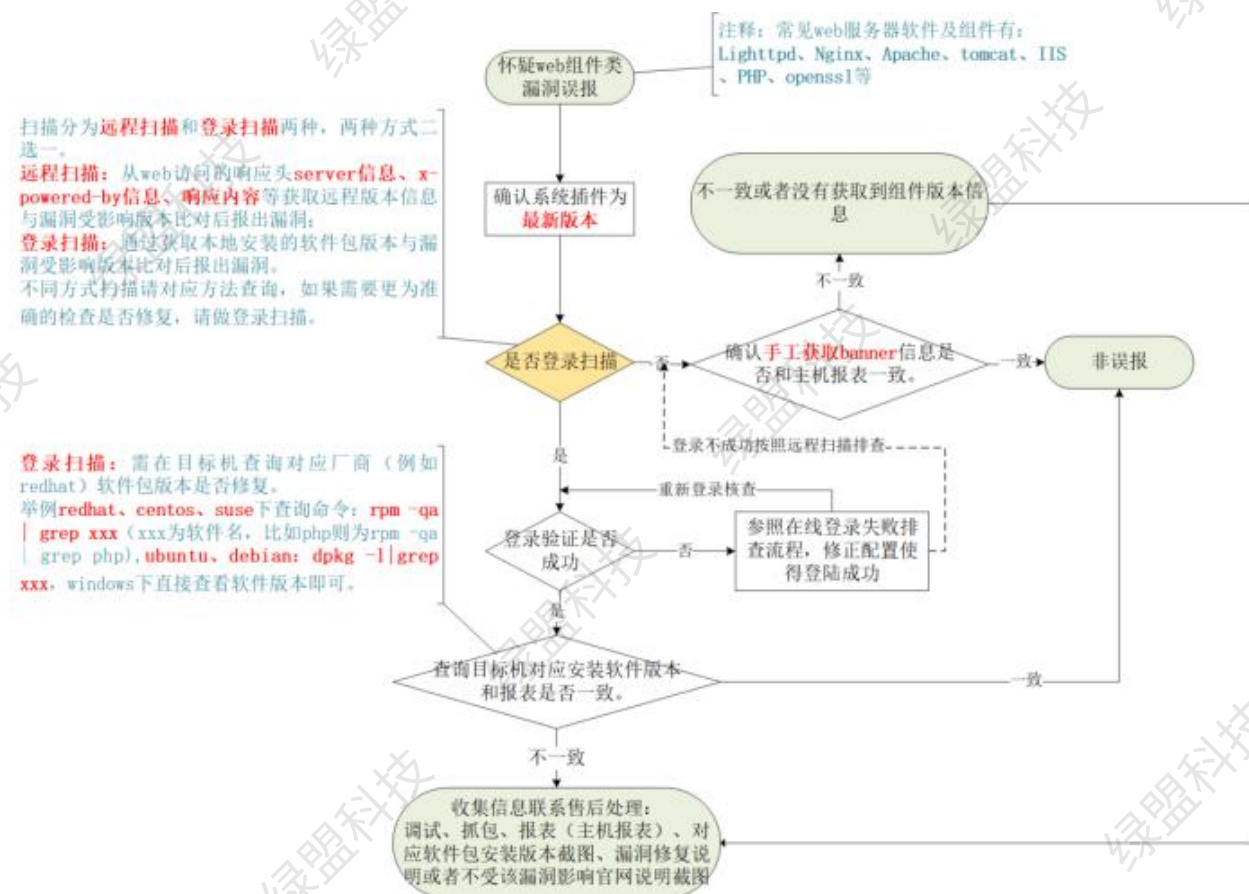
因此判定补丁更新不成功。

解决办法：重新更新对应补丁后重启，再去检查 srv.sys 文件的版本是否有更新上，版本更新上后则微软漏洞补丁更新成功。确定的确更新生效后再进行扫描问题解决。

PS: 详细的确认微软补丁类漏洞文件更新版本方法请参考产品速成里面的微软 MS 补丁相关
如果上述流程检查无误，补丁也的确更新成功，请按照流程图要求提供信息。

(四) Web 服务器软件及组件类漏洞误报

1. 流程图



2. 流程答疑

- 1、系统插件必须保持当前官网最新，以排除过往版本 bug 影响
- 2、远程扫描以获取到的远程版本匹配漏洞，如需更精确的扫描结果，需要做登录扫描，准确识别目标软件的安装信息后匹配漏洞
- 3、远程扫描版本获取，可以通过手动访问目标，获取其响应头中的 server 信息或 X-powered-by 信息等，或者通过访问时抓包过滤其响应内容中获取。
- 4、本地扫描软件版本识别，linux 下以查询软件安装版本结果为准进行匹配，例如：
centos/redhat 查询命令为：`rpm -qa | grep 软件名`；debian/ubuntu 查询命令为：`dpkg -l | grep 软件名`

3. 排查示例

【经典案例一】

已升级修复对应漏洞且服务器上查询对应软件版本已经不在受影响范围内,但是远程扫描还能扫描到相应 web 服务器组件类漏洞

排查过程:

首先查看主机报表上获取到的漏洞信息:

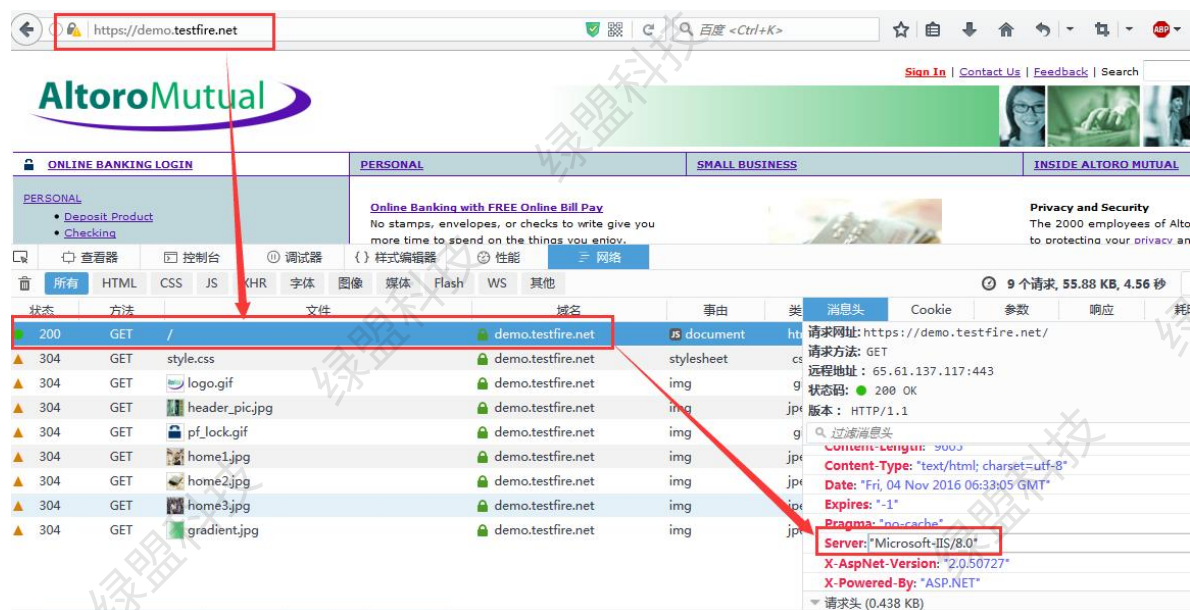
80	TCP	http	PHP libmagic/apprentice.c apprentice_load函数拒绝服务漏洞(CVE-2014-9426)
			PHP/5.2.6

确认报表中爆出漏洞对应的端口和协议是什么,如果协议为 http,那么就以 http://IP:port 去访问,用开发者工具 F12 看响应头里面的 server 信息(或 X-POWERED-BY 信息)和报表中的比对;如果协议为 https,那么就以 https://IP:port 去访问,用开发者工具 F12 看响应头里面的 server 信息或 X-powered-by 和报表中的比对。如上图举例,应该以 http://IP:80 的形式去做访问。

访问前先打开 F12 开发者工具,直接按 F12,或者在浏览器中选择开发者工具:



访问网页,看如下图的 server 回显信息:



将此处回显和报表中的获取的 web 服务器软件版本作对比即可验证 RSAS 是否获取正确。远程扫描通过此类方式去获取版本信息匹配漏洞。

解决办法：删除对应软件远程 banner 回显，或者将回显改成不受影响版本，精确扫描请做本地扫描

【经典案例二】

做了本地扫描且登录是成功的，匹配中的相应 web 服务器组件内漏洞，比如 openssl 漏洞，但是本地查询 openssl version 版本已经不在受影响范围内了，怀疑误报

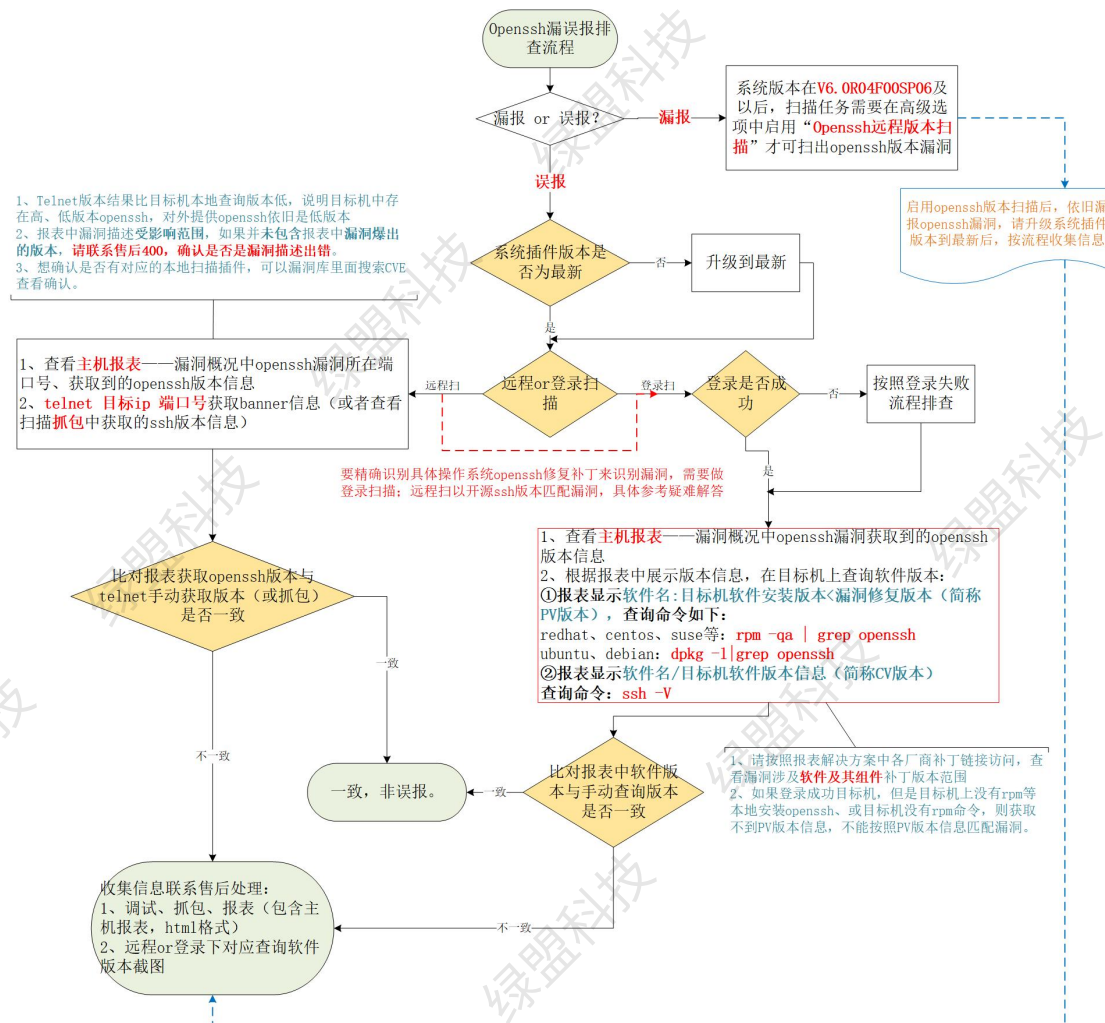
排查过程（截图暂无）：

本地扫描请以 rpm -qa 查询结果为准，openssl version 查询出来的版本结果是通过编译得到的，而编译的路径是可以自定义的，通过扫描器自动识别编译内容不现实。并且扫描器能查询到的确存在漏洞影响范围内的软件版本，就会报出漏洞

修复建议：将 rpm 包升级到无漏洞版本，或者将 rpm 包卸载

（五）openssh 漏洞漏误报

1. 流程图



2. 流程答疑

1、系统插件必须保持当前官网最新，以排除过往版本 bug 影响

2、需要明确目标设备的 openssh 是开源版本还是厂商定制版：

①开源版本：

由 OpenSSH 开源社区维护的免费版本，所有人都可以从对应站点获取相关所需软件。若用户直接使用下载软件，没有对其进行二次开发修改，那么如果需要对已知 Bug 进行修复，通常情况下只需要直接升级到某个特定版本即可。

②厂商定制版：

某些操作系统厂家（Redhat、AIX、SUSE、Centos 等）从 OpenSSH 开源社区获取该软件，将其集成到自己的操作系统中，并做了二次修改。Bug 修复不再单独使用开源版本提供的单独升级包来解决，而是根据各个厂商官网提供的补丁包来升级。修复补丁打完后，只改变 OpenSSH 小版本，大版本不会发生变化。

3、openssh 两种扫描方式介绍：

①版本扫描:

开源版 OpenSSH 的漏洞都是通过升级版本修复, 因此 RSAS 对开源版 OpenSSH 的扫描方式为**远程版本扫描**, 即比对获取的目标机 OpenSSH 大版本是否在漏洞受影响范围之内, 如果在, 就报漏洞。反之则不存在漏洞。

②本地扫描:

厂商定制版 OpenSSH 通过打补丁包来修复, 修复后不会改变 OpenSSH 大版本, 只会改变 OpenSSH 的小版本, 不同的厂商的补丁包都不一样, 版本展示也会存在差异。所以我们针对这种情况增加了 Linux 本地扫描插件。如果客户是这种情况的话, 需要对目标系统进行**登录扫描**, RSAS 获取到客户是哪种操作系统和 OpenSSH 具体的小版本信息, 再比对规则确认是否要报出漏洞。。

(注意: 因为权限问题, 如果不登录或者无法登录, 是获取不到小版本号的。**如果是国产化 linux 极有可能不支持本地漏洞扫描, 此类操作系统可与技术支持确认**)

4、如何判断是否做了登录扫描且登录成功?

①下发任务是做了登录操作 (登录验证成功)

②查看主机报表信息是否有获取到操作系统的详细版本, 获取到了 openssh 补丁信息:

操作系统名字	版本号
CentOS Linux	6

主机报表漏洞概述中获取到具体补丁号:



3、如何查看扫描器远程扫描获取到的 openssh 版本信息

①获取主机报表:

②openssh 版本信息在主机报表中展示, 如下图:

22	TCP	ssh	OpenSSH J-PAKE授权问题漏洞(CVE-2010-4478) OpenSSH 远程权限提升漏洞(CVE-2016-10010) OpenSSH MaxAuthTries限制绕过漏洞(CVE-2015-5600) OpenSSH/5.3
----	-----	-----	--

或者

端口	Banner
22	SSH-2.0-OpenSSH_5.3

4、如何判断 openssh 获取到的版本信息和目标机器实际版本一致。

①远程版本扫描判断方法

同网段找一台 PC telnet 目标机 SSH 端口，看 banner 回显中的版本信息是否和扫描器获取的版本一致。



②登录扫描判断方法

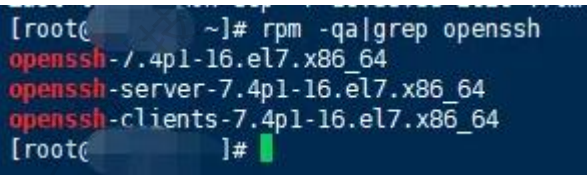
登录目标机本地查询，看查询结果是否和报表中显示一致：

如果报表中本地漏洞一栏结果显示为：**软件名:目标机软件安装版本<漏洞修复版本（简称为 PV 版本）**，则：

Centos/Redhat 查询方式: `rpm -qa | grep 软件名`

Debian/Ubuntu 查询方式: `dpkg -l | grep 软件名`

（软件名为报表中获取的软件信息名字，可能为 openssh 或者 libssh 等组件，请结合读懂报表中 RSAS 版本扫描一项理解）



如果报表中本地漏洞一栏结果显示为：**软件名/目标机软件版本信息**，则：

查询方式: `ssh -V`

注意：有可能出现 telnet 目标端口回显的 banner 信息和扫描器获取一致，但是和目标机本地看到的版本信息不一致，这种可能是设备中存在两个版本的 openssh，为了排查这种情况，建议将不用的低版本 openssh 删除。

3. 排查示例

【经典案例】

客户表示针对扫出来的 openssh 漏洞，已经根据补丁链接打了补丁修复，复扫后还是能扫出来，怀疑误报。

【排查过程】

1、确定设备系统插件版本为当前官网最新；

2、确认客户的 openssh 是开源版本还是厂商定制版；

经过确认，客户的 openssh 是厂商定制版，是 centos 系统中集成的，漏洞补丁也是 centos 官网提供的。

3、确认客户是否有做登录扫描且登录成功了？

告知客户厂商定制版需要进行登录，做本地扫描。如果客户没有做登录扫描，建议登录重扫。如果客户已经做了登录扫描，请核实登录验证是否成功且可以看看主机报表中有没有登录成功后的一些现象（方法参考上面 1.2 的内容）

经过确认，客户没做登录扫描，再复扫做登录扫描后问题解决。

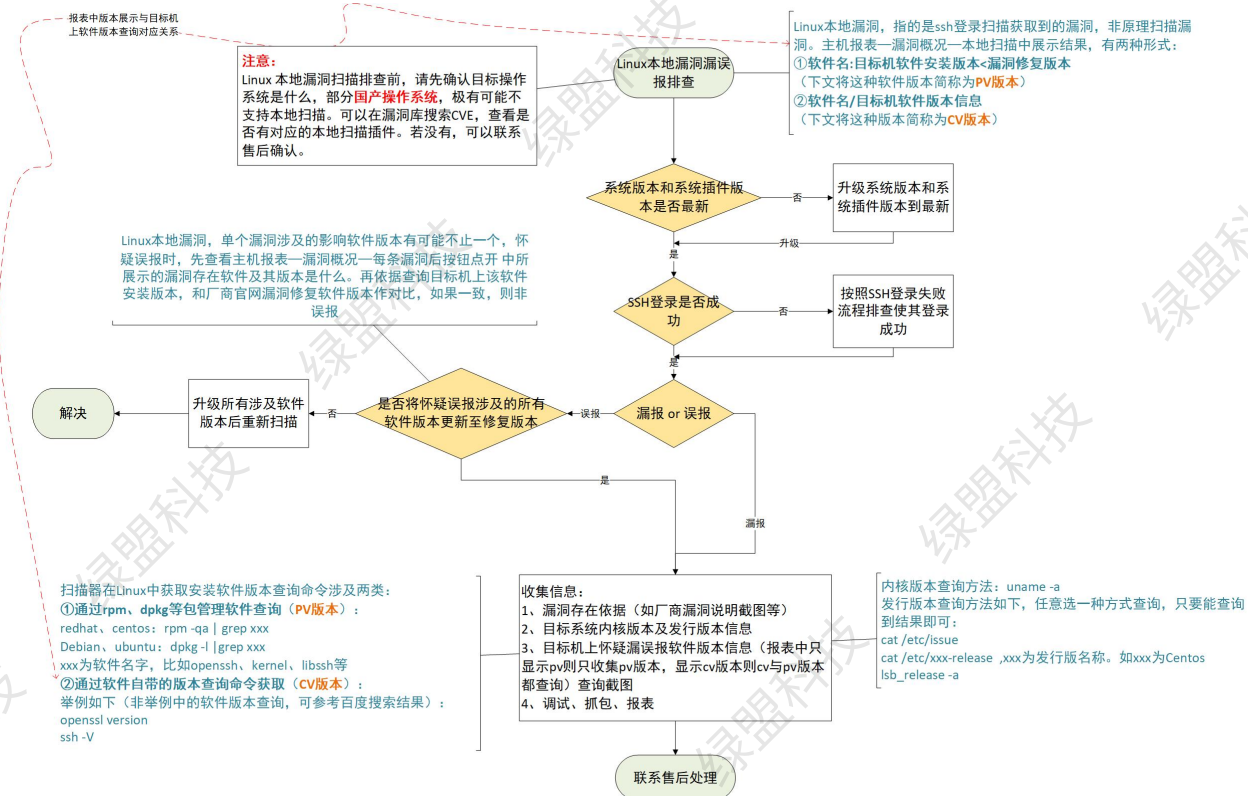
22	TCP	ssh	登录前 OpenSSH 安全漏洞(CVE-2016-1908) OpenSSH J-PAKE授权问题漏洞(CVE-2010-4478) OpenSSH 安全限制绕过漏洞(CVE-2016-10012) OpenSSH do_setup_env函数权限提升漏洞(CVE-2015-8325) OpenSSH auth_password函数拒绝服务漏洞(CVE-2016-6515) OpenSSH MaxAuthTries限制绕过漏洞(CVE-2015-5600) OpenSSH 远程代码执行漏洞(CVE-2016-10009) OpenSSH 'schnorr.c'远程内存破坏漏洞(CVE-2014-1692) OpenSSH sshd mm_answer_pam_free_ctx释放后重用漏洞(CVE-2015-6564) OpenSSH glob表达式拒绝服务漏洞(CVE-2010-4755) OpenSSH 'x11_open_helper()'函数安全限制绕过漏洞(CVE-2015-5352) OpenSSH <=7.2p1 xauth命令注入漏洞(CVE-2016-3115) OpenSSH默认服务器配置拒绝服务漏洞(CVE-2010-5107) OpenSSH 远程权限提升漏洞(CVE-2016-10010) Portable OpenSSH 'ssh-keysign'本地未授权访问漏洞 探测到SSH服务器支持的算法 OpenSSH sshd monitor组件欺骗漏洞(CVE-2015-6563) SSH版本信息可被获取 OpenSSH CBC模式信息泄露漏洞(CVE-2008-5161)【原理扫描】 OpenSSH 'ssh_gssapi_parse_ename()'函数拒绝服务漏洞 OpenSSH 本地信息泄露漏洞(CVE-2016-10011) OpenSSH auth_parse_options函数信任管理漏洞(CVE-2012-0814) OpenSSH 信息泄露漏洞(CVE-2011-4327)
----	-----	-----	---

扫描后就没有再报这些漏洞了。

4、如果第三步没解决问题，请根据流程图中的内容收集信息处理。

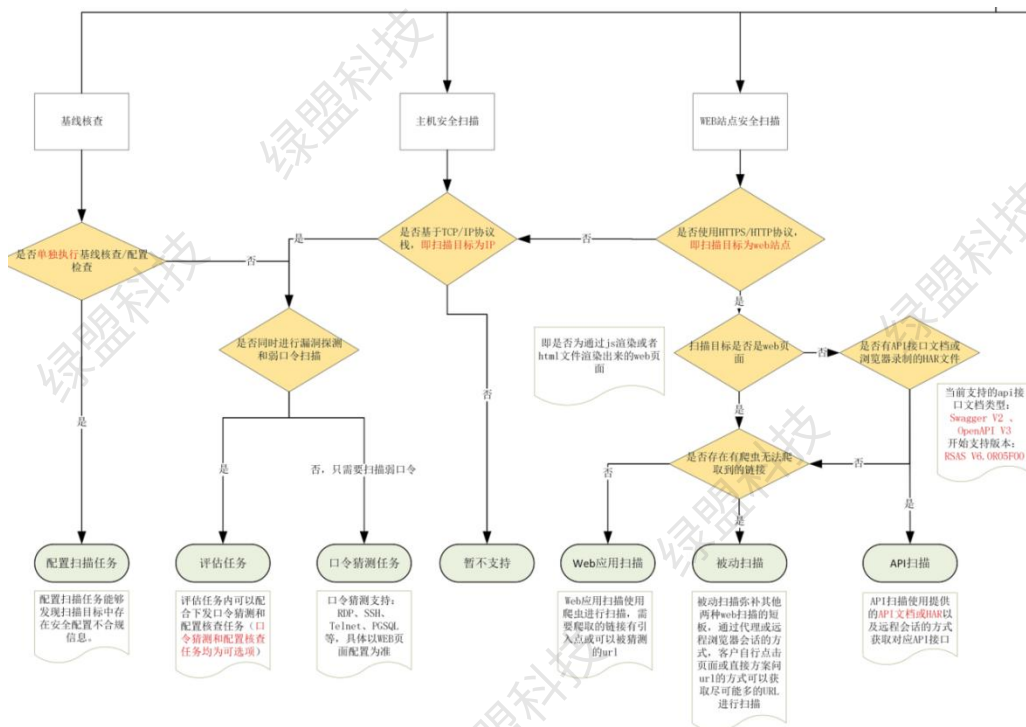
(六) linux 本地漏洞漏误报排查

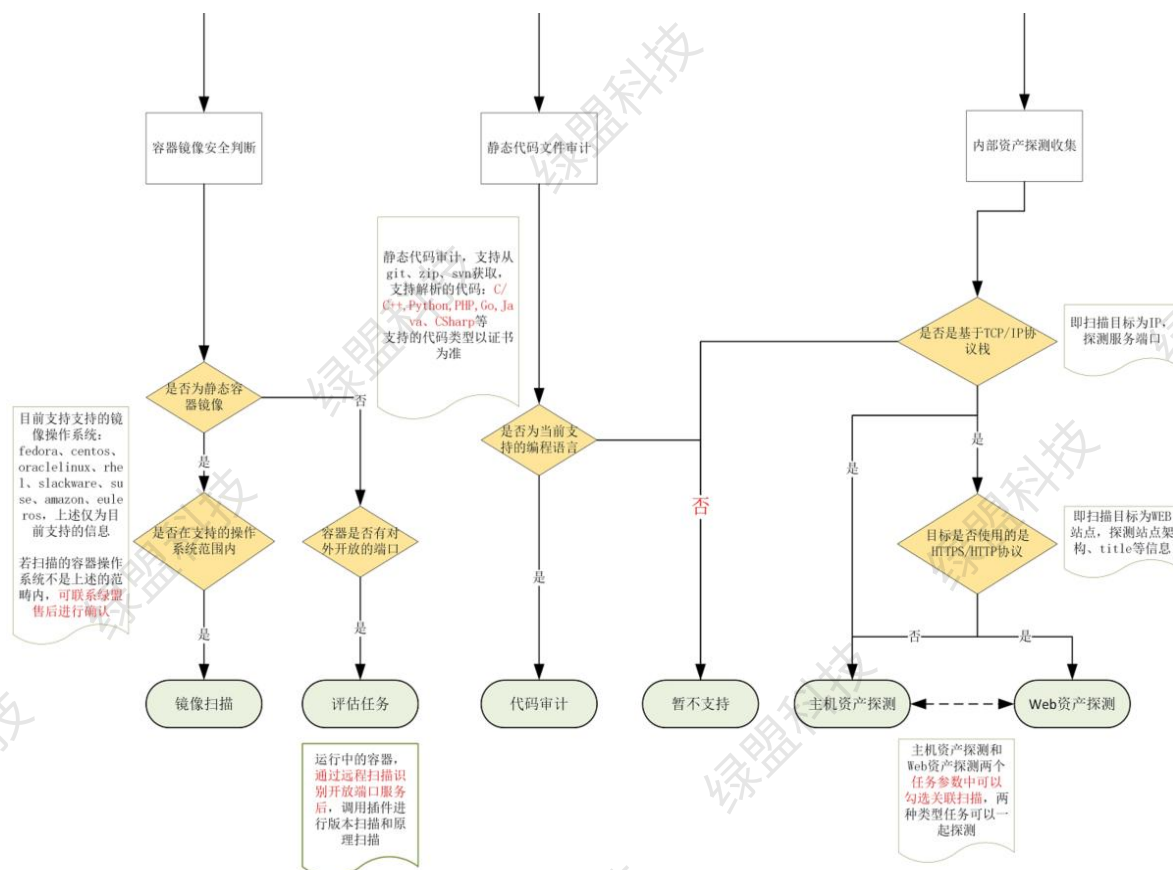
1. 流程图



（七）各任务类型区别，怎么判断该下发哪种任务

1. 流程图



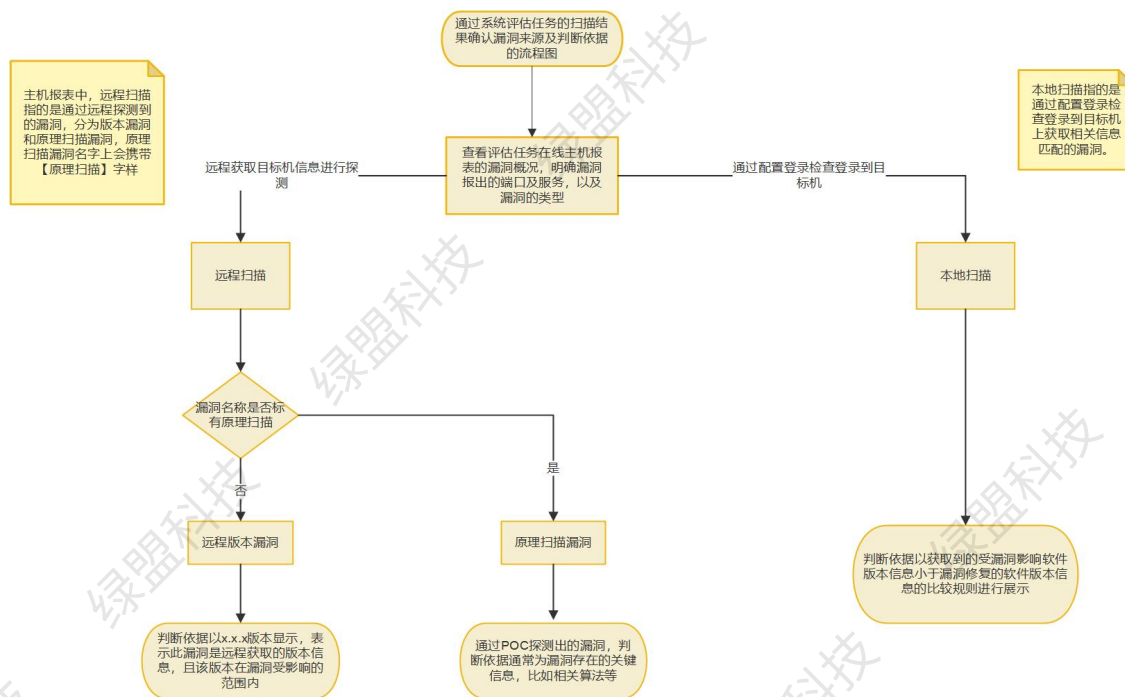


2. 流程答疑

该流程基于 RSAS V6.0R05F00 版本功能进行绘画的流程图，实际支持使用的任务以 RSAS 系统版本及证书授权为准。

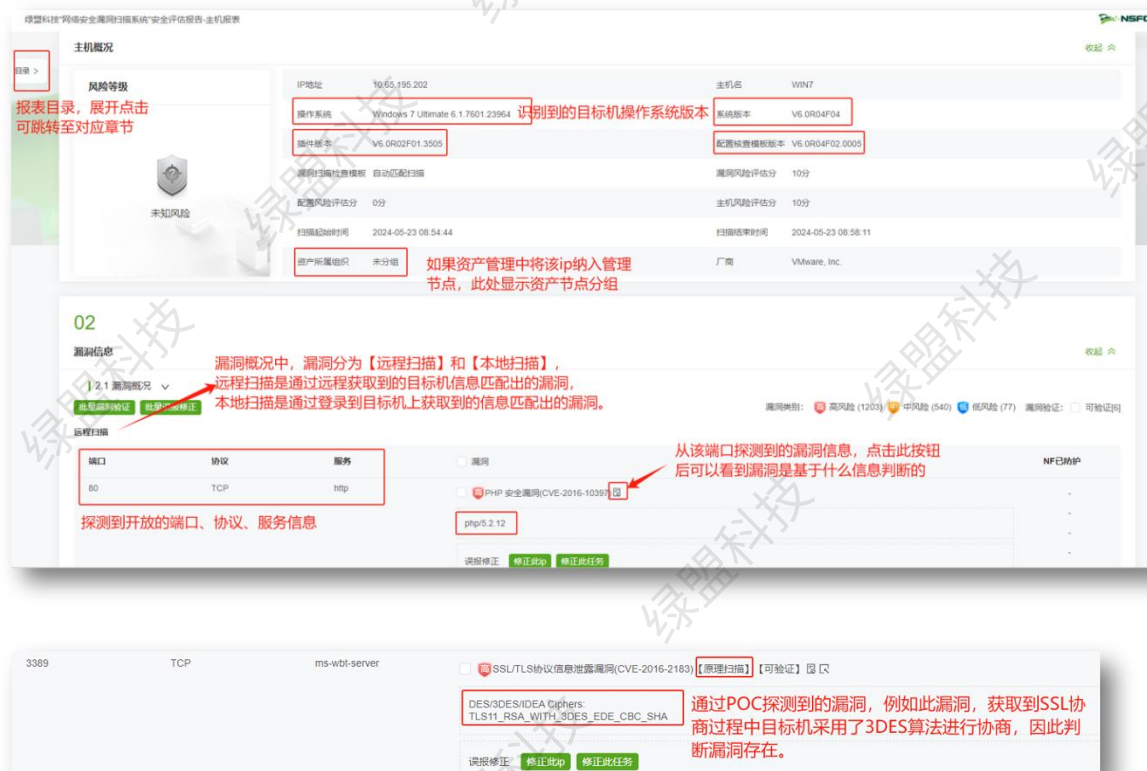
（八）通过系统评估任务的扫描结果确认漏洞来源及判断依据

1. 流程图



2. 流程答疑

主机报表中，远程扫描指的是通过远程探测到的漏洞，分为版本漏洞和原理扫描漏洞，原理扫描漏洞名字上会携带【原理扫描】字样；本地扫描指的是通过配置登录检查登录到目标机上获取相关信息匹配的漏洞。





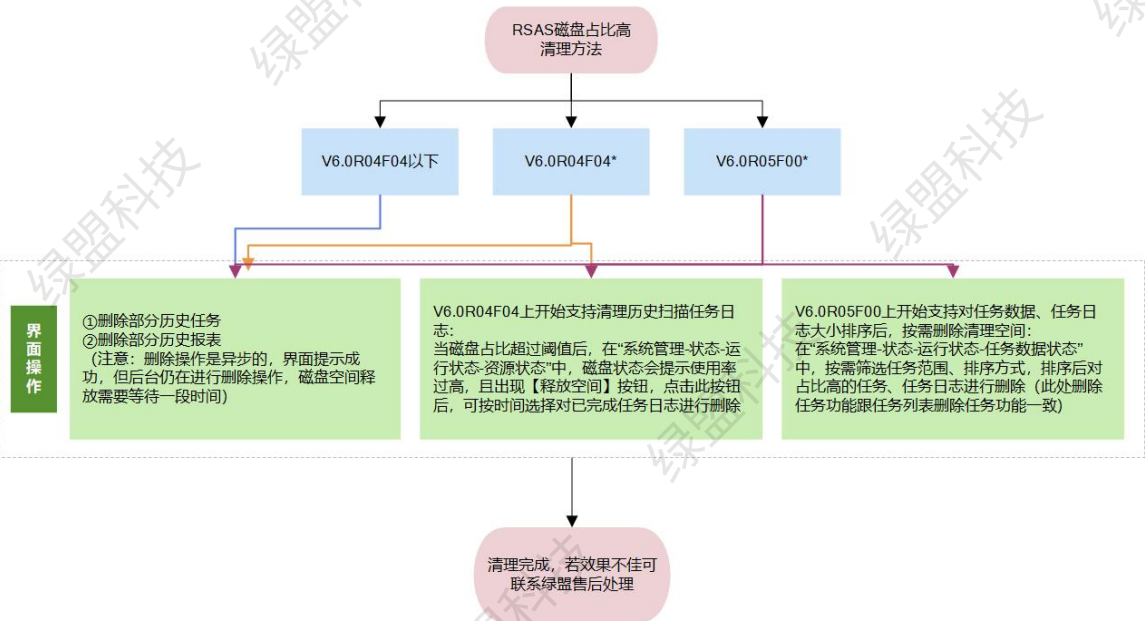
主机报表中，还提供了扫出漏洞的参考解决方案，点击到“漏洞详情”下展开对应漏洞即可查看，示例如下：



当然，提供的解决方案是适用于大多数客户环境的，如果解决方案仍无法修复，建议咨询软件厂商索取修复方案，或者联系专业的漏洞修复团队处置。

(九) 磁盘清理

1. 流程图



2. 流程答疑

①V6.0R04F04 及以上版本，系统管理-状态-运行状态-资源状态下释放空间操作图示：

资源状态			
			系统资源优化
状态	资源项	资源使用率	操作
● 正常	CPU	51.1 %	--
● 正常	内存	34.4 %	--
● 使用率过高	硬盘	54.6 %	释放空间



提示

确认释放磁盘空间吗？默认会删除部分系统日志，如果仍不能解决您的问题，您可以选择删除已完成任务的日志。

删除已完成任务日志： 不删除

删除任务日志后将无法对已删除日志的任务做故障排查！

取消

确定



提示

确认释放磁盘空间吗？默认会删除部分系统日志，如果仍不能解决您的问题，您可以选择删除已完成任务的日志。

删除已完成任务日志：

不删除

删除任务日志后将无法对已删除日志的任务做故障排查！

半年前

一月前

两周前

一周前

所有

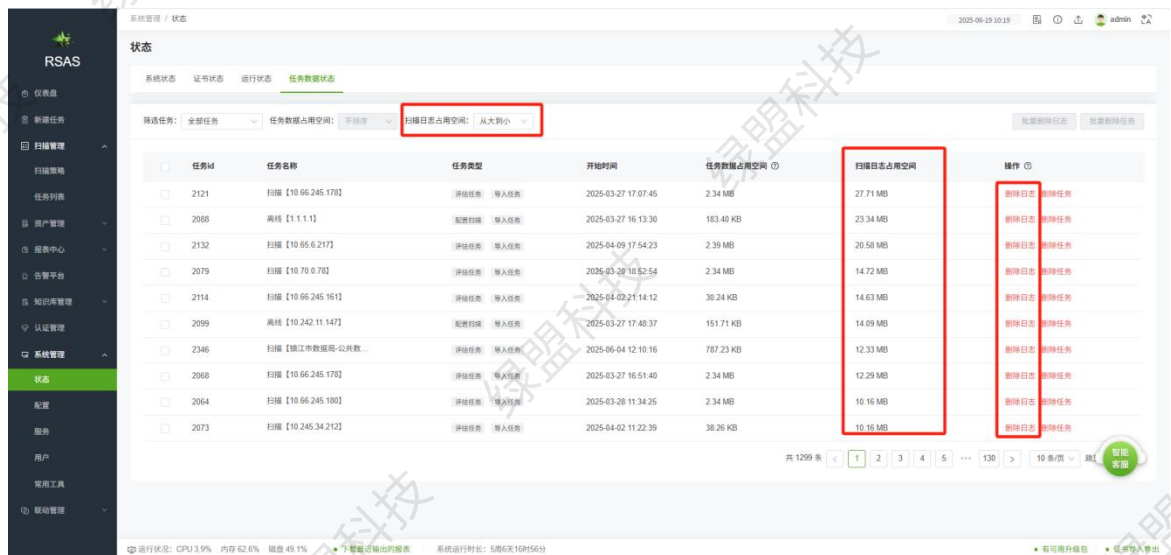
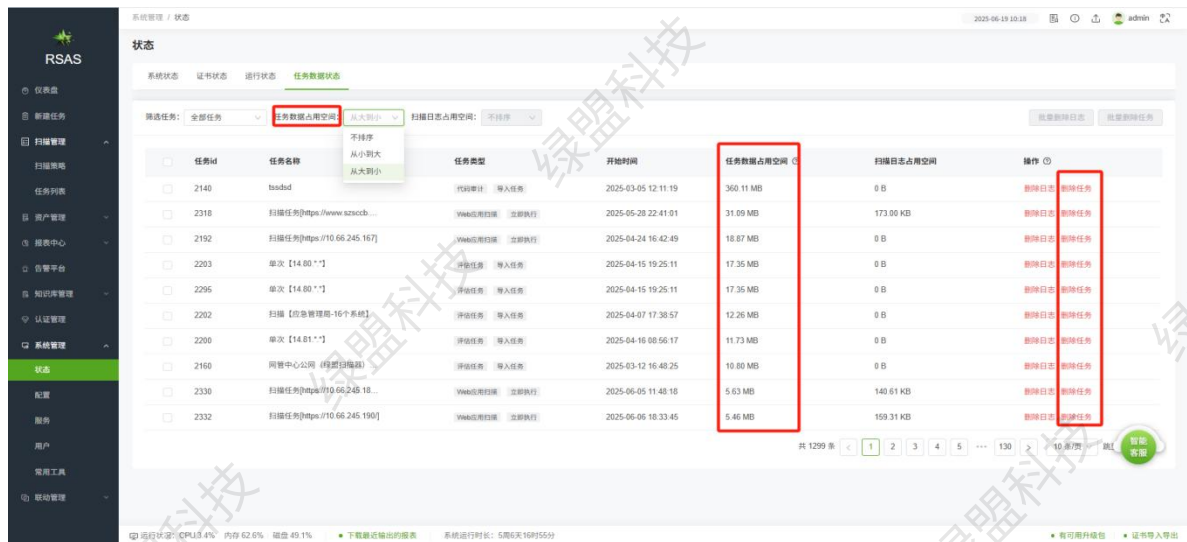
不删除

取消

确定

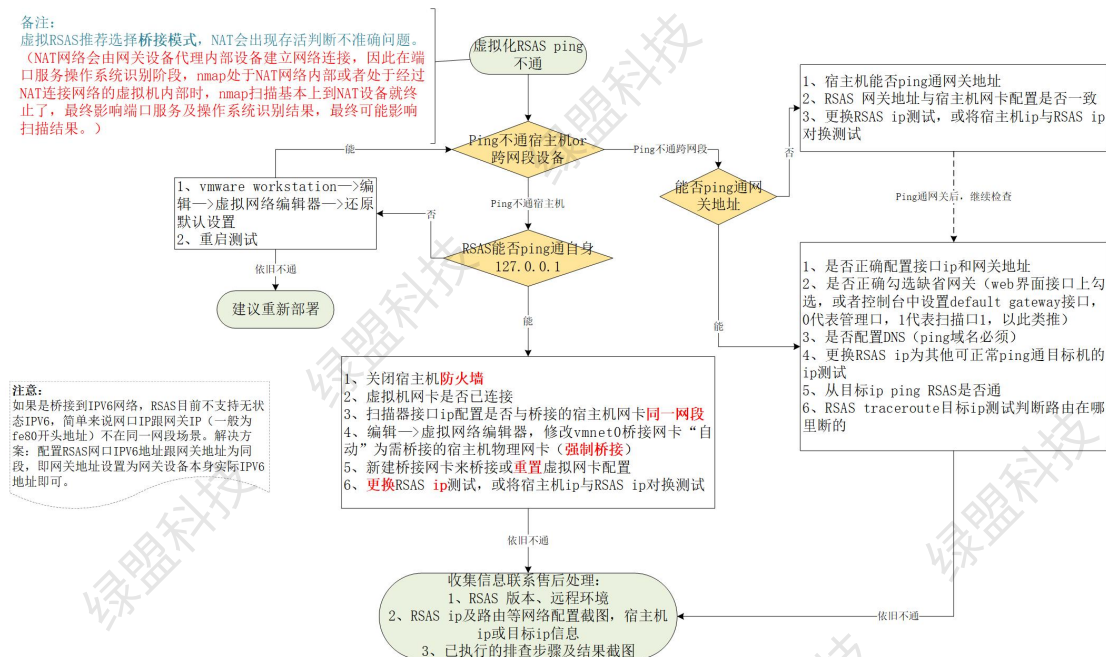
②V6.0R05F00 及以上版本，系统管理-状态-运行状态-任务数据状态操作图示：

按任务数据排序，按需删除任务释放空间：



（十）虚拟化漏扫 ping 不通

1. 流程图



2.1 流程答疑

①虚拟化 RSAS 网络说明

(1) 虚拟化漏扫 **V6.0R02F01** 镜像 (ova 格式) 加载后, 默认生成 8 个网络适配器, 用户不可做添加、删除。**V6.0R02F04** 之后的镜像 (iso 格式) 默认安装只有管理口, 扫描口需要自行虚拟机中添加虚拟网卡。

以下以 6021 镜像作说明，6024 及之后的镜像除了部署时默认接口有些不一致，后续网络排查是一致的：

(2) 网络适配器对应扫描器管理口, 网络适配器 2-7 分别对应扫描口 1-6



(3) 为了同时访问管理口和扫描口，管理口一般使用仅主机模式（或者 NAT 模式），扫描口使用桥接模式。各接口 IP 不能配置为同网段。

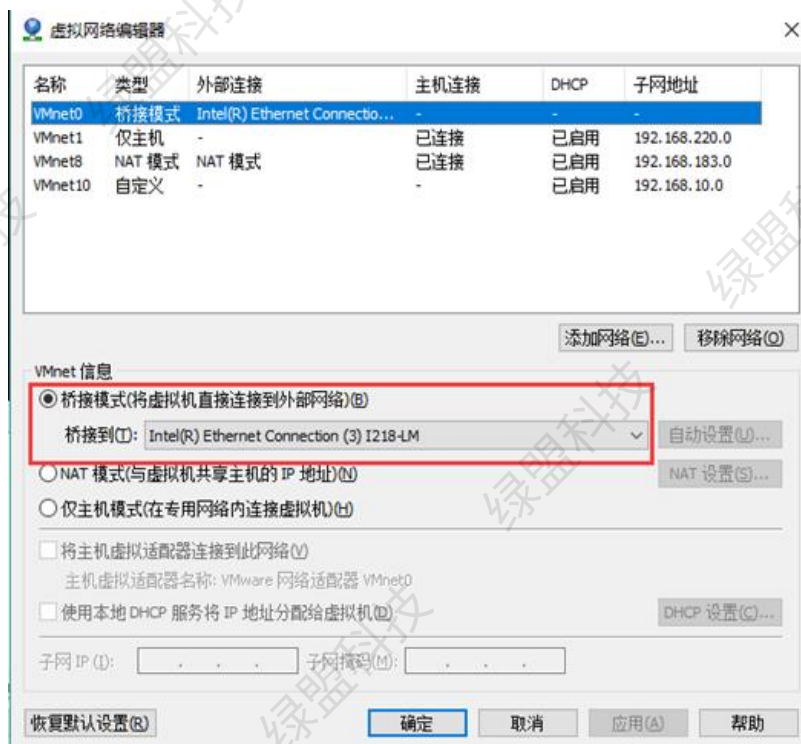
当管理口配置为仅主机模式时，管理口 IP 应与宿主机 VMnet1 配置的 IP 处于同一网段。



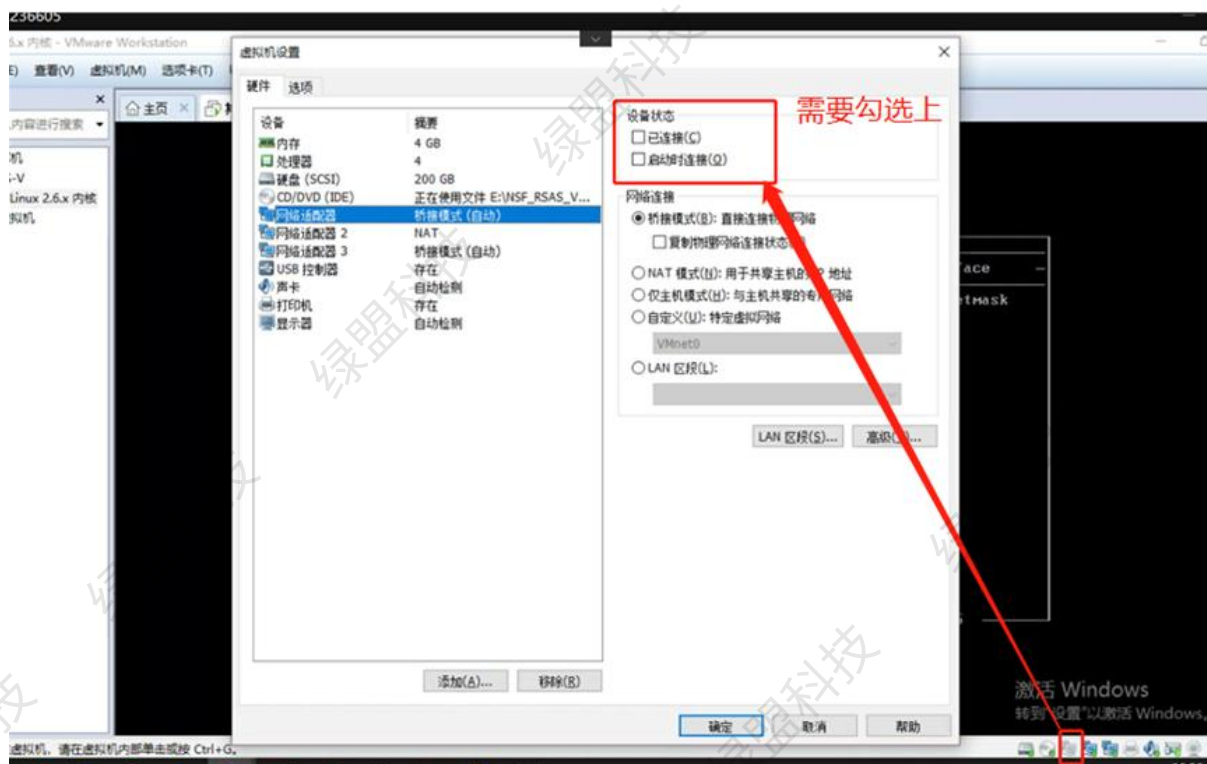
当扫描口配置为桥接模式时，扫描口 IP 应与宿主机对应桥接网卡配置的 IP 处于同一网段。

(4) 手动选择桥接网卡的方法：

点击虚拟机编辑--虚拟网络编辑器，选择桥接网卡 VMnet0，将其桥接到宿主机对应的物理网卡上。



(5) 如何确认虚拟机网卡已连接



3. 排查示例

(1) 《经典案例一》—无法访问 web 界面

问题描述: 虚拟化漏扫，管理口配置为仅主机模式，扫描口配置为桥接模式。发现宿主机可以 ping 通扫描口 eth1，但 telnet 443 端口不通，通过扫描口 IP 访问 web 页面，提示“连接超时”。同时通过管理口 IP 可以正常访问 Web 页面。

【排查过程】

1. 宿主机 cmd 下 `arp -a`，检查宿主机获取到的扫描口 IP 对应的 MAC 地址

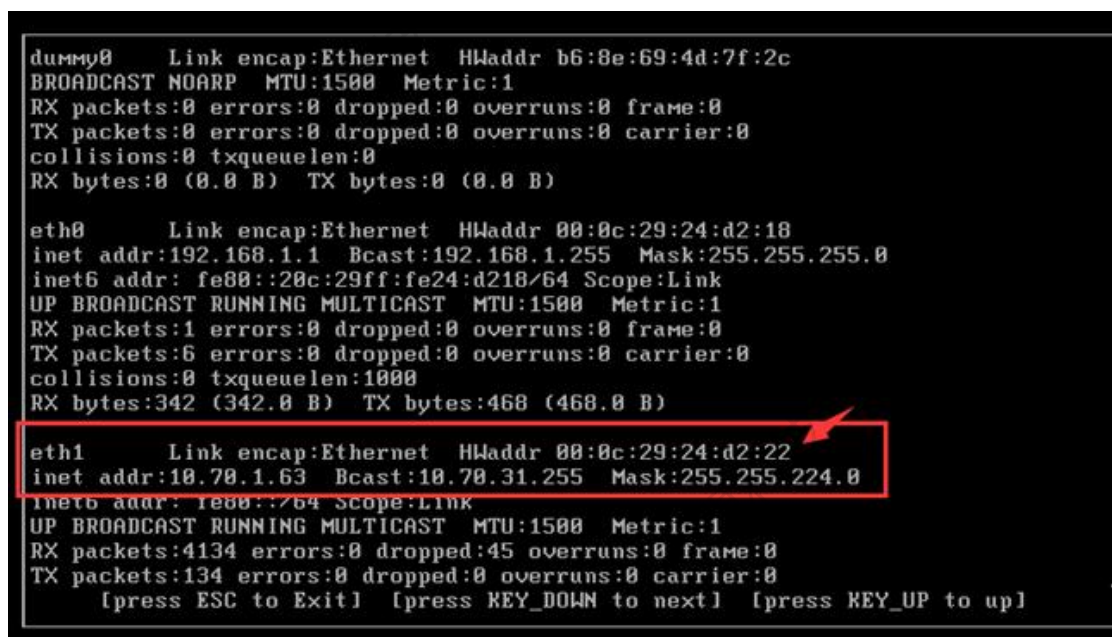
```
C:\WINDOWS\system32>arp -a 10.70.1.63

接口: 10.70.0.65 --- 0x10
Internet 地址      物理地址      类型
10.70.1.63         00-00-00-00-00-22 动态
```

2. 检查扫描口 eth1 的 MAC 地址:

网络适配器 2 的 MAC 地址与漏扫串口 System Status—Network Card 下查看的 eth1 MAC 地址一致，确认虚拟机网卡对应关系正确。

该 MAC 为扫描口 eth1 的实际 MAC 地址。



3. 对比发现，扫描口实际 MAC 地址与宿主机获取到的扫描口 IP MAC 地址不一致。

4. 将虚拟漏扫关机，再去 ping 扫描口 IP，发现依旧可以 ping 通。确认客户环境中存在 IP 冲突。

【解决办法】

修改扫描口 IP，确保无 IP 冲突情况。

(2) 《经典案例二》—无法 ping 通跨网段地址

问题描述：漏扫扫描口可以 ping 通网关、宿主机，但无法 ping 通跨网段地址。

【排查过程】

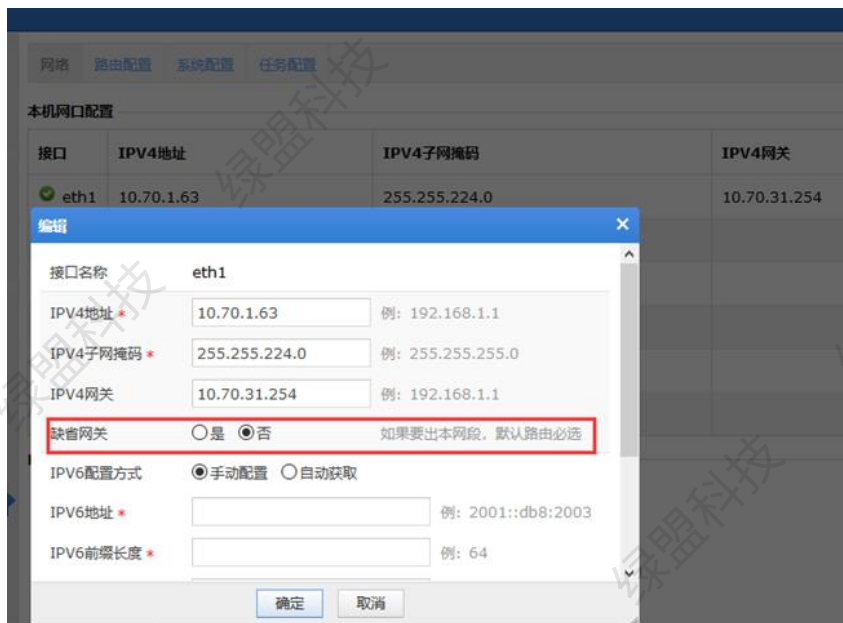
1. 系统管理—常用管理—路由信息，检查设备路由表，发现扫描口 eth1 未配置到对应目的地址的路由。



Destination	Gateway	Genmask	Flags	Metric	Ref	Use	Iface
10.70.0.0	0.0.0.0	255.255.224.0	U	0	0	0	eth1
127.0.0.0	127.0.0.1	255.0.0.0	UG	0	0	0	lo
192.168.1.0	0.0.0.0	255.255.255.0	U	0	0	0	eth0

2. 系统管理—服务—网络，检查 eth1 口配置，发现未选定缺省网关。

同时路由配置处也未添加到对应目的地址的路由。



接口	IPv4地址	IPv4子网掩码	IPv4网关
eth1	10.70.1.63	255.255.224.0	10.70.31.254

接口名称: eth1

IPv4地址: 10.70.1.63 例: 192.168.1.1

IPv4子网掩码: 255.255.224.0 例: 255.255.255.0

IPv4网关: 10.70.31.254 例: 192.168.1.1

缺省网关: ☐ 是 ☒ 否 如果要出本网段，默认路由必选

IPv6配置方式: ☒ 手动配置 ☐ 自动获取

IPv6地址: 例: 2001::db8:2003

IPv6前缀长度: 例: 64

确定 取消

网络 路由配置 系统配置 任务配置

路由信息

25 /页, 共0条 < 1 >

路由信息表 添加

接口	目的IP地址	掩码/前缀	网关	优先级	操作
i 无数据					

25 /页, 共0条 < 1 >

路由信息表 添加

【解决办法】

选择接口缺省网关为是（网关选择为“是”后，不需要在路由配置中再手动配置默认全零路由），或在路由配置处按照实际情况添加对应路由，确保路由表信息中路由正确。

编辑

接口名称 eth1

IPv4地址 * 10.70.1.63 例: 192.168.1.1

IPv4子网掩码 * 255.255.224.0 例: 255.255.255.0

IPv4网关 10.70.31.254 例: 192.168.1.1

缺省网关 ☒ 是 ☐ 否 如果要出本网段，默认路由必选

IPv6配置方式 ☒ 手动配置 ☐ 自动获取

IPv6地址 * 例: 2001::db8:2003

IPv6前缀长度 * 例: 64

确定 取消

网络 路由配置 系统配置 任务配置

路由信息

25 /页, 共1条 < 1 >

路由信息表 添加

接口	目的IP地址	掩码/前缀	网关	优先级	操作
eth1	0.0.0.0	0.0.0.0	10.70.31.254	-	

25 /页, 共1条 < 1 >

路由信息表 添加

Ping Traceroute Dig Nmap Telnet SSH 路由信息 Curl

RouteInfo 输出

IPv4 路由信息

Destination	Gateway	Genmask	Flags	Metric	Ref	Use	Iface
0.0.0.0	10.70.31.254	0.0.0.0	UG	0	0	0	eth1
10.70.0.0	0.0.0.0	255.255.224.0	U	0	0	0	eth1
127.0.0.0	127.0.0.1	255.0.0.0	UG	0	0	0	lo
192.168.1.0	0.0.0.0	255.255.255.0	U	0	0	0	eth0

(3) 《经典案例三》—如何配置扫描 VPN 后目标

问题描述: 客户期望在宿主机拨 VPN 后, 虚拟 RSAS 能扫到 VPN 的目标, 如何配置实现虚拟 RSAS 网络可达 VPN 后的目标?

vpn 场景, 主要还是看 windows 系统和虚拟软件自带的配置以及 vpn 网络能否让虚拟机去正常通信。虚拟 RSAS 本身不能拨 vpn 只能宿主机拨的场景, 这种都需要依赖宿主机上的配置来实现。参考网上类似案例:

https://zhuanlan.zhihu.com/p/380614384?ivk_sa=1024320u&utm_id=0

当前遇到的场景主要有两个:

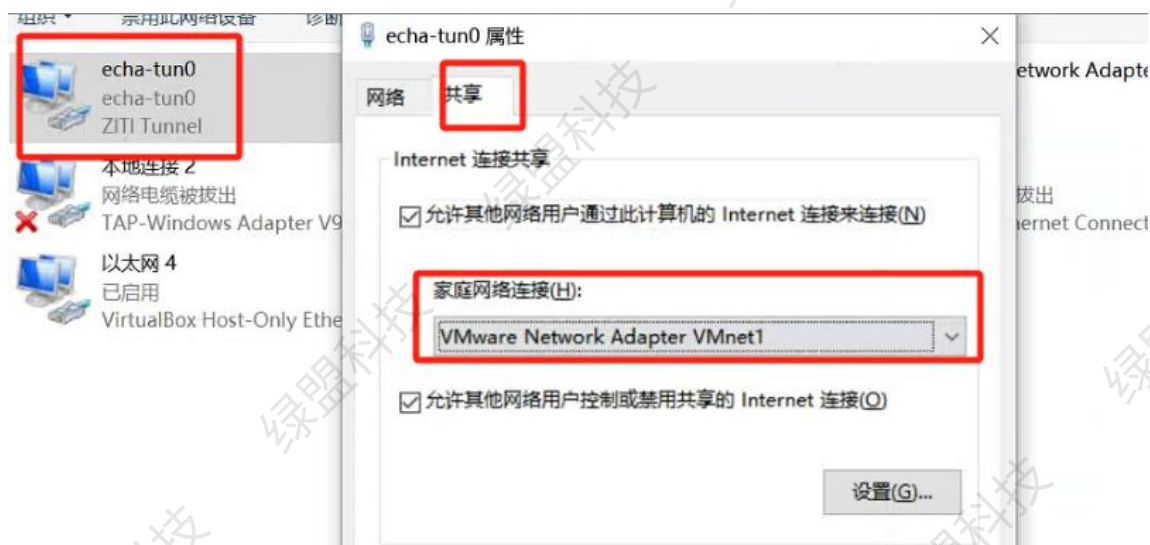
- ①宿主机上存在 VPN 网卡, 可使用 VPN 网卡共享网络方式实现 RSAS 访问 VPN 后网络;
- ②宿主机上不存在 VPN 网卡, 只能使用虚拟网络 NAT 模式实现 RSAS 访问 VPN 后网络(可能影响是扫描结果不准, 需知悉)。

【配置方法】

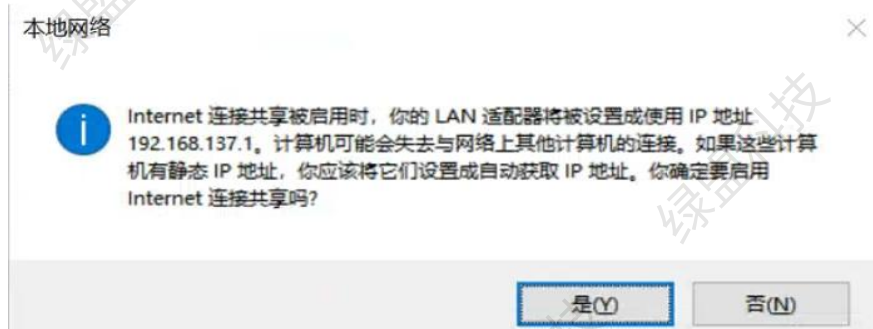
1) 虚拟化 RSAS 如何配置网络扫描 VPN 网络后的目标(宿主机存在 VPN 网卡, 共享网络)

宿主机拨 VPN 后, 在宿主机上具备 VPN 网卡场景下, 可以通过 VPN 网卡共享网络给本地任意一张网卡(除去拨 VPN 依赖的那张本地网卡), 虚拟 RSAS 再连接到该网卡后实现网络可达 VPN 后网络, 但此时 ping 宿主机的本地网卡是不通的。具体操作示例如下:

- ①把 vpn 网卡的网络共享给虚拟网卡-仅主机卡(默认为 vmnet1)



弹出提示确定:



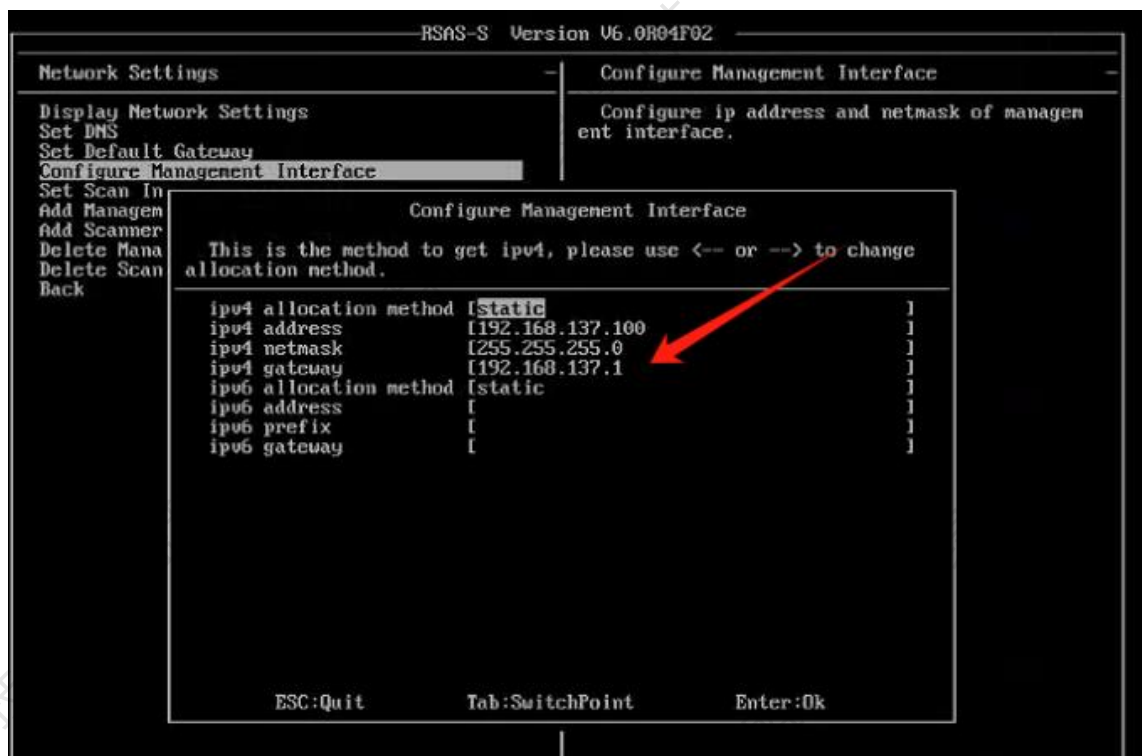
然后被共享的 vmnet1 这张仅主机卡的网络就会变成 192.168.137.x



②配置虚拟 rsas 网卡，管理口或者扫描口都行，选择其中一个口为仅主机模式。这两种选择都可以：



③去虚拟 rsas 里面，将选择为仅主机模式的卡网络配置成与仅主机卡一个网段的，网关要写成仅主机卡的 ip，例如这里配置的管理口：



然后把缺省网关选到配置的口，管理口是 0，扫描口 1 是 1，以此类推



④使用刚配置的接口 ip 去访问界面，再去常用工具-ping 测试访问 vpn 后的网络就可以通了

2) 虚拟化 RSAS 如何配置网络扫描 VPN 网络后的目标（宿主机不存在 VPN 网卡，NAT）

宿主机不存在 VPN 网卡的场景下，是无法通过桥接共享网络的方法去实现网络可达 VPN 后网络的，此时只能采用 NAT 模式。需要注意的是，NAT 模式下可能会对扫描结果产生影响，例如端口服务识别不准确等。但这种场景也只有使用 NAT 才能可达 VPN 后目标，可能的影响需知悉。

（NAT 模式扫描不准原因简述：

>由于 NAT 网络会由网关设备代理内部设备建立网络连接，因此在端口服务操作系统识别阶段，nmap 处于 NAT 网络内部或者处于经过 NAT 连接网络的虚拟机内部时，nmap 扫描基本上到 NAT 设备就终止了，最终影响端口服务及操作系统识别结果，最终可能影响扫描结果。

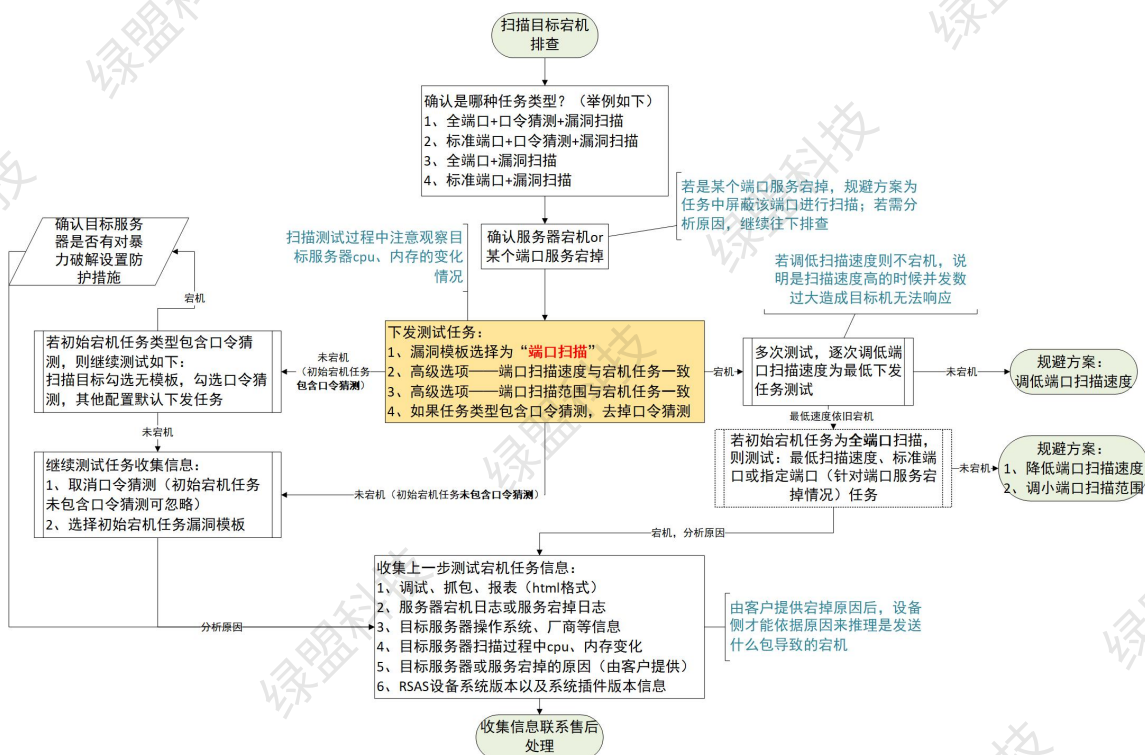
>就算 nmap 能够扫描外部网络, 由于 NAT 对 TCP 连接代理时会影响报文原本的 seq 以及 ttl 等, 从而对相应的指纹产生影响, 最终的结果就是指纹信息不准确或者混乱。从而最终导致 nmap 的 os 识别的不准确。)

操作方法简述:

将虚拟 RSAS 的网口网络连接模式选择为 NAT 模式, 该网口 ip 手动配置为 NAT 网卡同网段或者采用 DHCP 获取 ip, 再将该网口设置为默认网关口 (即在该口生成一条默认全零路由), 配置完成后即可访问 VPN 后网络目标。

(十一) 扫描器造成目标服务器宕机排查流程

1. 流程图

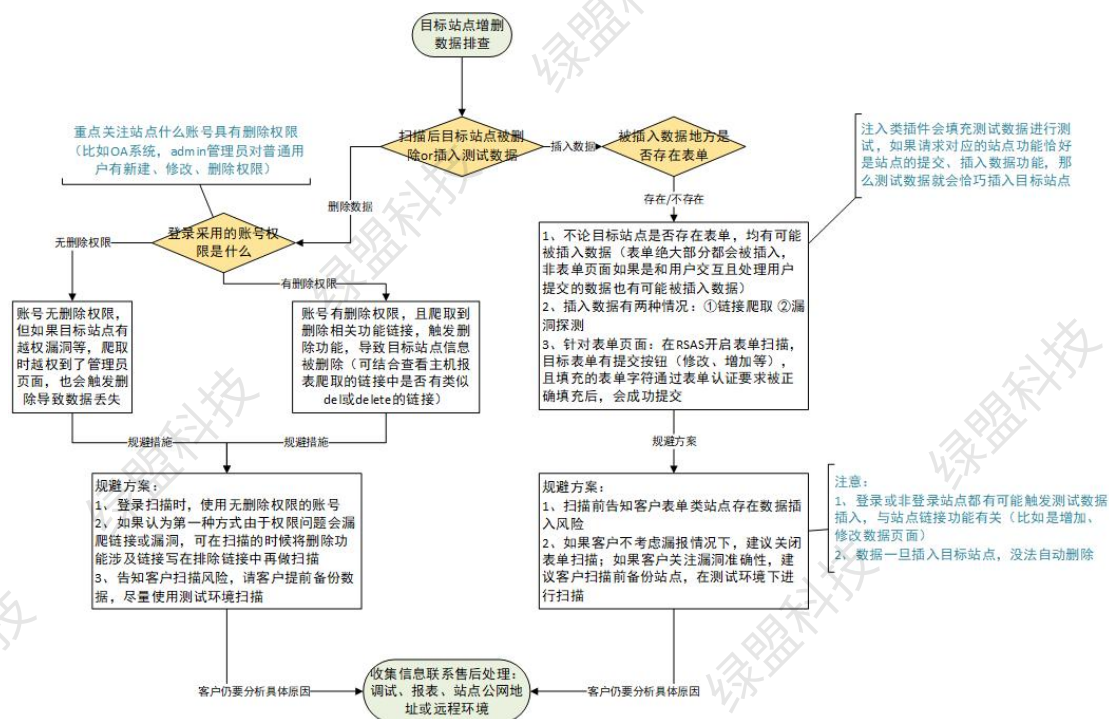


2. 流程答疑

- 1、收集好目标服务器的相关信息 (如操作系统、厂商、支持功能等)
- 2、如涉及复杂网络, 需要网络拓扑图, 包括详细 IP 标注
- 3、宕机设备上的日志, 扫描过程中服务器上的 cpu, 内存占用变化
- 4、严格按照流程图排查, 遇到宕机问题, 必须首先测试纯端口扫描, 通过此测试能初步确定是纯端口扫描就造成宕机, 还是插件扫描造成的宕机, 以便于确定问题的定位方向。

(十二) Web 扫描后目标站点被增删数据排查流程

1. 流程图

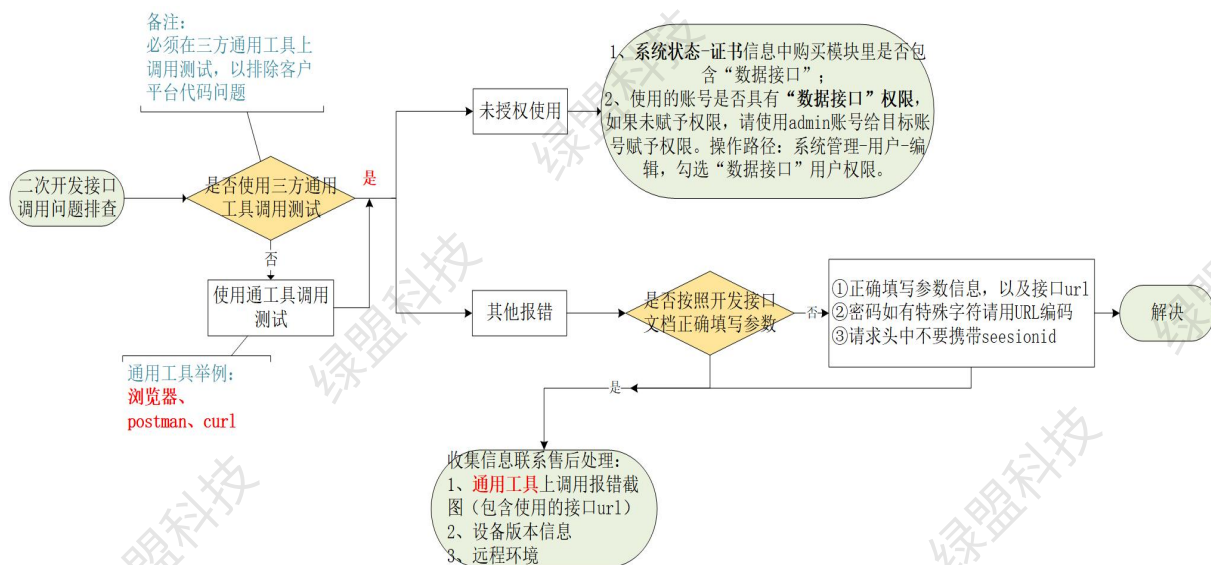


2. 流程答疑

- 1、确认使用了什么权限的账号进行登陆扫描，是否有删除，修改，新建的权限
- 2、是否开启了表单填充（任务参数-高级选项参数-表单填充/渲染策略-智能表单填充）
- 3、**需要明确一点，扫描器插入数据后没办法自动删除**
- 4、正常情况下，如果数据库服务器里有相应操作，会有日志记录。需要去日志里看看进行删除数据的IP是否是我们扫描器对应的IP，删除的时间是不是正好扫描的时间，让客户提供我们扫描器删除数据的证据。
- 5、使用RSAS扫描完目标站点后，发现目标站点被插入了很多测试数据、或者如果站点有发送邮件的功能，扫描站点的过程中发送了很多的测试邮件等等~~~如果插入的测试数据的特征类似于以下：atestuseru、atestpwdu、atestu@example.com、13456659734、beijing、13800138000等等，说明测试数据确实是扫描器扫描时插入的，除此之外的测试数据，不是扫描器扫描时插入的。

（十三）二次开发接口（数据接口）排查流程

1. 流程图



2. 流程答疑

1、二次开发接口简介

二次开发接口，也叫数据接口。该接口一般用于提供给客户对设备做联动管理，客户可以通过我们提供的接口方式，使用第三方软件调用接口方法来管理我们的设备，或者通过调用设备的二次接口功能和其他软件进行对接、实现数据的交换和传输等。

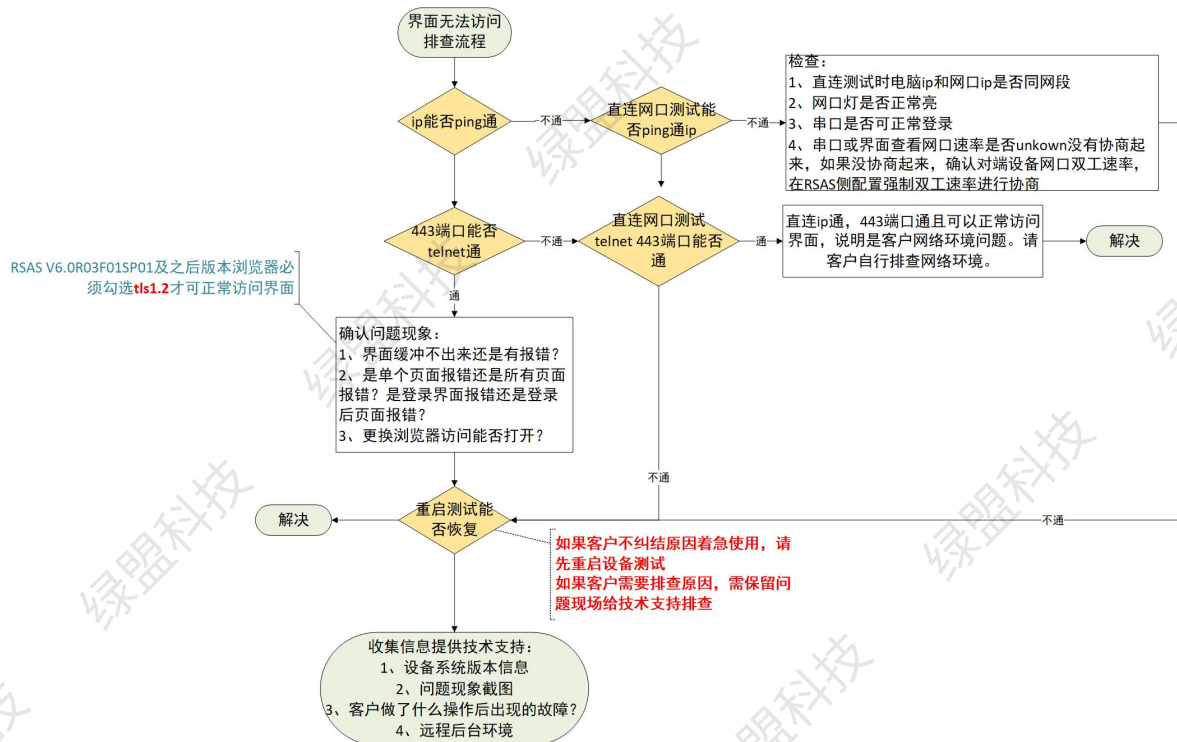
2、二次开发接口报错问题，必须在通用调用方法（例如 postman、curl 等通用工具）上调用测试，以排除目标三方平台代码问题。

只要确认浏览器（或通用工具）调用二次开发接口无问题，即 RSAS 提供的二次开发接口功能正常，此情况下若使用第三方平台调用出错，则需要客户自行排查平台问题（二次开发接口只是提供一个使用接口，而三方平台非我司产品，所以三方平台问题不在售后支持范围内）。

3、接口具体调用方法请参考二次开发接口文档（获取方式：登录 RSAS web 界面，点击右上角  关于，点击下载数据接口手册）

（十四）界面无法访问排查流程

1. 流程图

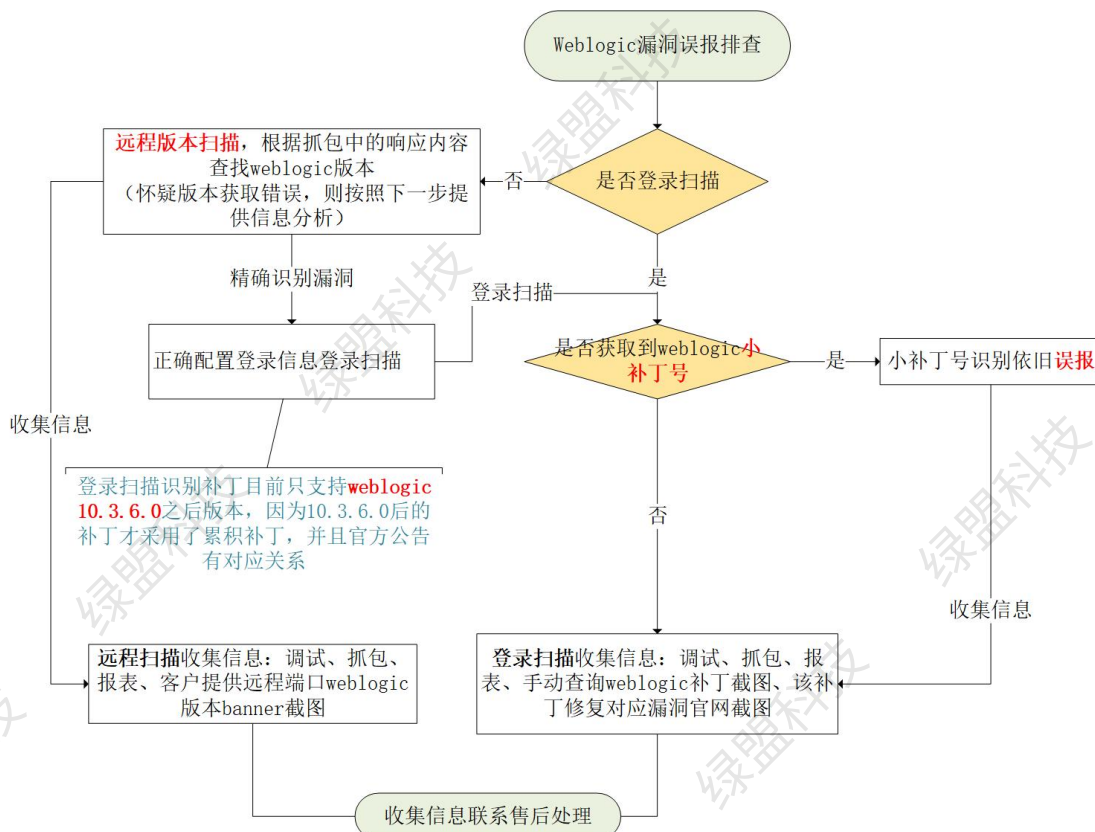


2. 14.2 流程答疑

- 1、确认系统版本是否为最新，如果不是最新建议升级到最新后再测试
- 2、需要确认做了什么操作后出现的界面无法访问？
- 3、请确认使用的浏览器是否在 RSAS 支持范围(设备用户手册中有对浏览器版本支持表记录)

（十五）Weblogic 系统漏洞误报排查流程

1. 流程图



2. 流程答疑

- 1、未做登录扫描时，通过识别 weblogic 远程 banner 信息匹配漏洞，此信息可通过扫描时候的抓包获得
- 2、未做登录扫描时，如果 weblogic 端口非默认 7001，如需识别对应端口的 weblogic 信息，则需自定义端口服务为 **www** 后扫描。自定义端口方式举例如下：



- 3、登录扫描时，各参数需要正确填写，系统登录账号可用非 root 账号（有条件情况下尽量用 root 避免权限问题，如 root 不能使用可用具有访问 weblogic 安装目录且有命令执行权限的账号，例如 weblogic 安装账号）。

4、登录扫描关于小补丁号获取相关问题，都需要提供手动查询 weblogic 补丁更新记录。
各版本 weblogic 补丁查询方式参考如下：

10 版本：

Linux: `./bsu.sh -prod_dir=安装目录（界面 wls path） -status=applied -verbose -view`

Windows: cmd 进入 bsu 所在目录（weblogic 安装主目录下的\utils\bsu）执行：`bsu -prod_dir=安装目录（界面 wls path） -status=applied -verbose -view`

12 版本：

Linux: 在 Opatch 目录下，执行命令：`./opatch lsinventory`

Windows: cmd 下进入 opatch 所在目录，执行 `opatch lsinventory`

若该方法查询不到，需要客户提供其本地查补丁的方法及结果

5、V6.0R03F00 版本上新增 weblogic 界面登录获取补丁方式，说明如下：

背景：有些客户不让 ssh/smb 登录，恰好 weblogic 通过界面登录可以获取到详细的小版本，所以增加了界面登录方法。

逻辑：如果 weblogic 界面登录参数和 weblogic ssh/smb 登录参数都勾选，优先界面登录尝试获取补丁号，如果获取不到再进行系统登录获取。

界面登录填写参数说明：

①weblogic web 控制台登录账号密码

②路径一般为：/console 或 console

WEBLOGIC策略 ^

系统登录

☐ 启用

界面登录

☒ 启用

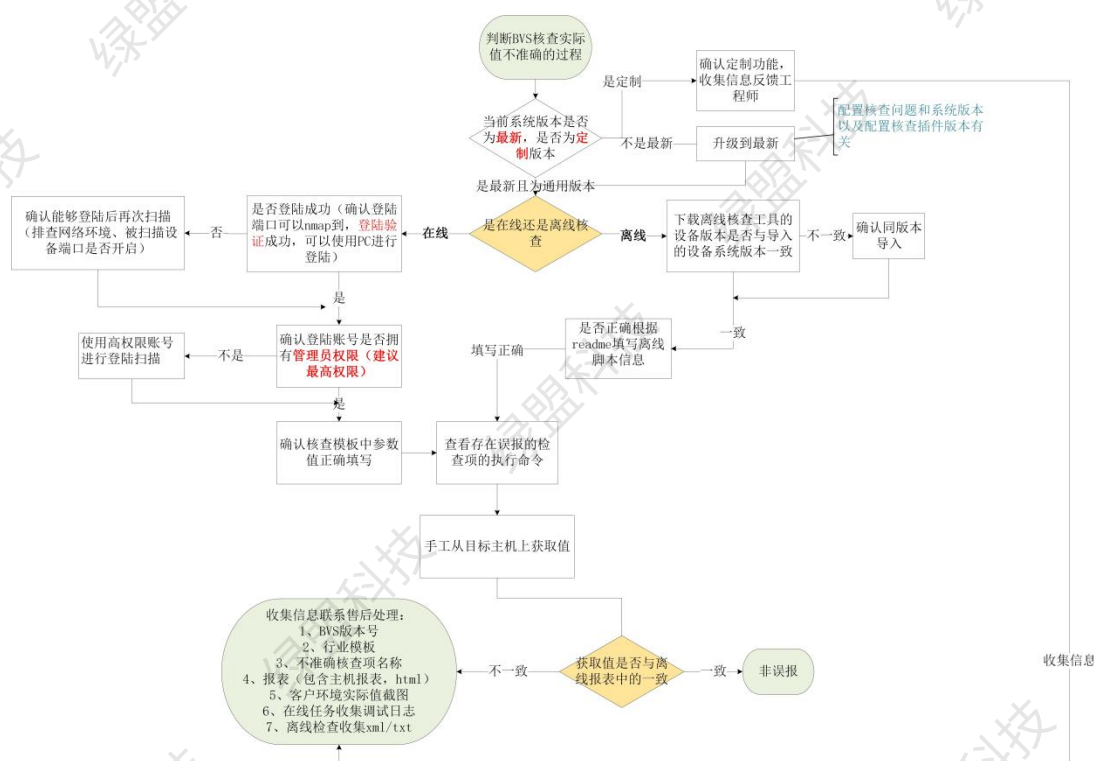
用户名 *

密码 *

路径 *

(十六) BVS 实际值不准确

1. 流程图



2. 流程答疑

- 1、如果在线核查实际值不准确，建议再离线核查一次，排除网络限制问题
- 2、确认核查的账号是否为最高权限
- 3、严格按照流程图提供最终信息，确认使用的什么行业模板的哪个模板
- 4、针对实际值不准确项，按照模板中执行命令手动获取值与报表获取值进行对比。

3. 排查示例

【经典案例】

绿盟科技 linux 核查模板离线核查，检查点“对于使用 IP 协议进行远程维护的设备，应禁止使用 telnet 协议”未获取到实际值。

序号	检查点	实际值	匹配规则	标准值	配置方法	结果
1	对于使用 IP 协议进行远程维护的设备，应配置使用 SSH 协议	sshd	字符串相等	sshd	在网站上免费获取 OpenSSH http://www.openssh.com/ ，并根据安装文件说明执行安装步骤	成功
	对于使用 IP 协议进行远程维护的设备，应禁止使用 telnet 协议		字符串包含	yes	利用命令 <code>rpm -qa grep telnet</code> 查看是否安装 telnet 和 telnet server 如果安装的话 1. 编辑 <code>/etc/xinetd.d/telnet</code> ，修改 <code>disable = yes</code> 。 2. 激活 xinetd 服务。命令如下： <code># service xinetd restart</code> 如果没安装则说明禁用 telnet 服务	失败

排查过程：

- 1、确认是离线核查，且核查使用账号为最高权限 root
- 2、手工获取值与报表对比，获取方法如下：

① 点击另存为绿盟科技 linux 核查模板（另存为才可看到具体的检查点命令）



② 执行核查模板中的初始化命令（初始化命令会执行登录、相关结果写入临时文件等操作，检查点获取配置结果可能会从初始化命令中得到。因此手动获取实际值时必须执行先执行初始化命令）

注意事项：执行初始化命令前需要将命令中的变量手动更换为实际需要填写的值，比如下图中的 NSF {Linux_su_user} 对应 su 用户，NSF {Linux_su_password} 为 su 密码，全局搜索替换这两个变量为具体值。其他核查模板初始化命令类似，注意查找替换 NSF {} 名称的字符串即可。

仪表盘
告警平台
资产管理
新建任务
任务列表
报表输出

认证管理
模板管理
镜像模板
配置模板
加固知识库
状态模板
报表模板
高级检查工具
ActiveX
高级加固工具

系统管理
安全中心

编辑模板

基本属性
配置检查项
附录检查项

基本信息

模板名称 * Linux 配置规范_另存为

模板分组 默认分组

系统归类 操作系统

检查类型 UNIX

模板类型 Linux

变量列表

引用名称	显示名称	类型	描述
ip	主机IP	文本类型	默认可用变量
user	登录用户名	文本类型	默认可用变量
password	登录密码	密码类型	默认可用变量
Linux_su_user	SU用户(SU或高权限用户)	文本类型	
Linux_su_password	SU密码	密码类型	

初始化命令

```
test -z "${NSF(Linux_su_user)}" || su - ${NSF(Linux_su_user)}
NSF(Linux_su_password)
echo "touch /tmp/nsfocus_mod_tmp;">/tmp/NSF(nsf_tm)_nsfocus_grub_tmp
echo "chmod 777 /tmp/nsfocus_mod_tmp;">/tmp/NSF(nsf_tm)_nsfocus_grub_tmp
echo "if [ -f /etc/grub.conf ];then">>/tmp/NSF(nsf_tm)_nsfocus_grub_tmp
```

下一步 保存 返回

③手动执行对应检查点命令（如果检查命令是查看文件内容或者查看权限，则按照说明执行获取）：

编辑模板

基本属性
配置检查项
附录检查项

配置检查项

协议安全

检查使用IP协议远程维护的设备是否配置SSH协议。禁用telnet协议

7

编辑检查项

检查项基本信息

索引 24

检查项名称 * 检查使用IP协议远程维护的设备

检查项分类 协议安全

风险值 7

检查点列表

一个检查项由多个检查点组成，各个检查点通过与或关系来决定该检查项是否合规。

序号	检查点描述	匹配规则	标准值	操作
27526	对于使用IP协议进行远程维护的设备，应配置使用SSH协议	字符串相等	sshd	
27888	对于使用IP协议进行远程维护的设备，应禁止使用telnet协议	字符串包含	yes	

添加检查点

检查点逻辑关系

各个检查点根据下边编辑的逻辑关系来计算该检查项是否合规

AND OR NOT () <-

对于使用IP协议进行远程维护的设备，应配置使用SSH协议 and 对于使用IP协议进行远程维护的设备，应禁止使用telnet协议

编辑检查项 | 编辑检查点

描述信息 *	telnet协议
配置方法	利用命令rpm -qa grep telnet查看是否安装telnet 和 telnet server 如果安装的话 1. 编辑/etc/xinetd.d/telnet, 修改 disable = yes. 2. 激活xinetd服务。命令如下: <pre># service xinetd restart</pre> 如果没安装则说明禁用telnet服务
检查方法	执行命令

执行命令

复制执行命令，粘贴到目标机回车执行

执行命令是在目标主机上执行的获取相关配置信息的命令

```
telnet_info=`rpm -qa |grep telnet`;if [ -z "$telnet_info" ]; then echo telnet disable;else cat /etc/xinetd.d/telnet 2>/dev/null | grep disable;fi;
```

```
[root@mozsh-server003 /]# telnet_info=`rpm -qa |grep telnet`;if [ -z "$telnet_info" ]; then echo telnet disable;else cat /etc/xinetd.d/telnet 2>/dev/null | grep disable;fi;
telnet disable
[root@mozsh-server003 /]#
```

根据手动执行命令发现是有回显值的，但是报表中实际值为空（如果报表上有实际值，且和手动获取一致，说明非误报，请客户检查目标机配置），说明脚本获取存在问题。

④查看离线结果 xml 文件中该检查点（检查点编号在模板中可看到为 27888）获取到的值（离线核查直接打开 xml 查看，在线核查需解开调试日志查看），将其与上一步手动获取值对比是否一致。如果一致则往下排查该检查点的匹配规则是否有问题，如果不一致，则售后反馈研发分析处理。

```
<item flag="27888">
  <cmd info="">
    <command>
      <![CDATA[
telnet_info=`rpm -qa |grep telnet`;if [ -z "$telnet_info" ]; then echo telnet disable;else cat /etc/xinetd.d/telnet 2>/dev/null | grep disable;fi;
]]>
    </command>
    <value>
      <![CDATA[
telnet disable
]]>
    </value>
  </item>
```

⑤查看检查点匹配规则，结合检查命令，发现正则表达式中只获取了服务已安装时配置文件情况 disable，未获取 telnet 服务没安装时的命令回显 telnet disable，因此判断为匹配规则问题：

执行命令

执行命令是在目标主机上执行的获取相关配置信息的命令

```
telnet_info=`rpm -qa |grep telnet`;if [ -z "$telnet_info" ]; then echo
telnet disable;else cat /etc/xinetd.d/telnet 2>/dev/null | grep disable;fi;
```

正则表达式

正则表达式用于对执行命令返回的结果进行匹配，筛选出需要的信息。可以使用括号()来表明与()内同样的参数信号中的子表达式内容将被读取；如果不使用括号，则取回匹配该正

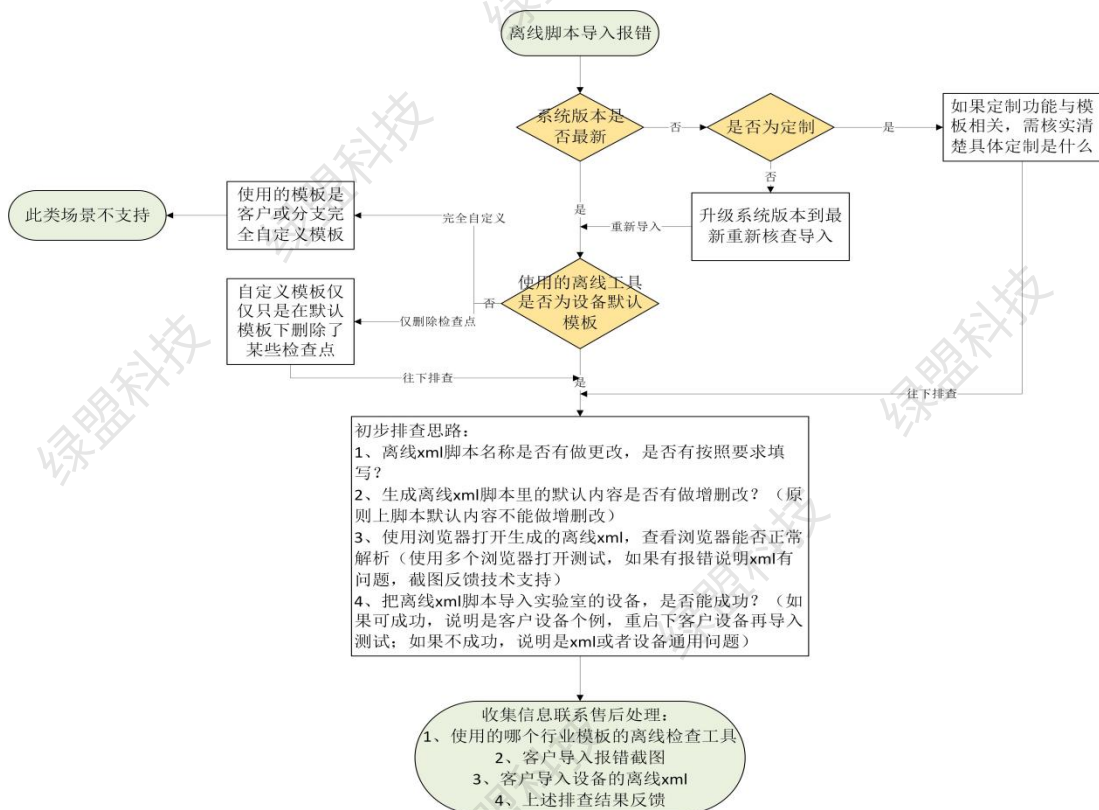
以与以下正则表达式中的子表达式内容将被读取；如果不使用括号，则取回匹配该正

匹配规则 字符串包含

期望值 * yes

(十七) 离线脚本导入报错

1. 流程图



2. 流程答疑

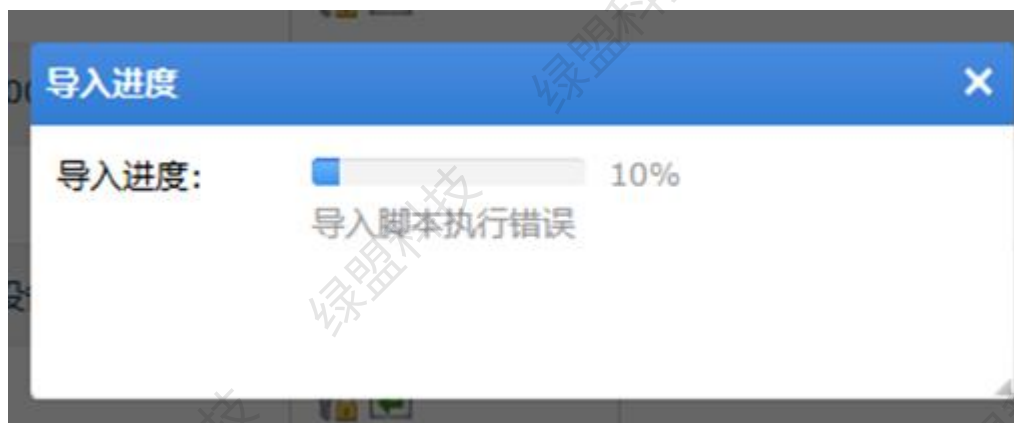
- 1、自动生成的离线脚本的名字、脚本中的内容都不能做修改，必须保持刚生成时候的样子；
- 2、如果离线核查结果跨设备导入（导入结果设备不是离线工具下载设备），需要确认两个设备的版本和购买的行业模板是否一致；
- 3、如果不是系统自带模板或研发给出的定制模板核查结果，而是用户完全自定义模板核查结果导入存在问题，售后无法支持排查（若只是另存为系统模板删除某些检查项，这类情况可支持；若不能分辨支持情况，可向工程师确认）。
- 4、对于网络设备离线核查工具比较特殊，有两种类型：一种是 securecrt vbs 脚本插件，一种是 txt 文件；txt 文件无法自动执行，需要将脚本里提供的命令在目标机上依次执行后按顺序依次贴回 txt 文档中，txt 核查文件举例如下：

```
ffabcdef-2018-0807-1733-aaa310145509.txt
1 模板名称: CheckPoint 配置规范_S1A1G1
2 模板最后修改时间: 2018-08-07 17:33:31
3 模板标志: ffabcdef-2018-0807-1733-aaa310145509
4 (使用说明: 请勿删除或改动以上文字内容)
5
6 请填写主机IP(host_ip):
7 (使用说明: 冒号后填写, 只填写勿删除, 此处若不填写, 将无法导入)
8
9 请填写变量信息:
10 CheckPoint_FW_expert:expert专家模式密码:
11 (使用说明: 按说明填写变量, 最后一个冒号后填写, 只填写勿删除, 此处若不填写, 将无法导入)
12
13 可执行命令:
14     expert
15     cp_conf admin get
16     expert expert专家模式密码 cat /opt/spwm/conf/cp_http_admin_server.conf
17     service sshd status
18     showusers
19 (使用说明: 建议顺序执行所有命令, 不要执行简写命令, 否则部分检查项会存在误报)
20
21 命令结果:
22 (使用说明:
23 1、此处的结果需要包含命令提示符, 可执行命令和命令结果,
24 例如,华为路由器, 执行"super"和"display ....."命令,需要复制以下全部内容
25 <Quidway-nsf>super
26 Password:
27 User privilege level is 3, and only those commands can be used
28 whose level is equal or less than this.
29 Privilege note: 0-VISIT, 1-MONITOR, 2-SYSTEM, 3-MANAGE
30 <Quidway-nsf>display .....
31 .....
32 <Quidway-nsf>
33 2、复制结果时, 无需每条可执行命令单独复制, 可以采用整块复制方式:
34 建议使用putty终端的 "Copy All to Clipboard"功能:
35 3、请在本行下粘贴结果,只粘贴勿删除以上文字内容。)
36
```

3. 排查示例

【经典案例】

等保 2.0 模板 S3A3G3 linux 离线核查结果文件导入设备报错：导入脚本执行错误



排查过程：

把 xml 文件用浏览器打开看是否有报错提示（多换几个浏览器打开试试，有的浏览器本身无法解析 xml 就看不到报错）：

XML 解析错误：格式不佳

位置：file:///C:/Users/LMT/AppData/Local/Temp/HZ\$D.243.2043/172.29.166.38_ffabcdef-2019-0909-行 406, 列 13:

```
export PS1="[4m[37m[PROD "$USER@"`hostname`":"`$PWD#`]"[0m "]]></value>
```

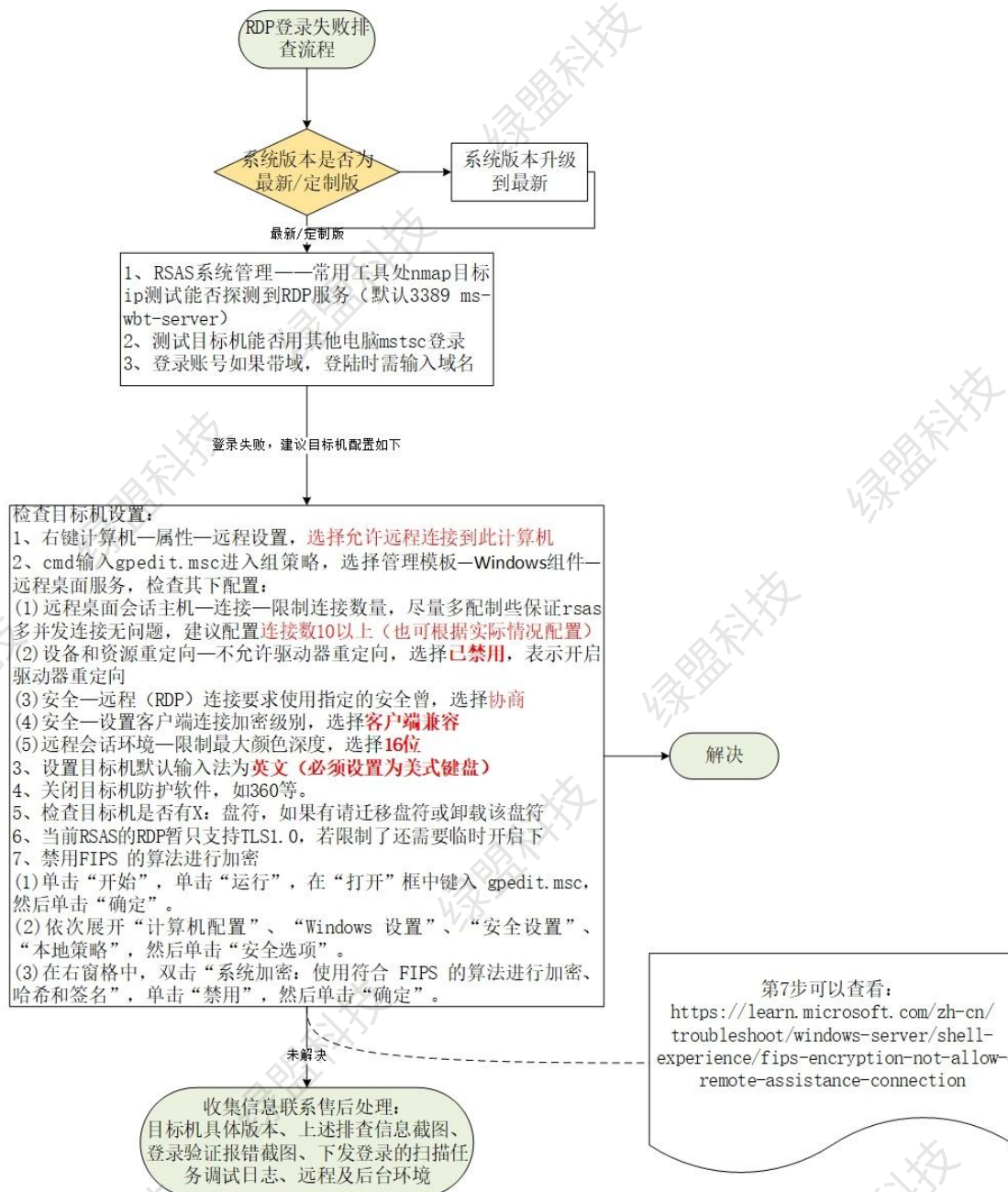
用浏览器打开 xml 文件报错提示在 406 行有问题，使用 notepad++打开 xml，查看第 406 行数据，发现有以下 ascii 字符：

```
402 HISTFILESIZE=40000
403 HISTTIMEFORMAT="%F %T %Z%"
404 export HISTSIZE HISTFILESIZE HISTTIMEFORMAT
405
406 -export PS1="[4m[37m[PROD "$USER@"`hostname`":"`$PWD#`]"[0m "]]></value>
407 </cmd>
408 </item>
409 <item flag="18279">
410 <cmd info="">
```

将报错行的 ascii 字符或者乱码字符删除后再用浏览器将 xml 打开访问，如无报错后再导入设备就没问题了

（十八） RDP 登录失败排查流程

1. 流程图



2. 流程答疑

- 1、除定制版本外，系统版本需保持当前官网最新，以便适配新版本 windows，并排除过往版本 bug 影响；
- 2、登录账户建议使用管理员权限账户，如 Administrator；
若需要对域账户进行扫描，可在填写主机登陆信息时填写域格式用户名（如：ZJYD\admin）
- 3、需使用常用工具 nmap 确认目标设备 RDP 端口开放，默认 3389 ms-wbt-server，如下：

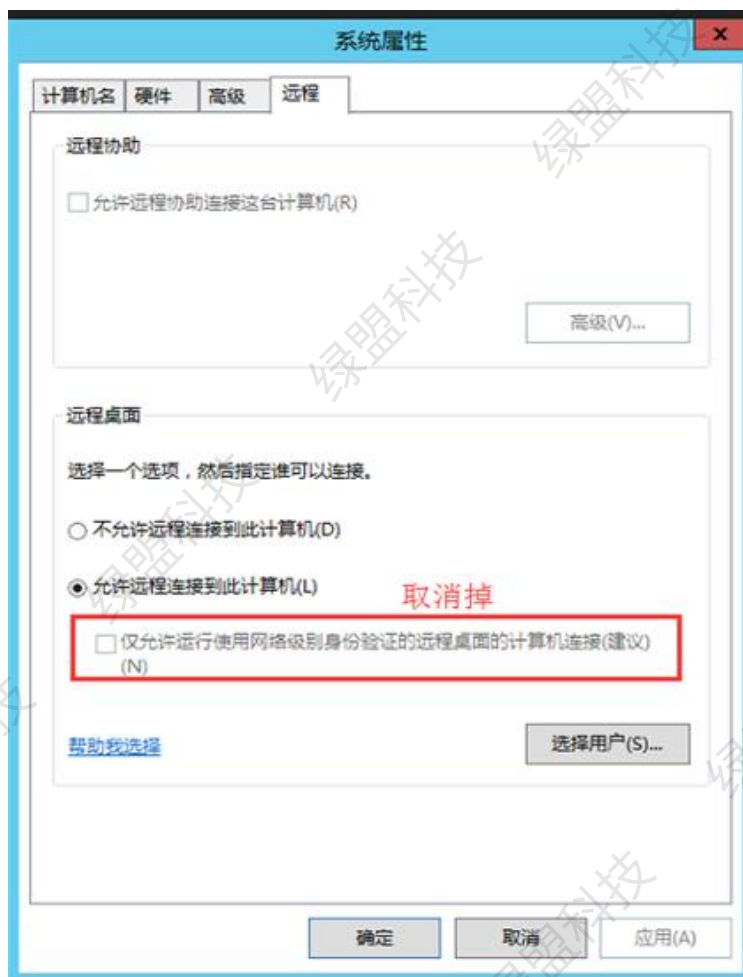


4、测试目标机能否用其他电脑 mstsc 登录：



5、检查服务器配置

(1) 计算机—属性—远程设置，取消勾选“仅允许运行使用网络级别身份验证的远程桌面的计算机连接”



(2) RDP 服务配置

仅 Windows server 2003:

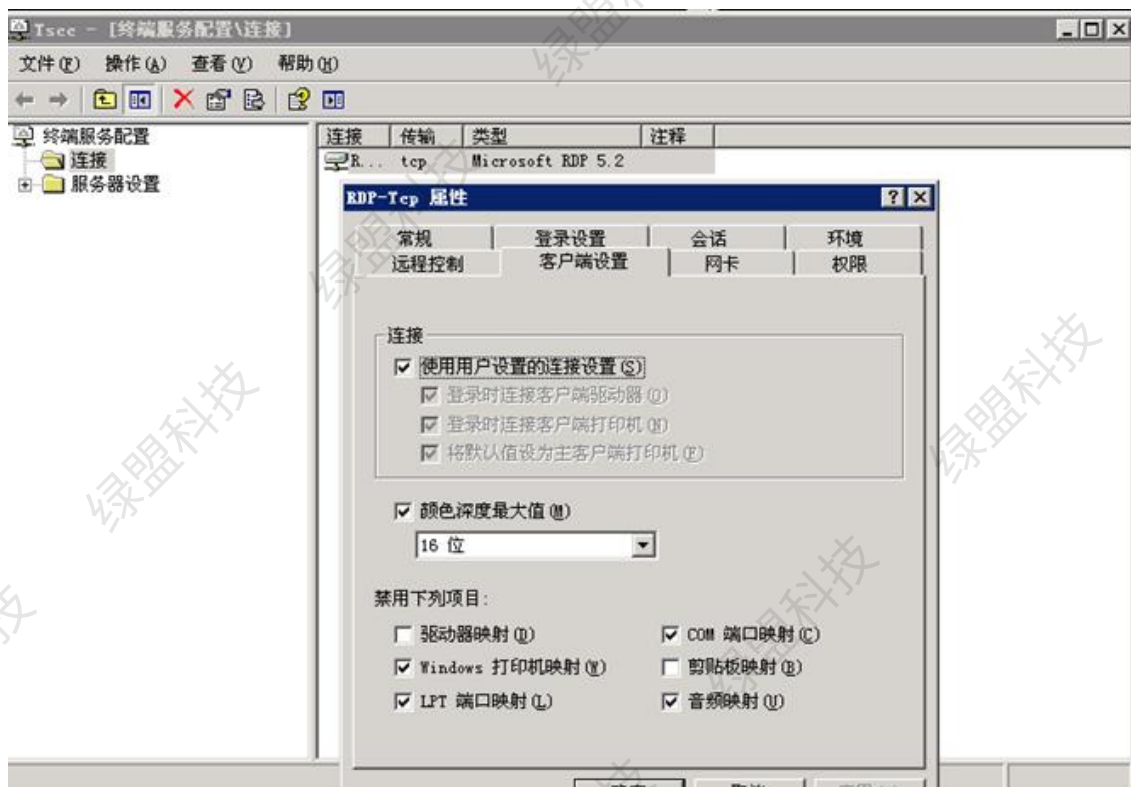
运行 (cmd) 中输入 Tscm.msc, 在终端服务器配置中查看 RDP-Tcp--客户端设置

- ① 远程 (RDP) 连接要求使用指定的安全层, 设置为“协商”
- ② 客户端连接加密级别“客户端兼容”



③ 最大颜色深度为“16”

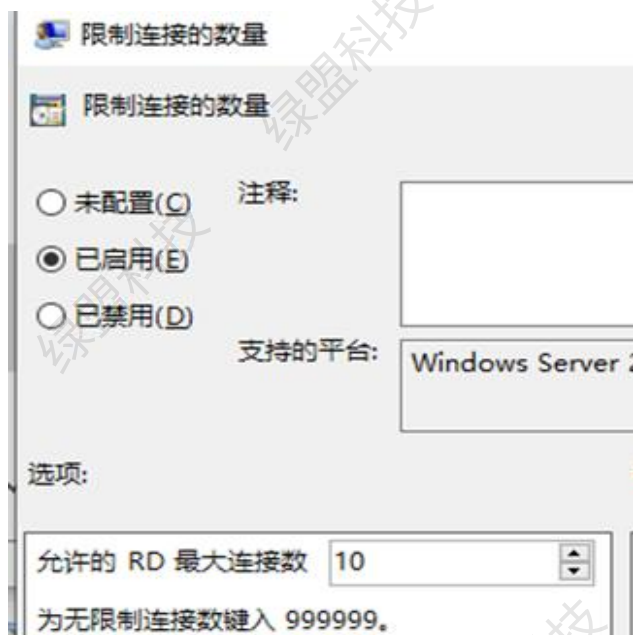
④ 是否禁用了”驱动器映射“——取消禁用

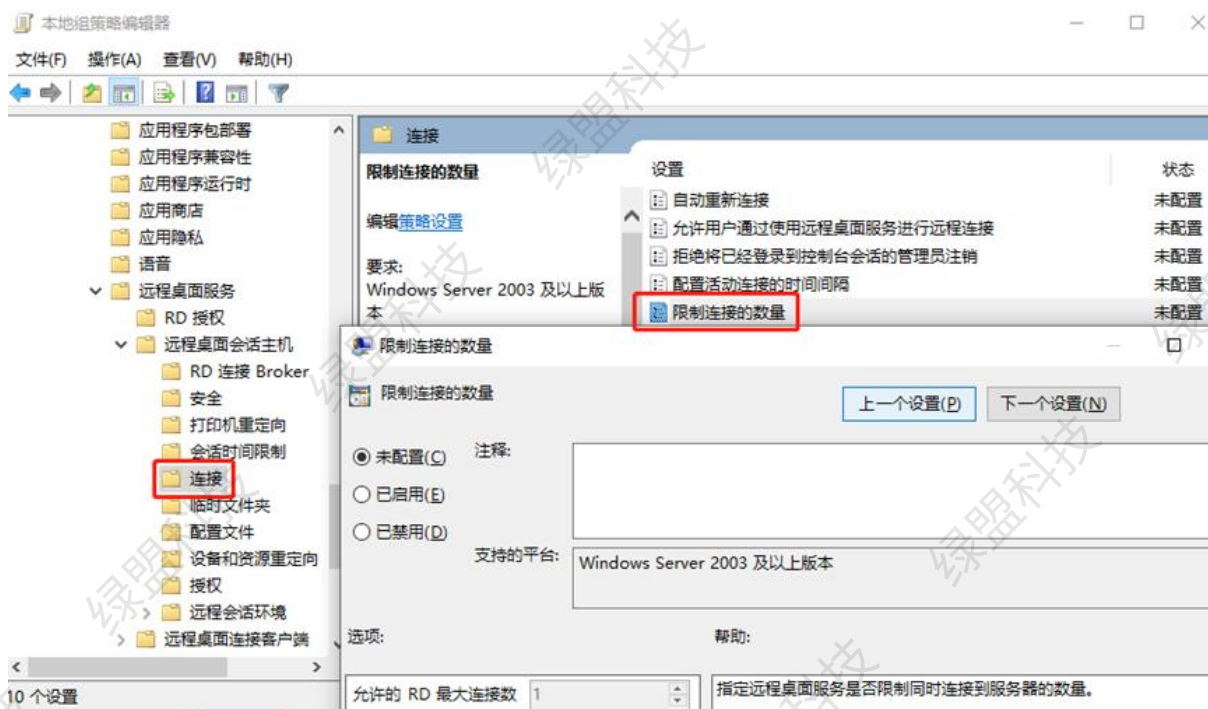


其他 Windows server/windows 版本（Vista 及其以后的系统）：

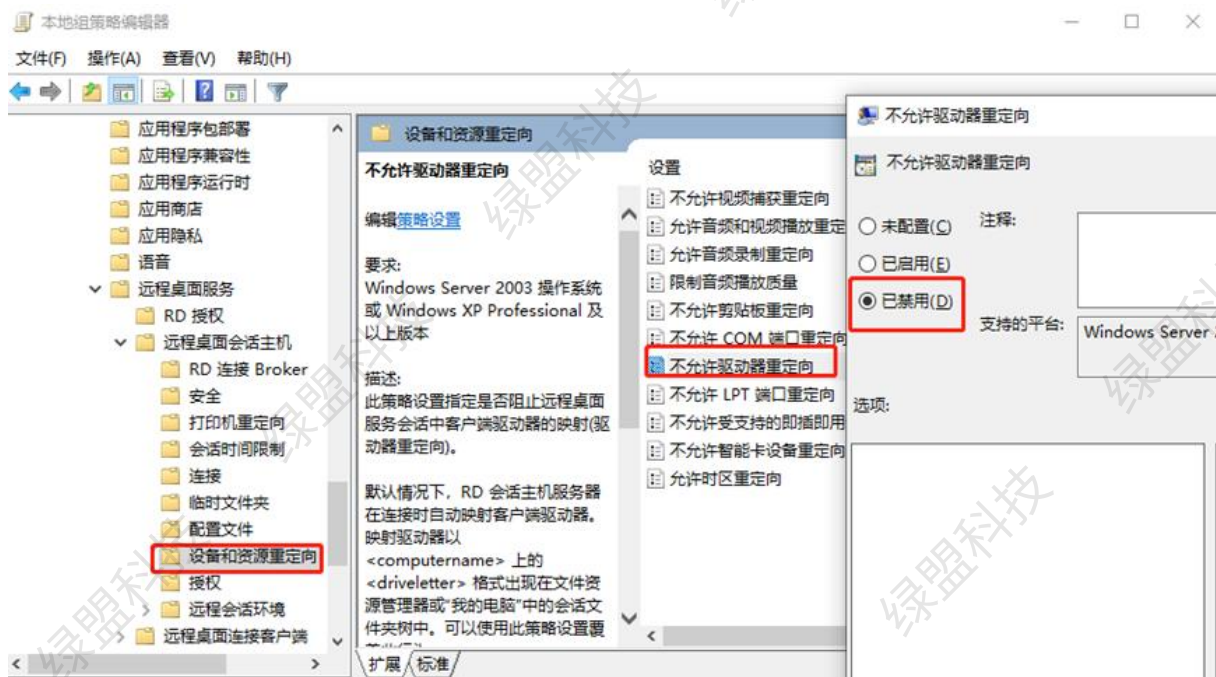
运行(cmd)中输入 gpedit.msc 进入组策略，选择管理模板—Windows 组件—远程桌面服务，检查以下配置：

① 远程桌面会话主机 ->连接 ->限制连接数量，配置连接数 10 以上（或者更大值）：

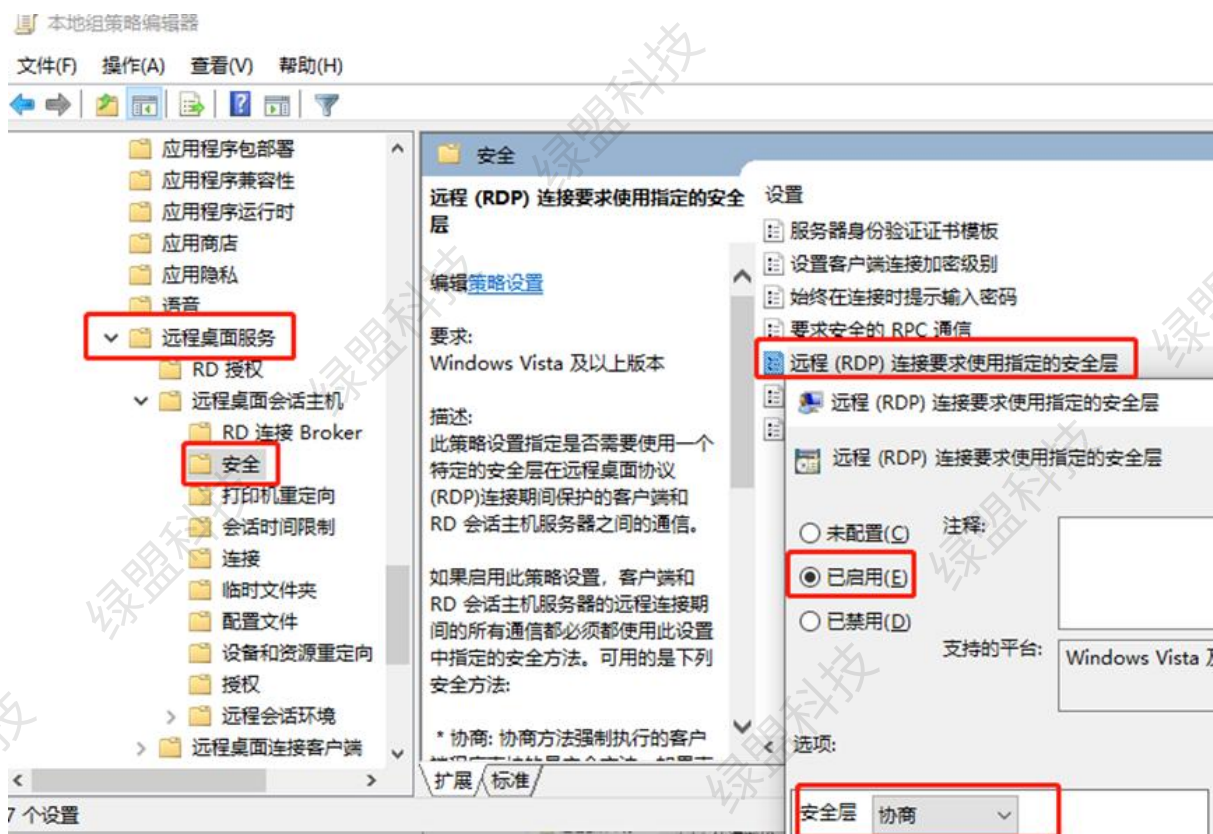




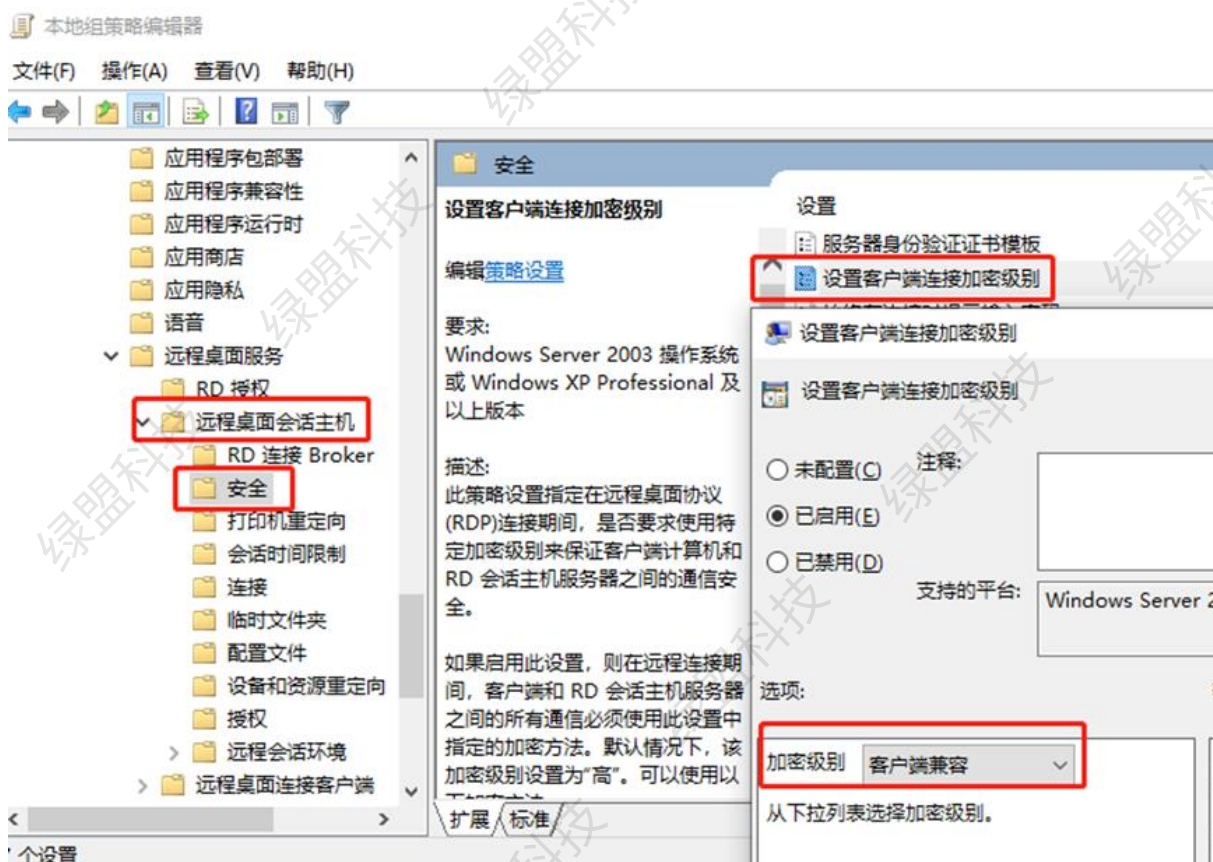
② 设备和资源重定向 -> 不允许驱动器重定向，选择已禁用，表示开启驱动器重定向



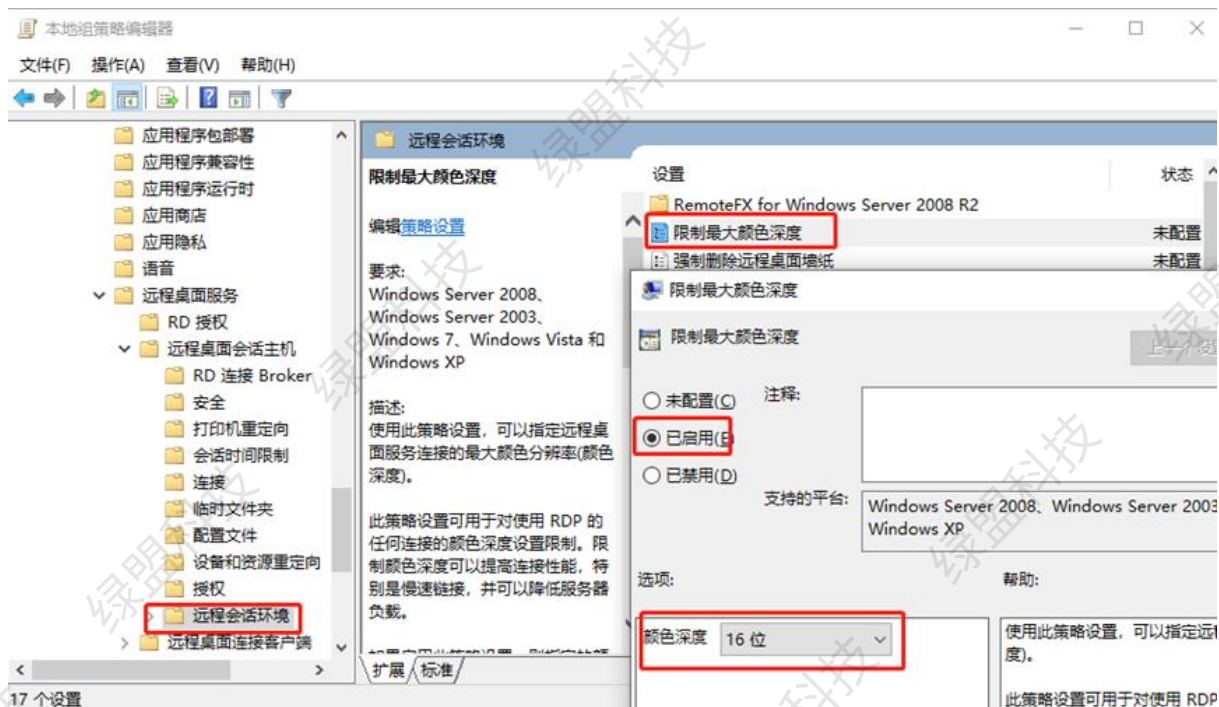
③ 安全 -> 远程 (RDP) 连接要求使用指定的安全层，选择协商



④ 安全 -> 远程设置客户端连接加密级别, 选择客户端兼容



⑤ 远程会话环境 -> 限制最大颜色深度, 选择 16 位



(3) 设备系统时间正确，且与扫描器一致

(4) 默认输入法必须为：英文键盘

举例 win10 设置方法如下，其他操作系统设置方法类似（也可在控制面板中设置），如不会设置可百度设置方法：





← 设置

高级键盘设置

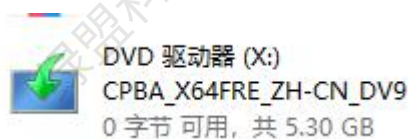
替代默认输入法



由于扫描器 RDP 登录时，需要执行一些命令，如果设备默认输入法是中文，就会使命令转换为中文乱码执行不成功导致登录失败。如果是因为中文输入法导致的登录失败，在目标机上输入 cmd 查看历史命令就能看到乱码现象：



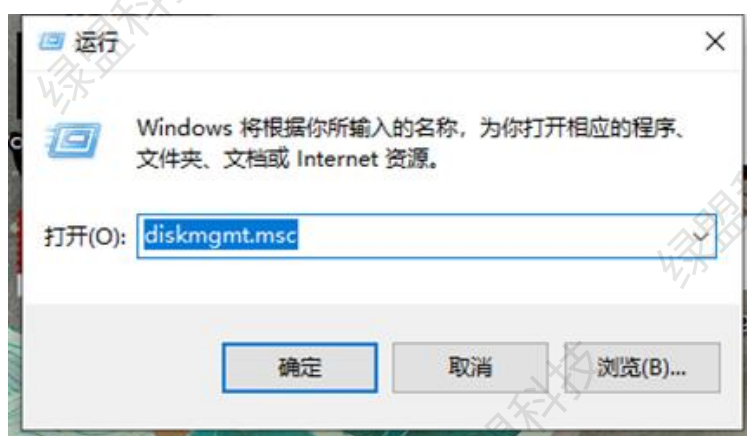
- 1、 关闭目标防护软件，如 360 等。
- 2、 检查目标及是否有 X: 盘符



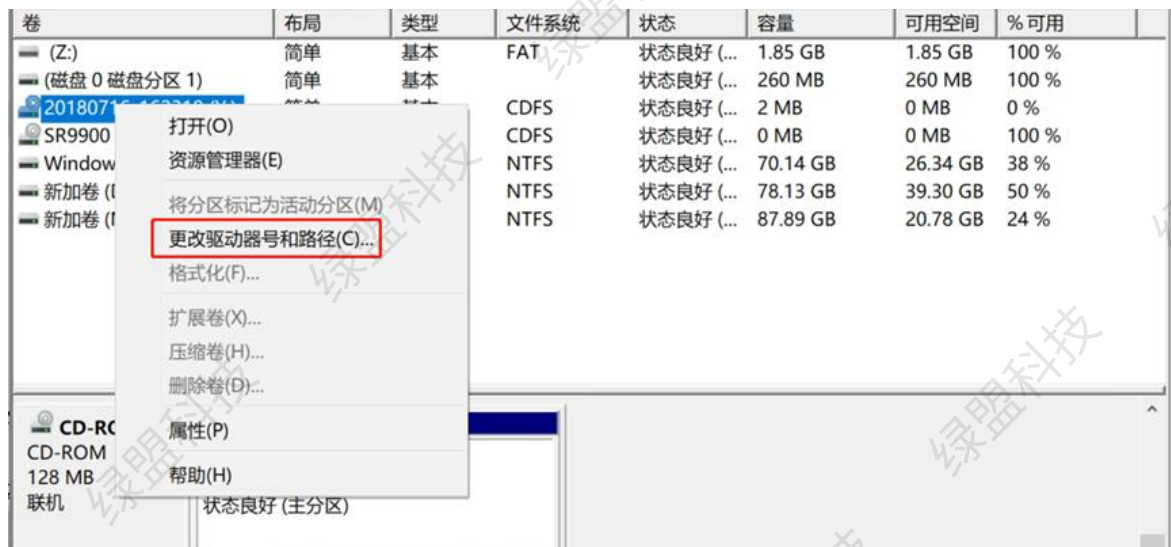
如果有请卸载或更改盘符占用

修改盘符方法：

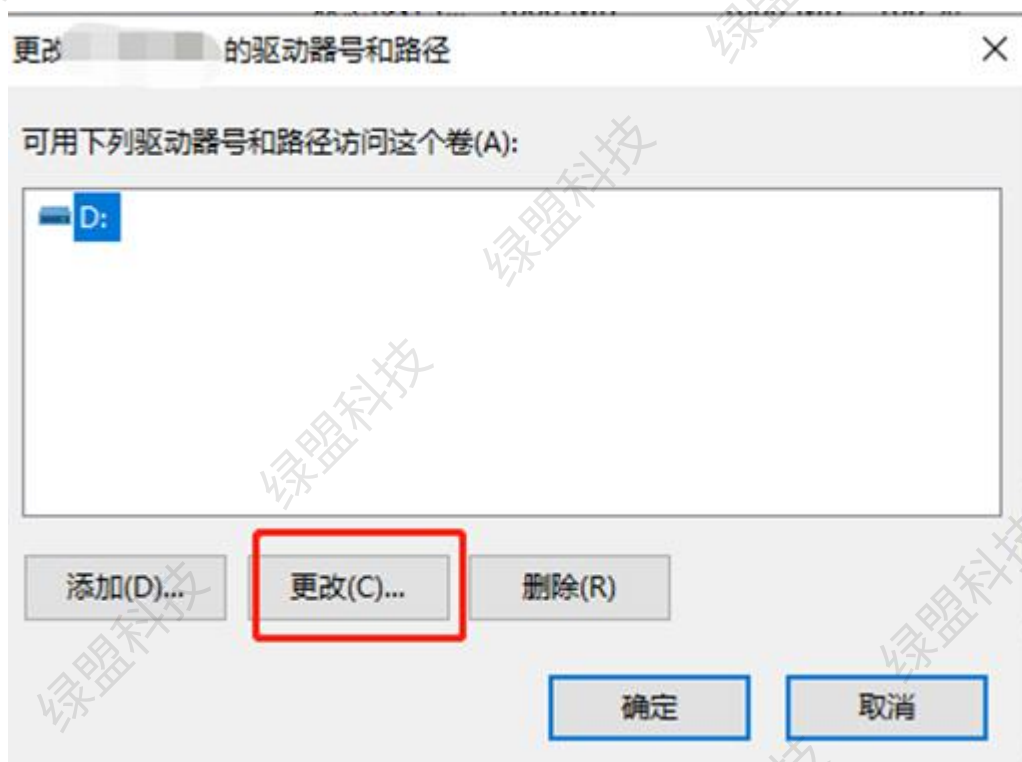
右键“此电脑”，选择管理（或者 cmd 下直接运行 diskmgmt.msc）：



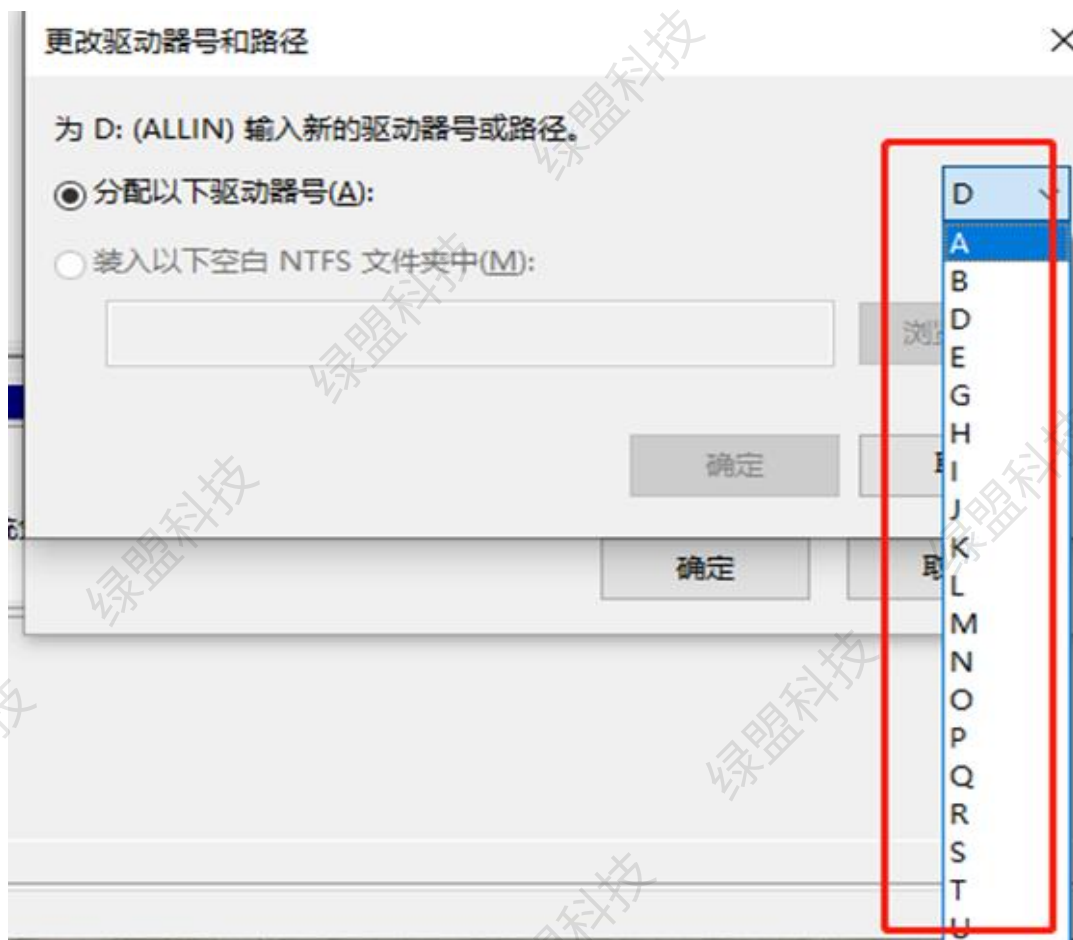
进入磁盘管理： 分别对配置核查 U 盘的代码盘和数据盘进行盘符修改，右键选中对应的盘，选择更改驱动器号和路径：



选择更改：

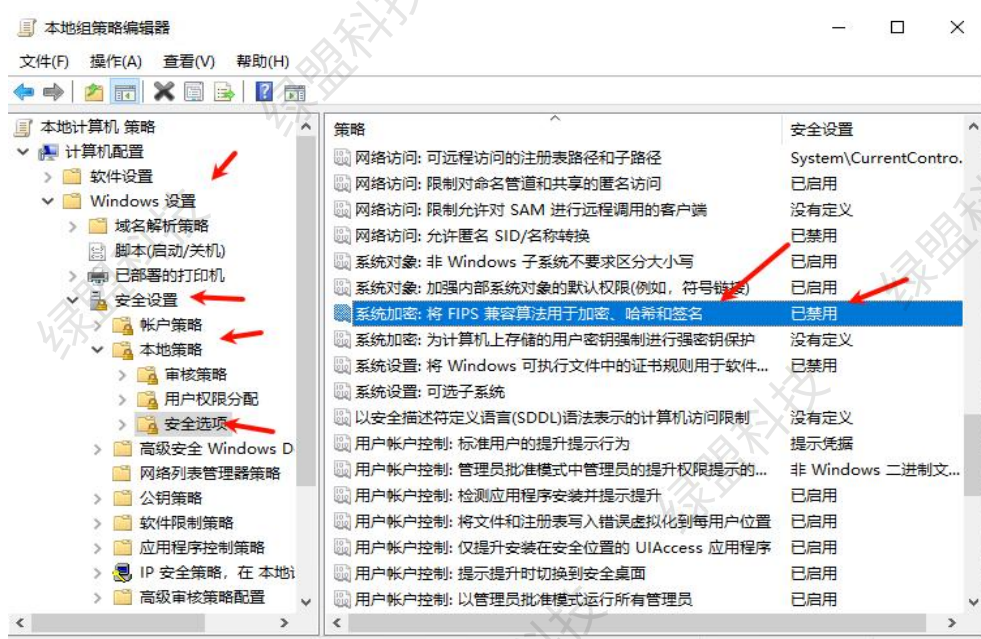


选择修改后的盘符（建议将盘符设置到靠后面的字母，比如代码盘设置为 Y，数据盘设置为 Z）：



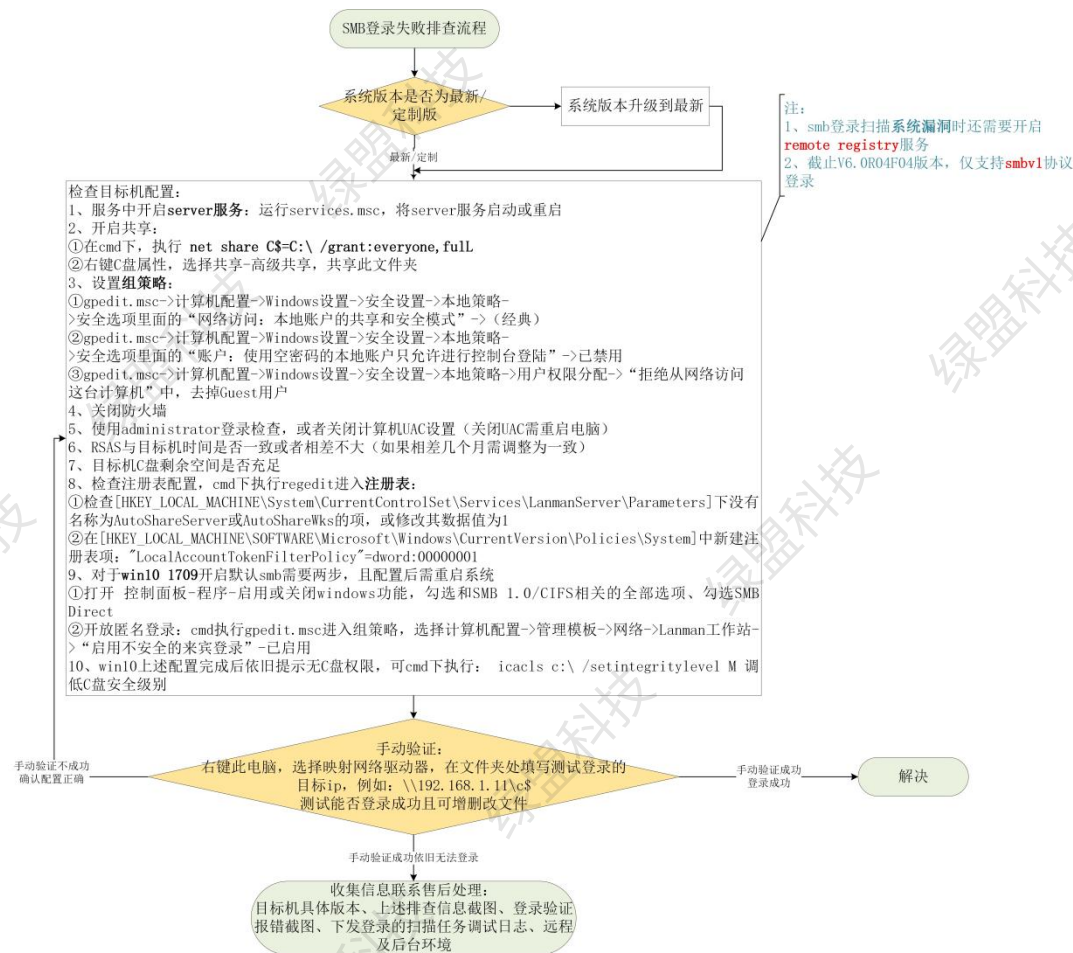
选择盘符后点击确定即可。数据盘和代码盘均按照上述方法修改后就可。

- 3、禁用 FIPS 的算法进行加密，可以参考：[远程协助连接不起作用 - WINDOWS SERVER | MICROSOFT LEARN](#)



(十九) SMB 登录失败排除流程

1. 流程图

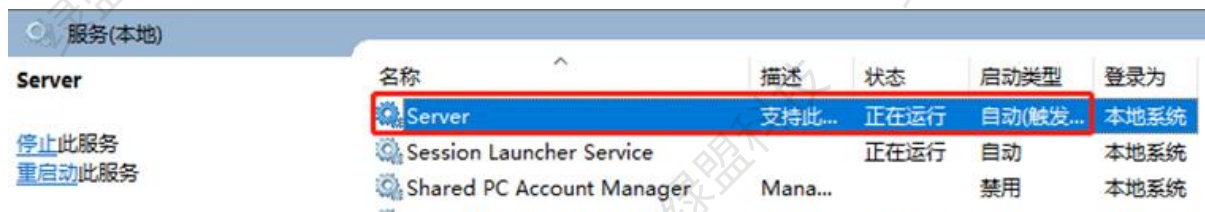


2. 流程答疑

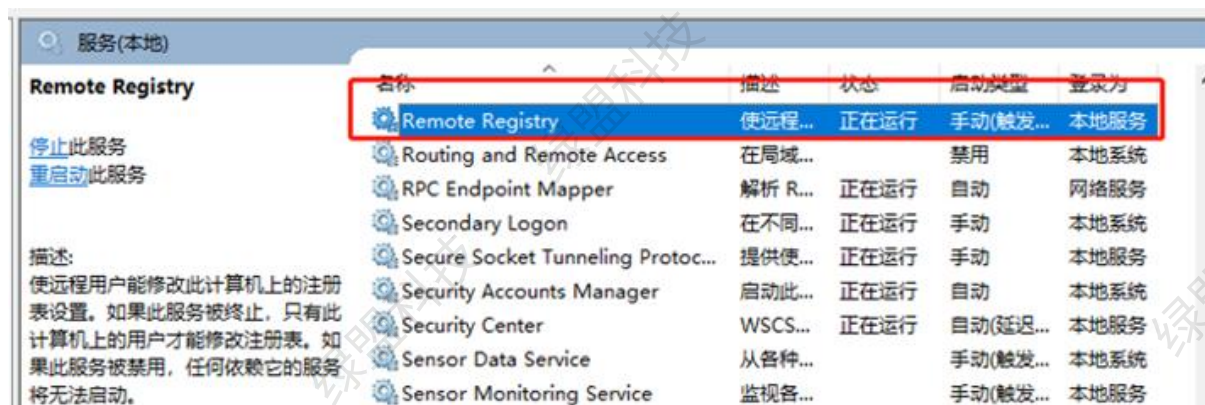
1、系统插件必须保持当前官网最新，以排除过往版本的 bug 影响

2、确认目标服务器的 ssh 端口是否开放

1、目标服务器是否有连接数等其他特殊限制



如果是 smb 登录扫描系统漏洞，则还需开启 remote registry 服务（仅做配置核查时，此服务可不开启），否则无法远程读取注册表



(2) 是否有主机防火墙或其他安全设备阻断。

若有，则关闭主机防火墙、对扫描器做安全策略放过。



3、登录账户建议使用管理员权限账户，如 administrator；

若需要对域账户进行扫描，可在填写主机登陆信息时填写域格式用户名（如：ZJYD\admin）

4、SMB 登录必须开启 C\$默认共享且 C\$具有可读可写权限。

①C 盘共享需执行两步

1) cmd 下执行：net share C\$=C:\ /grant:everyone,full

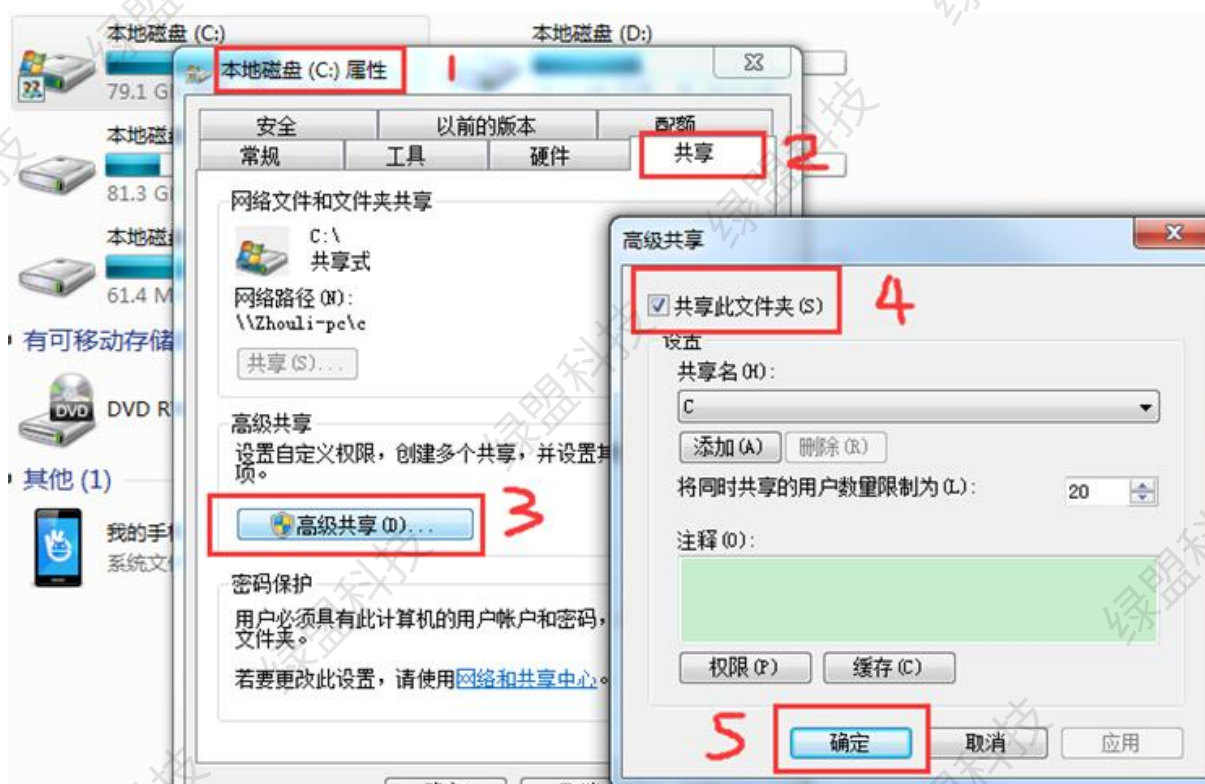

```
C:\Documents and Settings\Administrator>net share C$=C:\ /grant:everyone,full
C$ 共享成功。

C:\Documents and Settings\Administrator>net share

共享名      资源      注释
-----
IPC$         C:\WINDOWS 远程 IPC
ADMIN$       C:\WINDOWS 远程管理
C$           C:\         默认共享

命令成功完成。
```

2) 右键 C 盘属性，选择共享-高级共享，共享此文件夹



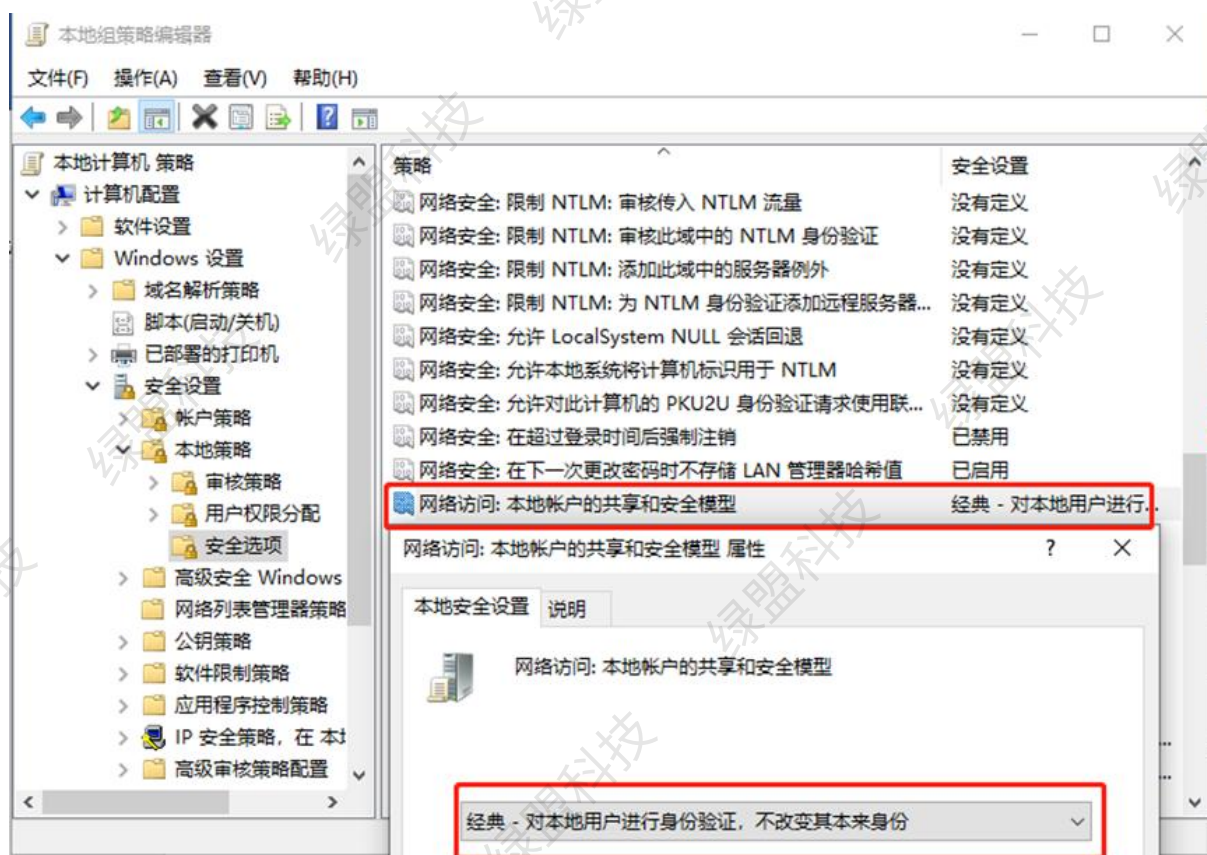
②目标服务器 C\$ 权限查看：net share C\$

```
C:\Documents and Settings\Administrator>net share C$
共享名      C$
路径       C:\
注释       默认共享
用户上限    无限制
用户       无限制
正在缓存    手动缓存文档
权限       Everyone, FULL

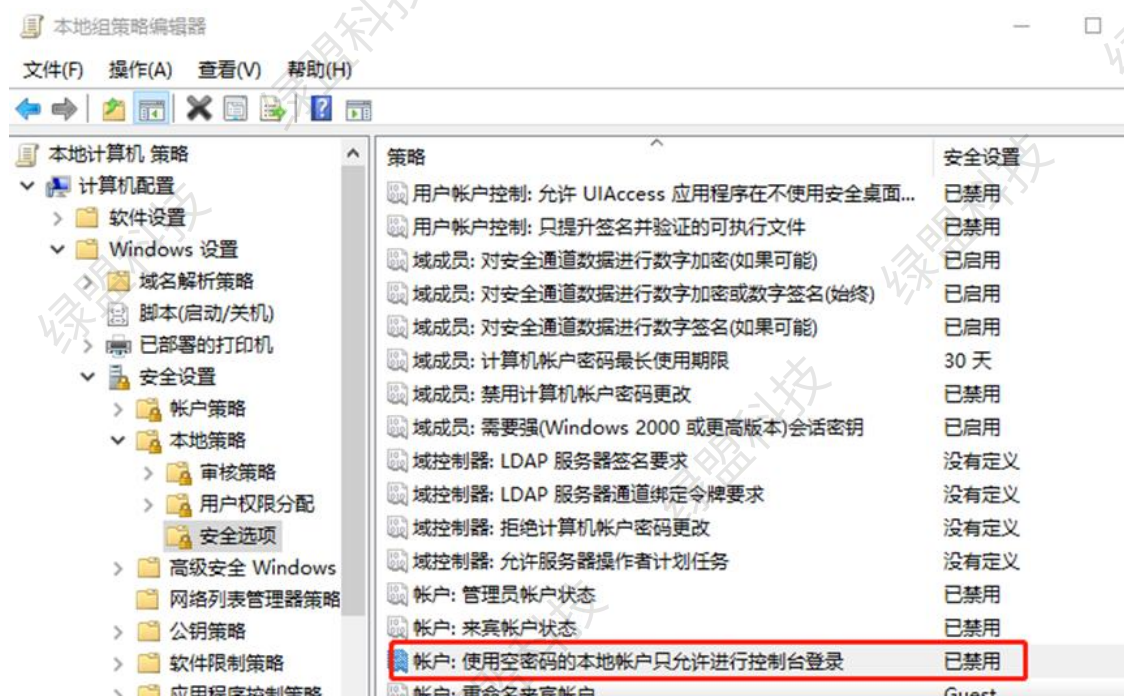
命令成功完成。
```

5、设置以下组策略：

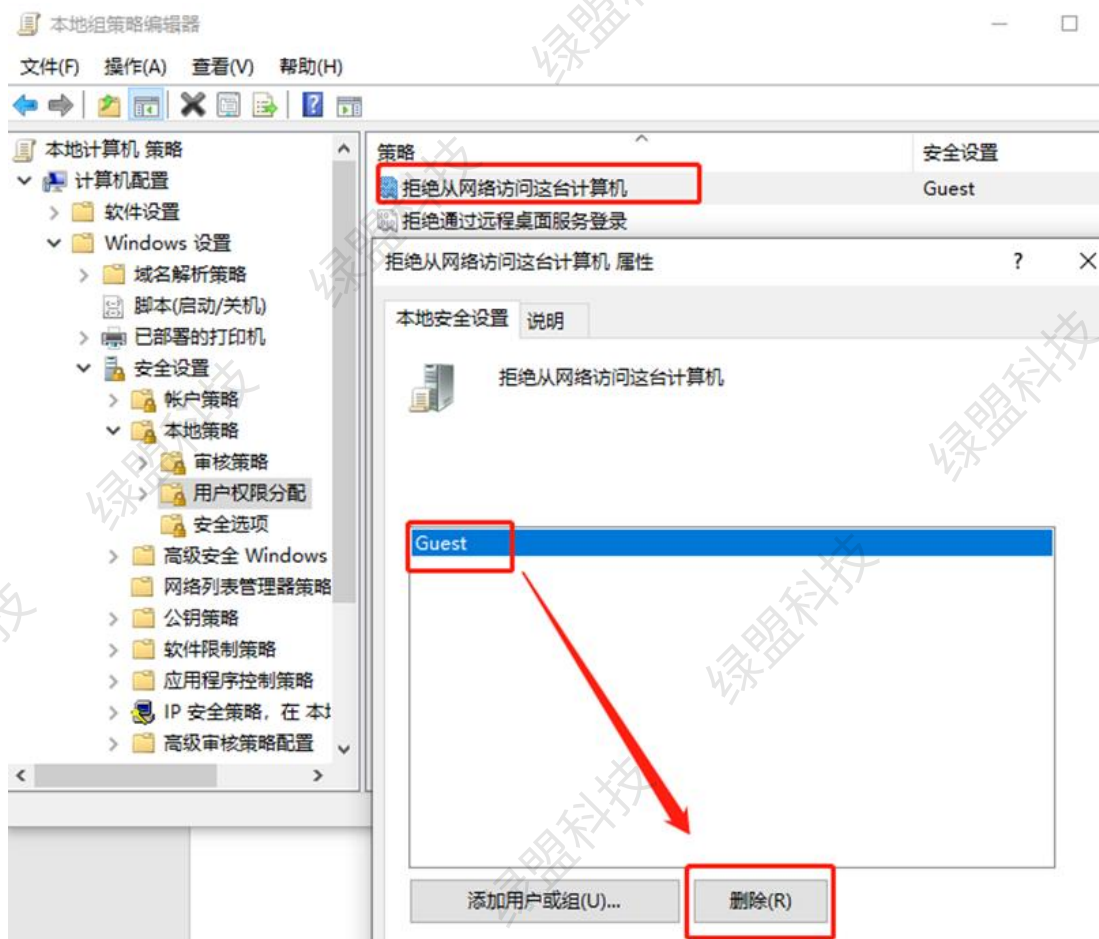
①运行中输入 gpedit.msc 在计算机配置\Windows 设置\安全设置\本地策略\安全选项里面的“网络访问：本地帐户的共享和安全模式”（经典）



②运行中输入 gpedit.msc 在计算机配置\Windows 设置\安全设置\本地策略\安全选项里面的“账户：使用空密码的本地帐户只允许进行控制台登录” à 已禁用



③运行中输入 gpedit.msc 计算机配置 本地策略 用户权限分配 “拒绝从网络访问这台计算机” 中删除 guest 账号



6、NT6 及其以上系统（Vista 及其以后的系统）上，关闭 UAC 提权或者使用 administrator 登录扫描。关闭 UAC 需重启系统，操作方法如下：



7、扫描器设备与目标的系统时间相差过大，需将时间调整为一致。

8、查看 C 盘空间是否已满，如果磁盘已满需要清理出一定空间。

9、检查注册表配置，cmd 下执行 regedit 进入注册表：

①检查：

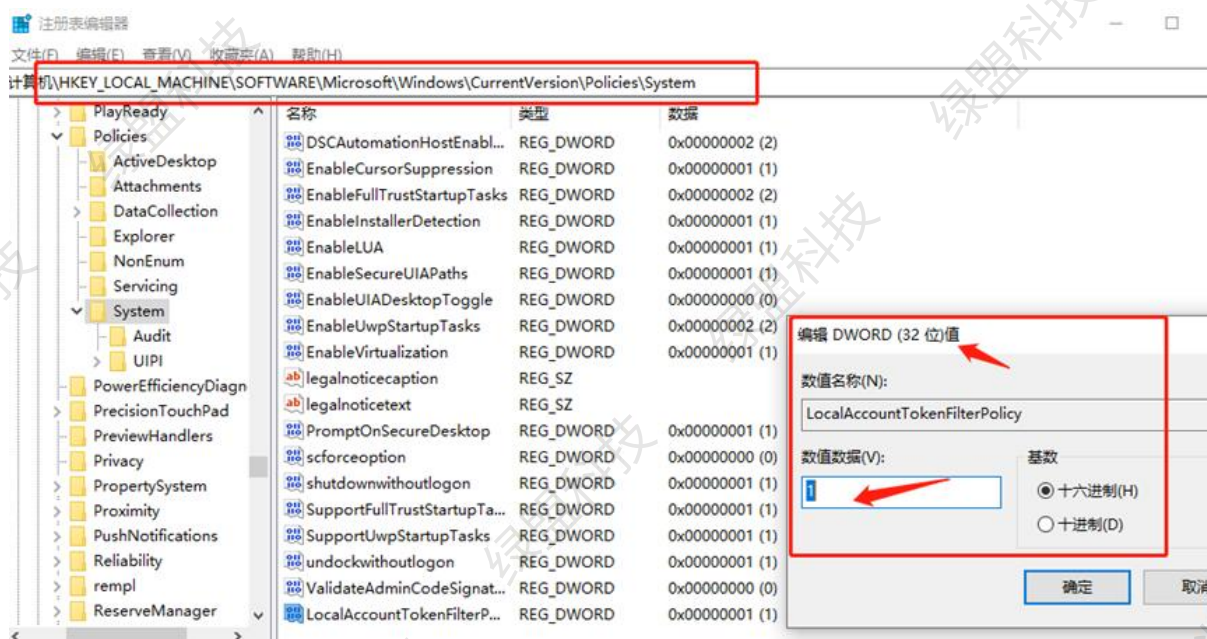
[HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanServer\Parameters]

下没有名称为 AutoShareServer 或 AutoShareWks 的项，或修改其数据值为 1

②在：

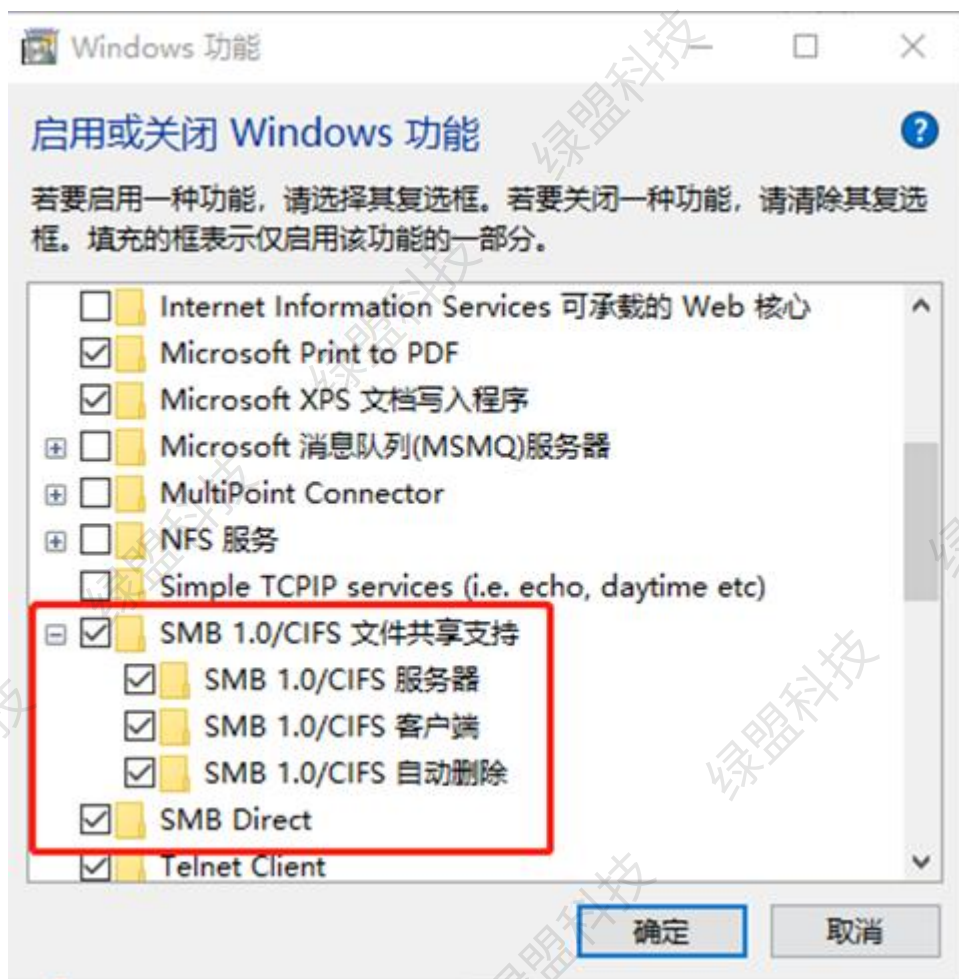
[HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System]

中新建注册表项：“LocalAccountTokenFilterPolicy”=dword:00000001

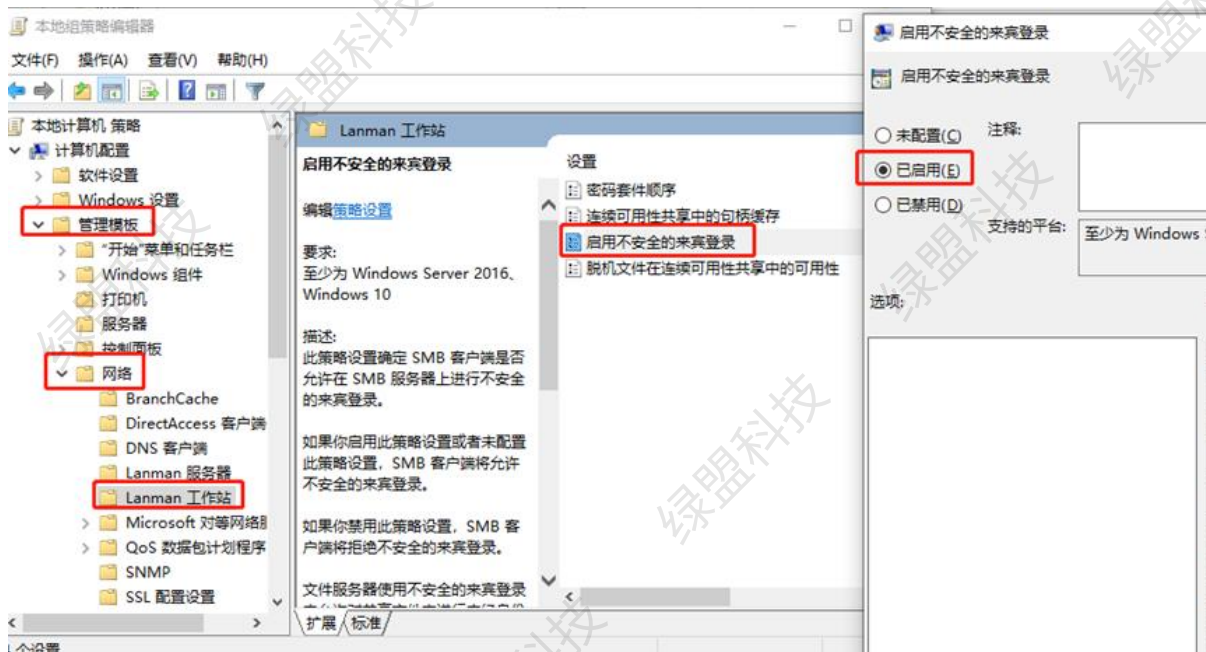


10、对于 win10 1709 开启默认 smb 需要两步，且配置后需重启系统

①打开 控制面板-程序-启用或关闭 windows 功能，勾选和 SMB 1.0/CIFS 相关的全部选项、勾选 SMB Direct



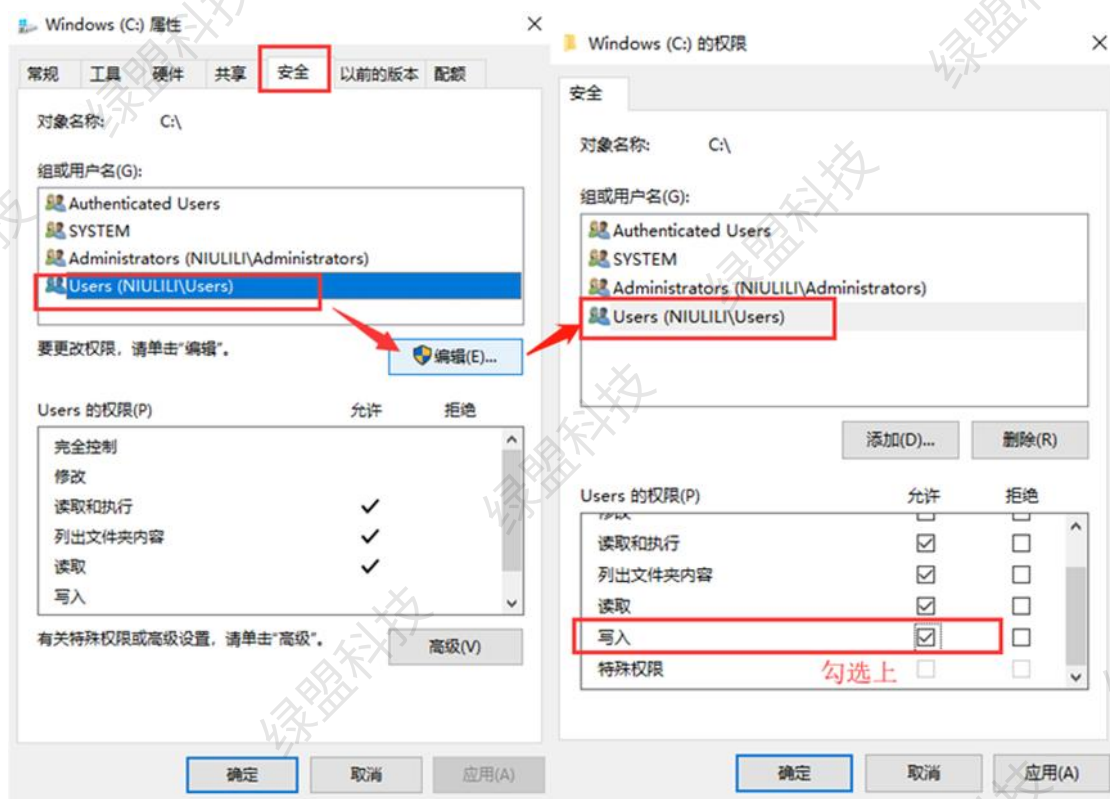
② 开放匿名登录：cmd 执行 gpedit.msc 进入组策略，选择计算机配置->管理模板->网络->Lanman 工作站->“启用不安全的来宾登录”-已启用



- 1、 win10 电脑若配置 C 盘共享后访问共享时依旧无权限新建和删除文件，则用管理员权限运行 cmd，输入： `icacls c:\ /setintegritylevel M`，将 C 盘安全级别下调至 M 级：

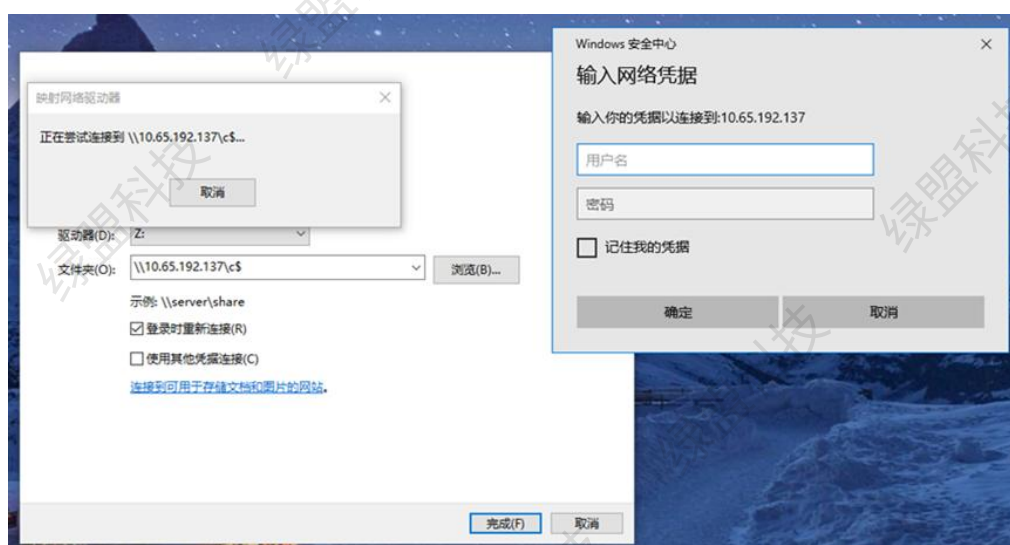
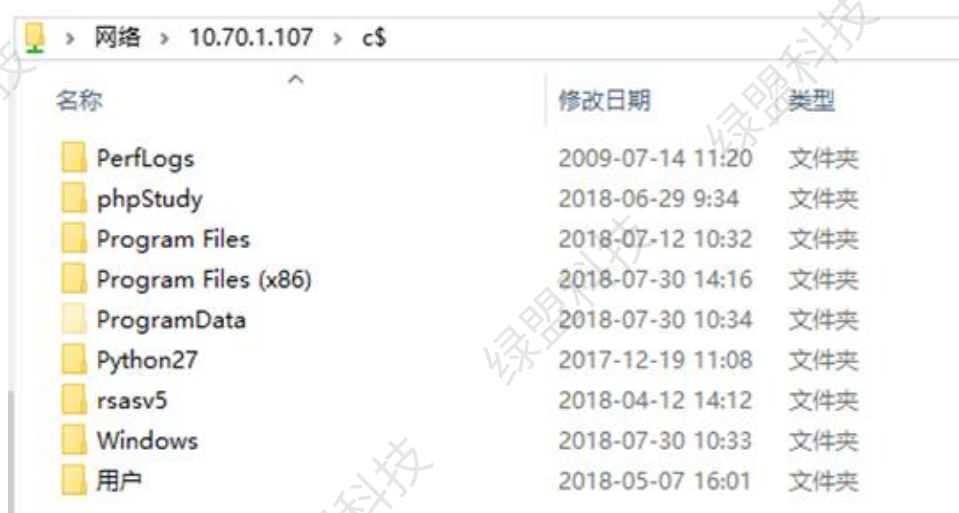


如果还是不能创建文件的话，右键点击 C 盘：属性 > 安全，把写权限赋予 Users 组，点击应用并确定（如果弹出错误提示不用理会，点击“继续”即可）

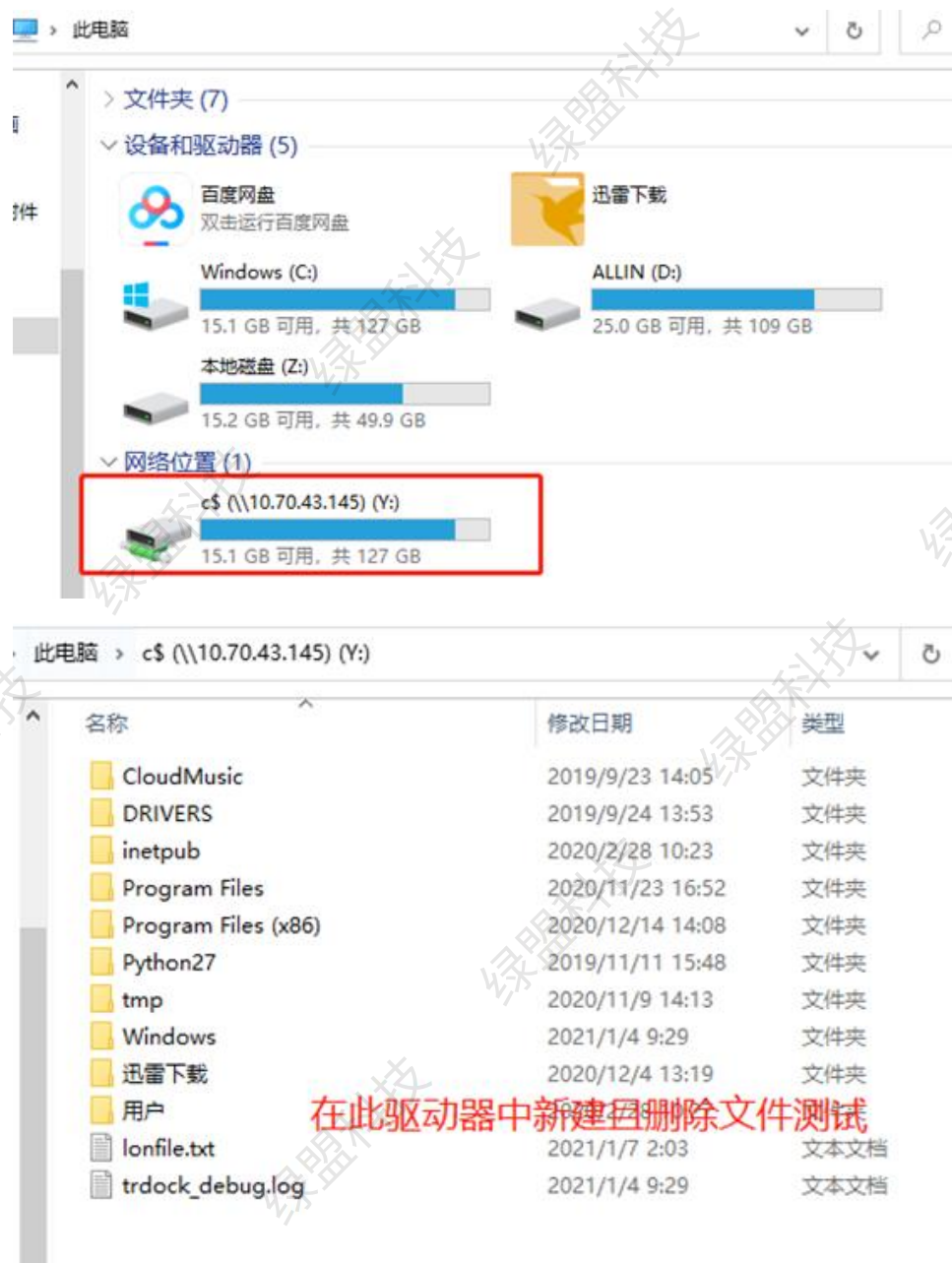


确认上述配置无误后，使用以下方法验证是否能成功登录且新建删除文件：

- (1) 右键此电脑，选择映射网络驱动器



(1) 登录成功后选择刚映射的驱动器，进行新建删除文件测试，保证可写权限

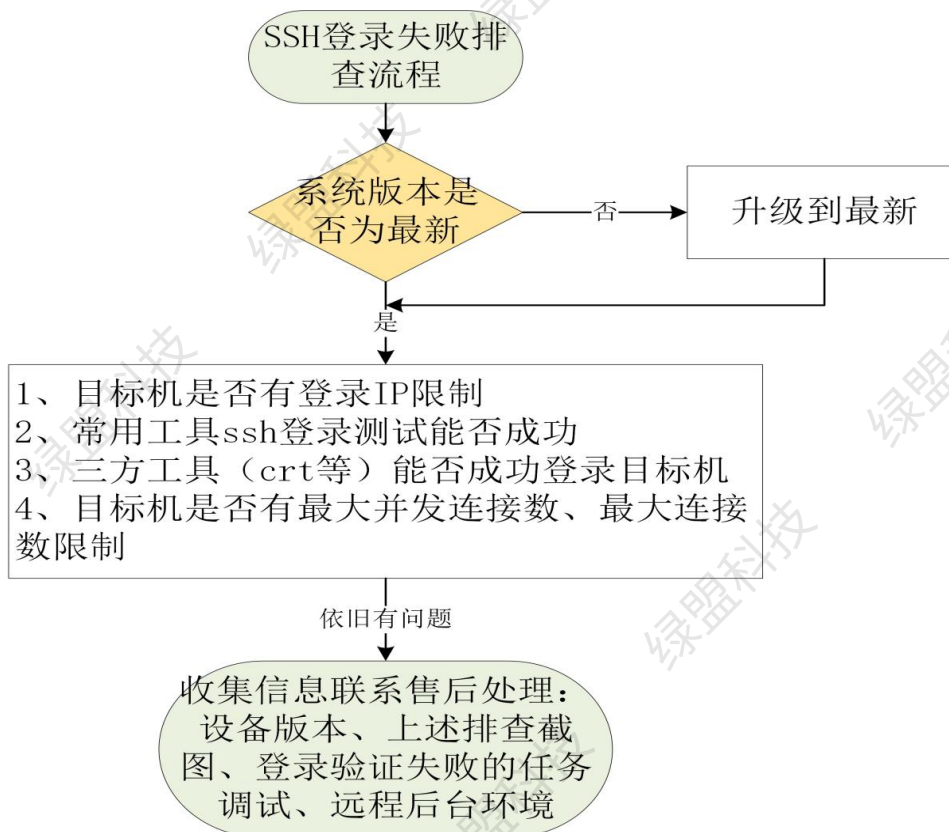


测试完成后记得断开此链接，避免影响后续扫描器登录：



(二十) SSH 登陆失败排查流程

1. 流程图

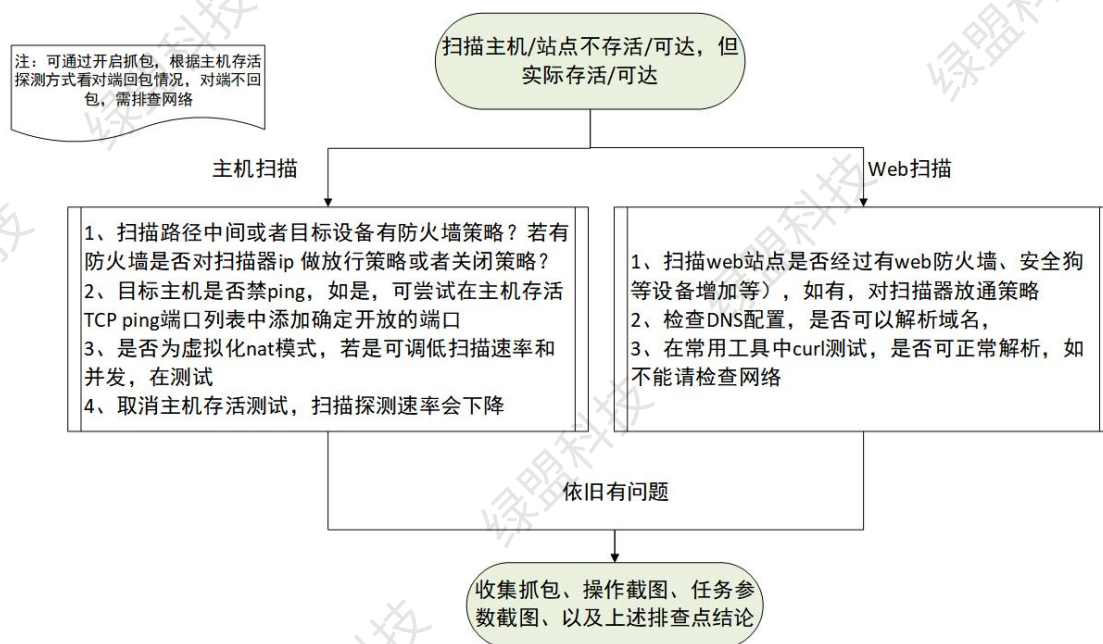


2. 流程答疑

- 1、系统插件必须保持当前官网最新，以排除过往版本的 bug 影响
- 2、确认目标服务器的 ssh 端口是否开放
- 3、目标服务器是否有连接数等其他特殊限制

(二十一) 扫描主机/站点不存活/可达，但实际存活/可达

1. 流程图



2. 流程答疑

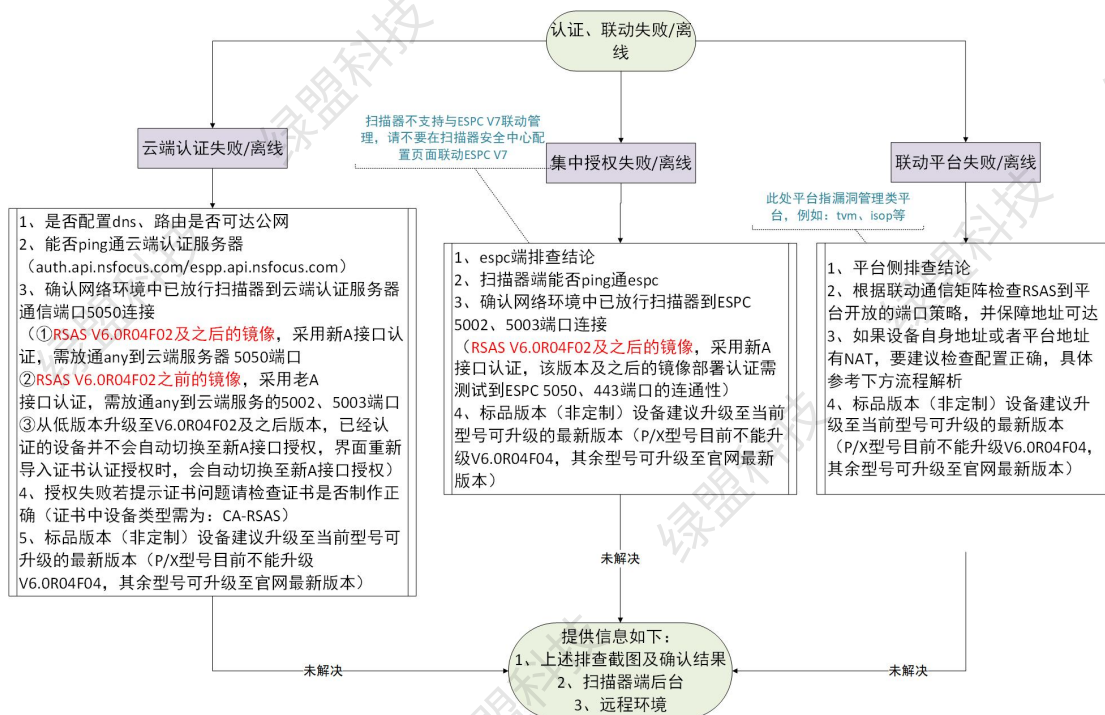
- 1 系统主机存活探测默认开启 ICMP 以及 TCP PING 探测指定端口，如果目标禁 ping，可在 TCP PING 端口列表中添加确认开放的端口，最多支持填写 30 个端口



2 由于 NAT 网络会由网关设备代理内部设备建立网络连接,因此在端口服务操作系统识别阶段, nmap 处于 NAT 网络内部或者处于经过 NAT 连接网络的虚拟机内部时, nmap 扫描基本上到 NAT 设备就终止了,最终影响端口服务及操作系统识别结果,最终可能影响扫描结果,推荐使用桥接。

(二十二) 认证、联动失败/离线

1. 流程图



2. 流程答疑

- 1、涉及到平台联动或者 ESPC 集中授权问题，需要先检查平台侧网络或配置情况，如未能解决，可联系 RSAS 支持团队继续排查
- 2、针对平台联动或离线的问题，先确认网络环境中无限制，根据 RSAS 部署手册中通讯矩阵要求检查端口开放情况

V6.0R04F02SP04 及以上版本所需开放的网络策略

RSAS端口	流量方向	TVM/ISOP端口
TCP: 1-65535 随机端口	→	TCP: 5050、443（用于首次注册）、4399（心跳上报）、10000（http通道）、10002（cmd通道）

V6.0R04F02SP04 及以下版本所需开放的网络策略

RSAS端口	流量方向	ESPC（集中授权平台）
TCP: 1-65535 随机端口	→	TCP: 5050、5007、5008
TCP: 5050	←	TCP: 1-65535 随机端口

- 3、针对联动场景，注意检查配置参数

- ①本地 IP 地址：RSAS 与 TVM/ISOP 通信时，RSAS 本机使用的 IP 地址
企业安全中心地址：TVM/ISOP 与 RSAS 通信时，使用的 IP 地址和端口号（默认 443）
- ②若 ISOP/TVM web 使用自定义端口，则 RSAS 上的端口也需保持一致，填写其自定义端口
- ③若平台自身配置 NAT，选择菜单 > 配置 > 南向管理，进入网络配置页面

配置项	描述
采集器内网IP	平台真实IP地址，如192.168.88.11
采集器外网IP	平台NAT环境下IP地址，如10.65.128.105
设备IP	扫描器外网IP，如10.65.41.3

- ④若 RSAS 自身地址有 NAT，平台没有，注意 RSAS 本地地址填写 NAT 后地址

新建任务
任务列表
报表输出
仪表盘
告警平台
资产管理
认证管理
模板管理
系统管理
联动管理
安全中心
Agent联动

基本配置

本地IP地址: 10.65.41.3
云安全中心地址: espp.api.nsfocus.com
企业安全中心地址: 10.65.128.105
IP地址: 221.122.179.2
端口: 443
版本: TVM/ISOP
启动: ☒ 启动

设备物理地址与平台联动，输入设备物理地址；
设备NAT地址与平台联动，输入设备NAT地址

设备与平台通信的TVM地址

设备与平台通信的TVM登录地址

⑤如果设备和平台两侧都有 NAT，则参考上述检查设备和平台对应的配置

⑥验证平台与设备连通性

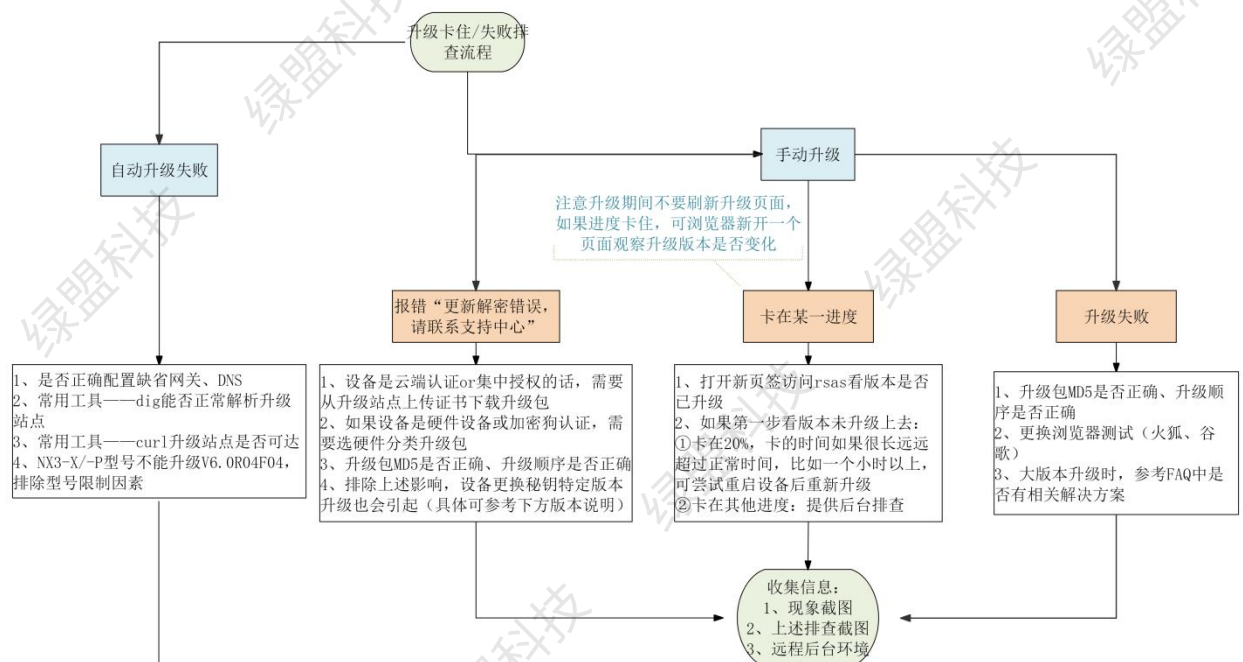
使用 telnet 工具测试 TVM 端口与 RSAS 的连通性，测试端口包括 443、4399、5050，如图所示测试 TVM 端口 4399 与 RSAS 连通性



4、ESPC V6 支持联动及集中授权扫描器，ESPC V7 仅支持集中授权扫描器。且集中授权均不需要在扫描器安全中心处配置 ESPC 地址，只需要在集中授权处正确填写本地 IP 及 espc IP，点击确定后将自动注册到 espc 端进行授权

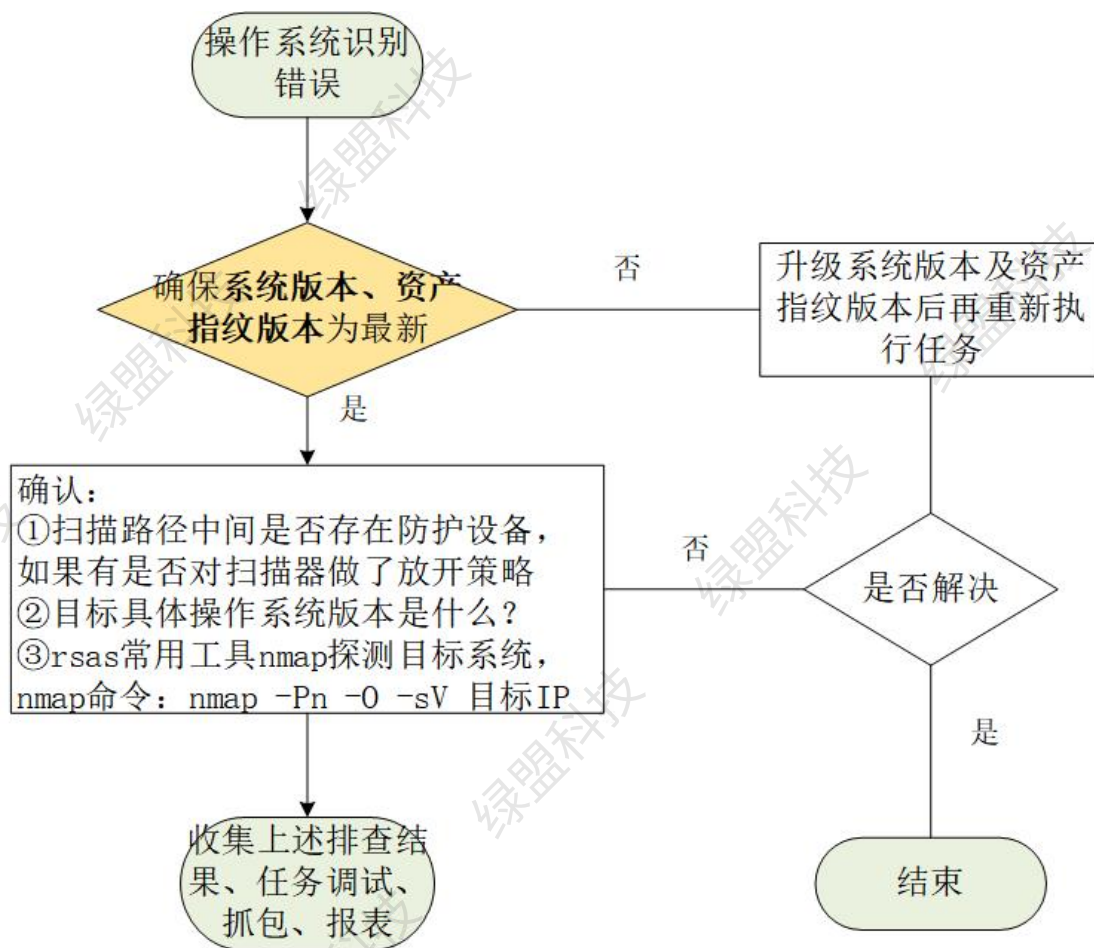
(二十三) 升级卡住、失败排查流程

1. 流程图



（二十四）操作系统识别错误排查流程

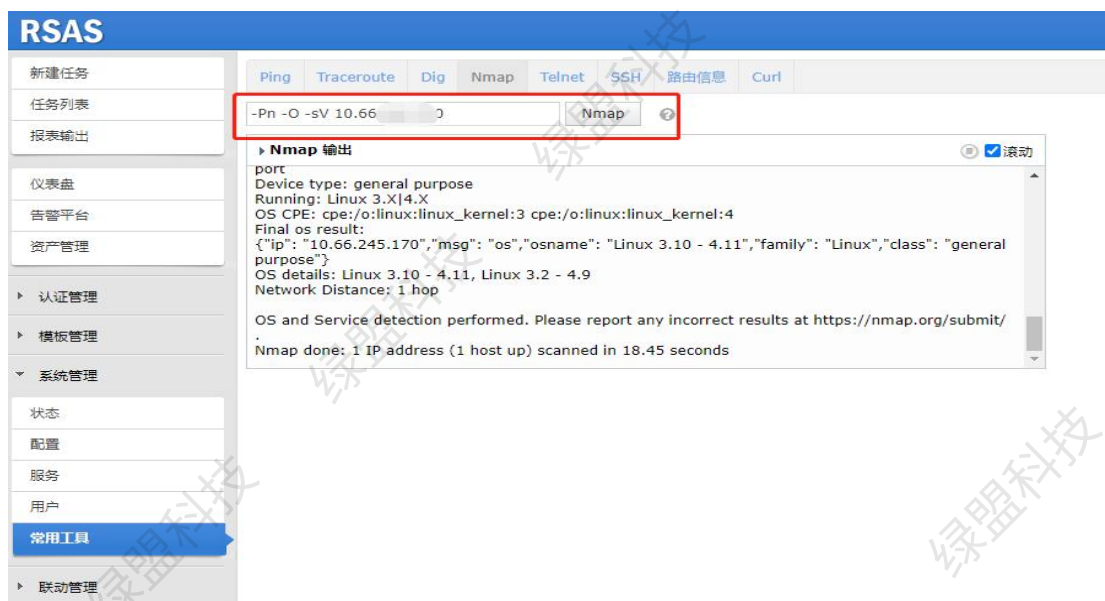
1. 流程图



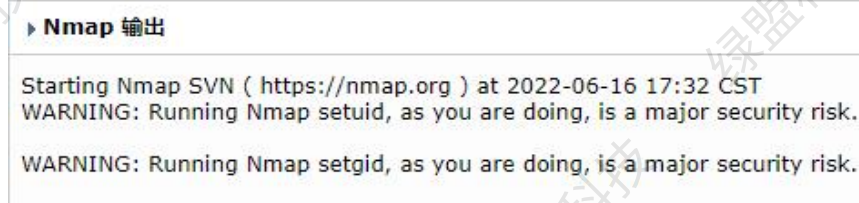
2. 流程答疑

举例流程图中 nmap 命令执行方法，执行后将所有结果贴到 txt 中收集：

命令：nmap -Pn -O -sV 目标 IP

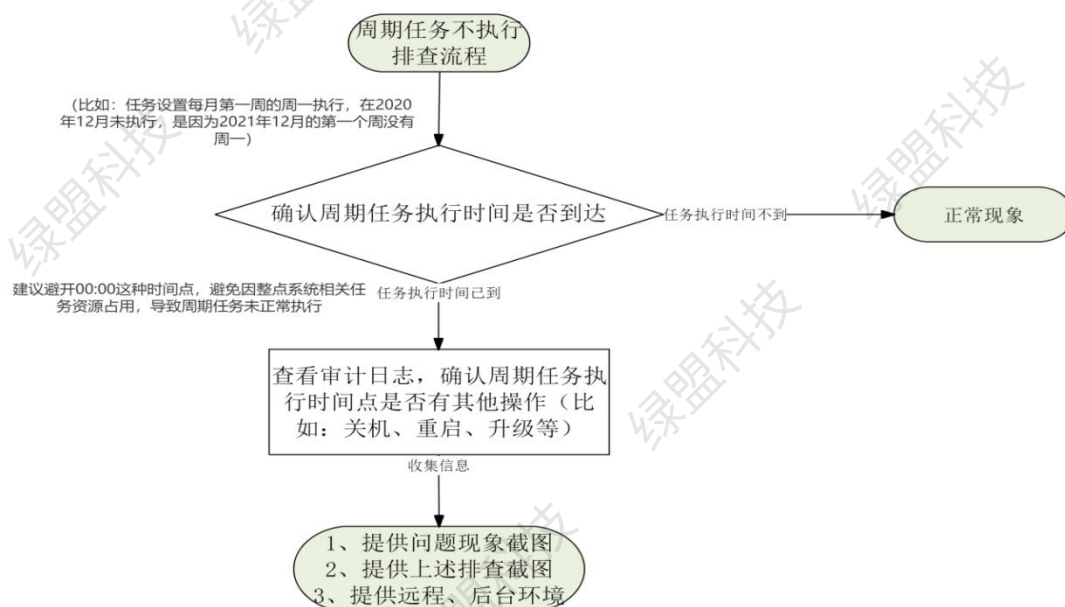


注意，开始出现以下提示时并不是报错，命令还在执行，需等待执行完成才会输出上述结果：



(二十五) 周期任务不执行排查流程

1. 流程图



2. 排查示例

【经典案例一】

设置的周期任务，每月的第一周星期一执行，在 2020 年 12 月末执行

任务类型	评估任务
执行方式	周期任务 执行时间：每月的第1周星期一 12:00
调度优先级	中
任务状态	正在扫描
下达任务的账户	sysmanager
漏洞扫描模板	自动匹配扫描
登录检查	否
启用SSH免密登录	否
任务来源	本地扫描

排查过程：

查看日历，发现 2020 年 12 月第一周是没有周日的，第一周是从周二开始的，因此 12 月周期任务不执行：

2020年12月						
一	二	三	四	五	六	日
30 十六	1 十七	2 十八	3 十九	4 二十	5 廿一	6 廿二
7 大雪	8 廿四	9 廿五	10 廿六	11 廿七	12 廿八	13 廿九
14 三十	15 十一月	16 初二	17 初三	18 初四	19 初五	20 初六
21 冬至	22 初八	23 初九	24 初十	25 十一	26 十二	27 十三
28 十四	29 十五	30 十六	31 十七	1 十八	2 十九	3 二十
4 廿一	5 小寒	6 廿三	7 廿四	8 廿五	9 廿六	10 廿七

【经典案例二】

周期任务设置的每月 31 号执行，在 4 月和 6 月未执行：

1793	批量扫描 (等保)			
☐ 全选全部子任务				
☐ 2299	批量扫描 (等保)	2020-08-31 14:01:01		
☐ 2294	批量扫描 (等保)	2020-07-31 14:01:00	2020-07-31 18:03:49	
☐ 1858	批量扫描 (等保)	2020-05-31 14:01:01	2020-05-31 17:16:11	
☐ 1795	批量扫描 (等保)	2020-03-31 14:01:00	2020-03-31 17:58:46	

排查过程：

查看日历，4 月和 6 月没有 31 号，所以不执行

(二十六) 系统扫描两次扫描结果存在差异

1. 流程图

注：如要对比两次扫描差异原因，需收集调试、抓包、报表。
但全端口扫描的包量很大，扫描器抓包大小有限制，有可能抓不全包，这类情况尽量协调客户提供后台，由二线在后台抓取全端口扫描时的报文进行分析。

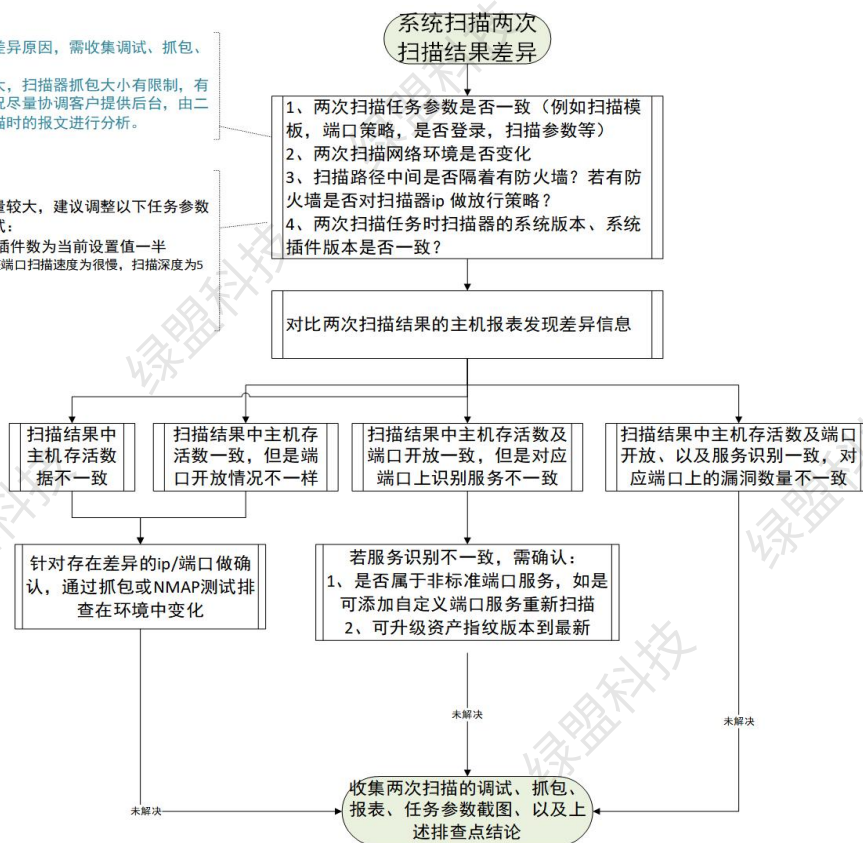
全端口扫描：

由于全端口扫描总发包量较大，建议调整以下任务参数降低发包频率后复扫测试：

- 1、降低并发ip数、并发插件数为当前设置值一半
- 2、新建任务-高级选项：调整端口扫描速度为很慢，扫描深度为5

标准端口扫描：

按流程收集信息



（二十七）web 扫描两次扫描结果存在差异

1. 27.1 流程图

